

SAP BTP Documentation - SECURITY IDENTITY

BTP Documentation: security-identity

URL: <https://help.sap.com/docs/btp/btp-admin-guide/complying-with-data-protection-and-privacy-requirements>

Title: *Complying with Data Protection and Privacy Requirements* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelComplying with Data Protection and Privacy Requirements
SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Complying with Data Protection and Privacy Requirements

All companies must respect data protection and privacy rights of individuals. Data protection and privacy most likely influences the architecture and functionalities of your application and should be considered as early as possible in the development process.

It's important you understand that simply using SAP software, such as SAP BTP, does not make your applications compliant. However, SAP software can help you achieve compliance. You should consult legal experts to determine the requirements for your applications and specific use cases.

Note

SAP does not provide legal advice in any form. SAP software supports data protection compliance by providing security features and data protection-relevant functions that can help to establish a compliant identity lifecycle management. In many cases, compliance with applicable data protection and privacy laws is not covered by a single product feature, and sometimes, not even within a product. For instance, users' wish to delete their personal data usually requires data deletion in several integrated systems.

Furthermore, this information should not be taken as advice or a recommendation regarding additional features that would be required in specific IT environments. Decisions related to data protection must be made on a case-by-case basis, taking into consideration the given system landscape and the applicable legal requirements.

To find out which services are available with EU Access, visit the SAP Discovery Center.

Related Informationà^

SAP BTP Data Protection and Privacy

URL: <https://help.sap.com/docs/btp/btp-admin-guide/security-concepts>

Title: *Security Concepts* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelSecurity Concepts
SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Security Concepts

The level of security you implement varies depending on your use case and your company's general security requirements. However, there are a few best practices that we recommend, regardless of your implementation.

SAP BTP Security Recommendationsà^

SAP BTP Security Recommendations collects information, which enables you to secure the configuration and operation of SAP BTP services in your landscape.

For more information, see SAP BTP Security Recommendations.

Network Security Aspectsà^

The SAP BTP landscape runs in an isolated network that is protected from the outside by firewalls, a DMZ, and communication proxies for all inbound and outbound communication. All user access is protected with transport layer security (TLS).

For more information, see Transport Layer Security (TLS) Connectivity Support.

User and Member Managementà^

On SAP BTP, member management happens at all levels from global account to environment, while user management is done for business applications.

Before diving into the different user and member management concepts, it's important to understand the

difference between the different types of users we're referring to: Platform users and business users.

Platform and Business Users

Platform users are usually developers, administrators or operators who deploy, administer, and troubleshoot applications and services on SAP BTP. They're the users that you give certain permissions for instance at global account or subaccount level, by adding them as members.

Member management refers to managing permissions for platform users. You can think about it as managing the members of your team.

Member management happens at global account, directory, subaccount, and environment level. Members' permissions apply to all operations that are associated with the global account, the organization, or the space, irrespective of the tool used. Depending on the scope you're using, you manage members in different ways.

Business users use the applications that are deployed to SAP BTP. For example, the end users of SaaS apps or services, such as SAP Workflow service or SAP Cloud Integration, or end users of your custom applications are business users.

Restrict access to applications through authentication and authorization. Identity and authorization management ensures that only the intended group, such as employees of your company, can access your applications.

Global accounts and subaccounts get their users from identity providers. There's a default identity provider or administrators can configure custom identity providers. Administrators decide which identity providers to trust and grant access rights to users from these identity providers. You have full control over your user base.

Identity Providers and Federation

SAP BTP supports identity federation, a concept of linking and reusing digital identities of a user base across loosely coupled systems. Identity federation frees applications on SAP BTP as well as the platform itself from the need to obtain and store the credentials of users and to authenticate them. Instead, the user base is reused from identity providers, which support the administration of digital user identities, authentication, and authorizations in a centralized and decoupled manner. To enable communication between SAP BTP and identity providers, you must cross-configure the communication endpoints of the involved systems, establishing a trust relationship between them.

Identity Federation

The two types of users on SAP BTP, platform users and business users, have separate trust configurations for identity providers. Platform users share one or more identity providers configured for the global account and further apply to the directory, subaccount, and the environment levels. Business users use the identity provider configured individually for each subaccount.

The following figure shows the default trust configuration for SAP BTP as well as a possible custom configuration for platform and business users.

Trust Relationship Between SAP BTP and Identity Providers

Note

Some services have their own user store or trust configuration. For the ABAP environment, business users reside in the ABAP user store. SAP HANA Database users have their own user store. The Kyma environment has a separate trust configuration from the subaccount.

Once a user is authenticated, single sign-on enables the user to log on to other trusted applications without reauthenticating. Principal propagation enables applications to pass credentials to back-end systems without requiring the user to reauthenticate. For technical users, principal propagation isn't needed for back-end access.

URL: <https://help.sap.com/docs/btp/btp-admin-guide/setting-up-access-to-remote-systems>

Title: *Setting Up Access to Remote Systems | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelSetting Up Access to Remote Systems
SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Setting Up Access to Remote Systems

Use SAP Connectivity service to enable your SAP BTP applications to access remote services on the Internet or in your on-premise systems. For connecting to Internet services, we recommend that you use APIs with destinations, and for cloud-to-on-premise scenarios, we recommend that you use destinations and the Cloud Connector.

If you use destinations, you achieve a separation between the application and the configuration, which means it's easier to make configuration changes. And you can use the destinations to store credentials and certificates. You can create destinations on two different levels:

Subaccount level

Service instance level

If a destination should be available for the entire subaccount, you can create it on subaccount level. If it is used for a specific scenario only, we recommend that you create it on service instance level. For security reasons, the respective access authorizations should be limited to a minimum for each level.

For more information, see:

Using the Destinations Editor in the Cockpit

Access the Destinations Editor

Multitenancy in the Connectivity Service

The Cloud Connector is a lightweight on-premise agent that establishes a tunnel for connecting your cloud applications to on-premise systems. The Cloud Connector acts as a reverse invoke between the on-premise network and SAP BTP. That means you don't need to open in-bound ports in the firewall for external access from the cloud. The Cloud Connector provides a fine-granular access control mechanism, supports multiple protocols, such as RFC and HTTP, and can forward the cloud user identity using principal propagation. It enables users to log on to on-premise systems without logging in again by forwarding their current identity from the cloud. You can configure the Cloud Connector directly from the subaccount in the SAP BTP cockpit.

For more information about connectivity in ABAP and Kyma environments, see:

Communication Operations for the ABAP environment

Connectivity in the Kyma Environment

Related Information

Principal Propagation

SAP Connectivity service

Cloud Connector

URL: <https://help.sap.com/docs/btp/btp-admin-guide/setting-up-authentication>

Title: *Setting Up Authentication | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelSetting Up Authentication

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Setting Up Authentication

Your initial access to SAP BTP depends on the default identity provider. After consuming the initial starter scenarios and testing, switch to integrating your own identity and access management solution, where you have control over your own security policies.

We recommend that you always use SAP Cloud Identity Services - Identity Authentication for SAP BTP. If you use corporate identity providers, connect them to your Identity Authentication tenant, which then acts as a proxy. We especially recommend this configuration if you're using multiple corporate identity providers. Avoid trusting your corporate identity provider directly. The use of Identity Authentication is mandatory for platform users or for the use of some applications, such as SAP Build Work Zone and SAP Build Apps for your business users. ABAP-based public cloud solutions require Identity Authentication, too. Identity Authentication is the central integration point for managing identities across all SAP solutions. The support of SAML and OpenID Connect (OIDC) eases integration and consumption.

For more information, see Onboard to SAP Cloud Identity Services

Identity Providers and Federation

Remember

The two types of users on SAP BTP, platform users and business users, have separate trust configurations for identity providers. Platform users share one or more identity providers configured for the global account and further apply to the directory, subaccount, and the environment levels. Business users use the identity provider configured for each subaccount.

To establish trust for platform and business users, see the following:

Establish Trust and Federation of Custom Identity Providers for Platform Users [Feature Set B]

Establish Trust and Federation Between UAA and Identity Authentication

Recommendation

For platform users, keep a few backup administrators in the default identity provider or in an additional custom identity provider. Use these backup administrators in case access to your primary custom identity provider fails.

Default Identity Providers

SAP ID service is the preconfigured user store you can use in your starter scenarios or for testing. SAP ID service is the place where you register to get initial access to SAP BTP.

SAP Universal ID manages the users of official SAP sites, including the SAP developer and partner community. If you already have such a user, then you're already registered with SAP ID service as well. SAP ID service acts as a proxy for SAP Universal ID, when users log on with their email addresses. Users can log on with and manage all their user accounts with SAP Universal ID.

Identity Providers and SAP BTP Environments

The Kyma environment has a separate configuration for the identity provider. We recommend that you also configure your Kyma environment to use Identity Authentication as your custom identity provider.

For more information, see [Configure a Custom Identity Provider for Kyma](#).

URL: <https://help.sap.com/docs/btp/btp-admin-guide/setting-up-authorization>

Title: [Setting Up Authorization | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelSetting Up Authorization

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Setting Up Authorization

The methods for assigning authorizations on SAP BTP include manual assignment, federation, and provisioning. In practice, you use all these methods according to the situation.

When your system has many users in widely used production accounts, identity federation or provisioning is the preferred method. We recommend provisioning over federation where possible.

Methods for Assigning Authorizations

Method

Provisioning

Federation

Description

Provisioning synchronizes users between source systems and target systems based on rules or processes.

Individual authorizations are assigned to business roles. When a user needs access a target system, the automation makes sure to assign all the required authorizations defined by the business role in the target system. For example, when a new hire is assigned to a sales organization in an HR system, provisioning triggers the creation of the user in the target sales system with the required authorizations.

Provision user data with tools like Identity Provisioning and the SAP Cloud Identity Access Governance service.

Federation is an agreement between the administrator of the identity provider and the administrator of the system that consume it. The agreement specifies what attributes to include in tokens used to authenticate users in the relying system. The administrator of the relying system assigns authorizations indirectly on the attributes the identity provider sends. For example, an identity provider includes the user groups attribute in authentication tokens it issues. The administrator of the relying system maps authorizations for sales applications to any user who belongs to the sales user group and not to individual users.

Use tools such as the command-line interface (btp CLI) or the SAP BTP cockpit

Restrictions

Provisioning is partially available for platform users: Role collections on the subaccount level can be provisioned, such as Subaccount Administrator.

The ABAP environment doesn't support federation.

Advantages

Centrally defined business roles define which authorizations belong together.

Approval workflows for authorizations.

When a user changes their job or leaves the organization, provisioning can remove the user data from target systems in accordance with compliance rules.

Simpler to implement than provisioning.

Authorization information comes with the authentication token. The user has information about their authorizations as soon as the changes have been made in the identity provider.

Disadvantages

To get authorizations in a system, the user must wait until a provisioning job has run to update the target system.

Doesn't scale like provisioning.

Information that authorizations belong together can only be achieved manually.

When a user is removed from the identity provider, the user can't log on, but their user data remains in the relying systems. You must actively ensure the deletion of the remaining data.

Remember

There are two types of users on SAP BTP: platform and business. Platform users are usually developers, administrators, or operators who deploy, administer, and troubleshoot applications and services. Business users are those users who consume the applications that are deployed to SAP BTP.

In addition to subaccount authorizations (role collections), assign roles for the environment.

For more information, see [Giving Access Rights to Platform Users](#).

Related Information

[Mapping Role Collections in the Subaccount](#)

[Role Collections and Roles in Global Accounts, Directories, and Subaccounts](#)

[Setting Up Identity Lifecycle](#)

[Onboard to SAP Cloud Identity Services](#)

URL: <https://help.sap.com/docs/btp/btp-admin-guide/setting-up-identity-lifecycle>

Title: [Setting Up Identity Lifecycle | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting Up Your Security and Compliance ModelSetting Up Identity Lifecycle

SAP BTP Administrator's GuideEnglish

[Provide feedback on our search](#)

à

[Setting Up Identity Lifecycle](#)

As people join, change roles, and eventually leave your organization, you care for the onboarding, maintenance, and offboarding of their users in your systems. If you're a small organization, you can use manual processes, otherwise you need to automate.

We strongly recommend creating users within SAP Cloud Identity Services. In certain scenarios, such as when using Joule or SAP SuccessFactors People Analytics, the existence of users in SAP Cloud Identity Services is mandatory.

The persistency layer of SAP Cloud Identity Services is the Identity Directory. Use SAP Cloud Identity Services - Identity Provisioning to provision users to SAP cloud solutions, such as SAP BTP. Identity Provisioning has connectors to distribute user artifacts needed at different levels of your SAP BTP accounts. By managing your identities centrally, you also ensure that when you offboard users, they're removed from target systems.

[SAP Cloud Identity Services Managing SAP Cloud Applications](#)

User Identifiers

The global user ID is a unique identifier across technology layers, products, and solutions in the Intelligent Enterprise. The global user ID enables you to correlate information about a user across applications. SAP Cloud Identity Services is best equipped to handle SAP-specific attributes, such as the global user ID. In fact, cloud solutions like SAP Task Center only function when using SAP Cloud Identity Services to manage the global user ID. SAP Cloud Identity Services can generate the global user ID for you or you can provide your own.

Recommendation

If you generate your own global user ID, don't use attributes that may change over time. Attributes in email format are not allowed, as the at-sign (@) is not a valid character. We generate a universally unique identifier (UUID) that remains stable as long as the user is in the system.

For more information, see [Global User ID in Integration Scenarios in the System Integration Guide for SAP Cloud Identity Services](#).

Before starting your integration, determine which system owns the global user ID and ensure that the attribute's

format is used consistently across your landscape. We recommend that SAP Cloud Identity Services own and generate the global user ID in the Identity Directory. Once generated, distribute the global user ID from the Identity Directory to your business applications, ensuring that they all support this attribute.

The global user ID is primarily used for correlation. It should be included in the token issued by the identity provider. While it doesn't need to be configured as the subject name identifier, which is typically reserved for a unique identifier for users during authentication, it can be if necessary.

User Provisioning

Define a system of origin for each user type, such as employees, contractors, and external users, to ensure proper access control based on user roles and their relationship with your organization. SAP SuccessFactors typically serves as the system of origin for employees, while SAP Fieldglass is often used for managing external workforces.

Avoid configuring multiple systems of origin for one and the same user to prevent conflicts and overwriting of user data. If this cannot be avoided, set up pairs of source and Identity Directory target systems to control which user attribute comes from each source system.

For more information, see [Merging Data from Multiple Sources](#).

If you already have your own identity and access management solution, use this solution to ensure the correctness and consistency of user data. Identity Provisioning synchronizes the user or group data between SAP Cloud Identity Services and all SAP cloud applications, eliminating the need to maintain custom point-to-point connections.

For more information, see [System Integration Guide for SAP Cloud Identity Services](#):

Scenario Recommendations

SAP BTP Integration Scenario

To authenticate with SAP BTP, the system needs user artifacts such as:

- E-mail address of the user

- Identity provider that authenticates the user

The ABAP and Kyma environments require a unique email address.

An administrator can create these users manually or in some cases allow for automatic creation after successful authentication at the identity provider. SAP BTP provides tools such as the SAP BTP cockpit, command-line interfaces, and APIs to enable you to manage this data yourself.

Schedule provisioning jobs for regular user data synchronization, and make sure to test your configurations with simulation and validation jobs beforehand.

For more information, see [Start and Stop Provisioning Jobs](#).

Related Information

Account Administration

Complying with Data Protection and Privacy Requirements

URL: <https://help.sap.com/docs/btp/btp-admin-guide/setting-up-your-security-and-compliance-model>

Title: [Setting Up Your Security and Compliance Model](#) | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting

Up Your Security and Compliance Model

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Setting Up Your Security and Compliance Model

Applications on SAP BTP are exposed to the Internet and should therefore fulfill the highest possible security requirements to prevent unauthorized access.

Security Concepts

The level of security you implement varies depending on your use case and your company's general security requirements. However, there are a few best practices that we recommend, regardless of your implementation.

Setting Up Authentication

Your initial access to SAP BTP depends on the default identity provider. After consuming the initial starter scenarios and testing, switch to integrating your own identity and access management solution, where you have control over your own security policies.

Setting Up Identity Lifecycle

As people join, change roles, and eventually leave your organization, you care for the onboarding,

maintenance, and offboarding of their users in your systems. If you're a small organization, you can use manual processes, otherwise you need to automate.

Setting Up Authorization

The methods for assigning authorizations on SAP BTP include manual assignment, federation, and provisioning. In practice, you use all these methods according to the situation.

Setting Up Access to Remote Systems

Use SAP Connectivity service to enable your SAP BTP applications to access remote services on the Internet or in your on-premise systems. For connecting to Internet services, we recommend that you use APIs with destinations, and for cloud-to-on-premise scenarios, we recommend that you use destinations and the Cloud Connector.

Complying with Data Protection and Privacy Requirements

All companies must respect data protection and privacy rights of individuals. Data protection and privacy most likely influences the architecture and functionalities of your application and should be considered as early as possible in the development process.

URL: <https://help.sap.com/docs/btp/btp-cli-command-reference/btp-update-security-settings>

Title: *btp update security/settings* | SAP Help Portal

Usage

âE

â

btp [OPTIONS] update security/settings [--global-account [SUBDOMAIN]] [--subaccount [ID]] [--iframe DOMAIN] [--custom-email JSON] [--default-idp-for-noninteractive-logon ORIGIN] [--treat-users-with-same-email-as-same-user BOOL] [--use-idp-user-name-in-tokens BOOL] [--home-redirect URL] [--access-token-validity DURATION] [--refresh-token-validity DURATION] [--rotate-signing-key-automatically BOOL]

âf

Parameter

Description

--global-account, -ga [SUBDOMAIN], ÷ F-öæ Â' The ID of the global account for which to update the security settings. [SUBDOMAIN] can be omitted if specified by 'btp target'.

--subaccount, -sa [ID], ÷ F-öæ Â' The ID of the subaccount for which to update the security settings. [ID] can be omitted if specified by 'btp target'.

--iframe DOMAIN, ÷ F-öæ Â' The new domains of the iframe. Enter as string. To provide multiple domains, separate them by spaces.

--custom-email JSON, ÷ F-öæ Â' The new custom email domains. Enter inline as a valid JSON array containing the list of custom email domains.

--default-idp-for-noninteractive-logon ORIGIN, ÷ F-öæ Â' 6WG2 æ÷F†W" -FVçF—G' &övider as default for noninteractive logon (for example, password grant flows). It makes noninteractive logon easier because you don't always have to specify the custom identity provider over the default identity provider. Use 'btp list security/trust' to retrieve the origin keys of the identity providers.

--treat-users-with-same-email-as-same-user BOOL, ÷ F-öæ Â' -b 6WB Fò G ue, users with the same email are treated as same users.

--use-idp-user-name-in-tokens BOOL, ÷ F-öæ Â' -b 6WB Fò G ue, username from the identity provider will be used in tokens.

--home-redirect URL, ÷ F-öæ Â' U\$Â Fò v†-6, W6W'2 &R &VF—&V7FVBâ To avoid open redirect attacks, we recommend that you redirect to a safe and valid URL when users log out.

--access-token-validity DURATION, ÷ F-öæ Â' 6WG2 F†R `alidity of the access token. You can choose a value between 1800 seconds and 86,400 seconds (between 30 minutes and 24 hours). The default value is 43,000 seconds (12 hours).

--refresh-token-validity DURATION, ÷ F-öæ Â' 6WG2 F†R `alidity of the refresh token. You can choose a value between 1800 seconds and 31,536,000 seconds (between 30 minutes and one year). The default value is 604,800 seconds (7 days).

--rotate-signing-key-automatically BOOL, ÷ F-öæ Â' -b 6WB Fò G ue, the signing key for access tokens is rotated automatically.

âf

URL: <https://help.sap.com/docs/btp/btp-developers-guide/a03d08e4038b46d480c410395593bbd2.html>

Title: Giving Access Rights to Platform Users | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's Guide...Setting Up

AuthorizationGiving Access Rights to Platform Users

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Giving Access Rights to Platform Users

If you've set up a staged development environment using different subaccounts or spaces, such as for development, testing, and production, grant the Cloud Development Team access to development subaccounts and environments. Only grant the Platform Engineering Team or Center of Expertise (CoE) access to the testing and production subaccounts or environments.

All developers and stakeholders for a particular development project or application should get access to the development subaccount or environment, if the project or application has been properly enrolled. We recommend that you assign all developers authorizations to develop, assign roles, and test the application's functionalities.

In cases where even the Platform Engineering Team/CoE isn't allowed to see or access the data, automate tasks that require developer access or integrate them into a deployment pipeline using a technical user with the developer authorizations. Firefighter situations where temporary use of the role is needed for manual actions by an actual administrative user can be handled by temporary assignment of the developer access. You can also use a special user account with access whose credentials are only given out when needed and changed immediately after use. Remember to log the use of this role in an audit trail or another tracking tool.

As every small change that's made in a single application (for example, changing a destination) can affect all other applications. Only grant the Platform Engineering Team/CoE access to the test and prod subaccounts or environments. Have this team manage them centrally. If necessary, assign developers read access. For all changes required in subaccounts or spaces, the Cloud Development Team should reach out to the Platform Engineering Team/CoE.

Division of Access to Different Stages of the Development Pipeline

Tip

To avoid overwhelming the Platform Engineering Team/CoE with inquiries, consider automating tasks and providing a build infrastructure for continuous deployment.

Global Accounts and Directoriesà^

Platform users depend on role collections for access at the global account and directory level. By default, user management isn't enabled for directories. To manage platform users at this level, use SAP BTP cockpit or the btp cli.

For more information, see:

Add Members to Your Global Account

Manage Users in Directories

Role Collections and Roles in Global Accounts, Directories, and Subaccounts

Multi-Environment Subaccountsà^

See Add Members to Your Subaccount.

Cloud Foundry

We recommend that you assign all developers the Space Developer role, so they can develop, assign roles, and test the application's functionalities.

Caution

The Space Developer role has broad rights within Cloud Foundry and, in particular, has access to the credentials used in various services and app bindings as well as other sensitive data. Users with this role can access the data in the environment, either directly through administration tools or indirectly through an application or other client.

In production environments, only give this role to members of the Platform Engineering Team/CoE that are authorized to access data in the environment.

For more information, see About User Management in the Cloud Foundry Environment.

ABAP

Platform users in the ABAP environment depend on Cloud Foundry. Administrators need the Org Manager and Space Manager roles. Developers need the Space Developer role. The same recommendations apply as in the

Cloud Foundry environment to members of the Cloud Development and Platform Engineering/CoE teams. In addition, platform users need the relevant business roles of the ABAP system: SAP_BR_ADMINISTRATOR and SAP_BR_DEVELOPER.

For more information, see [Creation of Additional Administrator Users](#) and [Creation of Developer Users](#).

Kyma

You can assign roles to a group of users only if you use a custom identity provider. Assigning roles in Kyma is based on the Kubernetes role-based access control (RBAC). Once you become the admin, your user name is read from the SAP BTP (RBAC) concept and is passed to the Kyma provisioner to be bound to the cluster-admin role in Kyma.

Because the development of a role concept is very specific for each organization, it's recommended that you start with a very simple role concept: As a starting point, just separate the developers and operators of a cluster. Later, you can refine the role concept as needed.

For more information, see [Role-Based Access Control \(RBAC\) in Kyma](#) and [Assign Roles in the Kyma Environment](#).

Neo Subaccounts

Assign the predefined platform roles for platform users. You can also configure custom roles.

For more information, see:

[Managing Member Authorizations in the Neo Environment](#)

[Manage Custom Platform Roles](#)

[Related Information](#)

[User and Member Management](#)

URL: <https://help.sap.com/docs/btp/btp-developers-guide/security-considerations-for-applications>

Title: [Security Considerations for Applications | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Developer's Guide...DevelopSecurity Considerations for Applications

SAP BTP Developer's GuideEnglish

[Provide feedback on our search](#)

à

Security Considerations for Applications

When building applications, use the security features of SAP BTP, such as protection from web attacks. We recommend that your developers configure and deploy application-based security artifacts containing authorizations, and administrators assign these authorizations using the cockpit. SAP BTP offers platform roles that help you ensure a segregation of duties, such as between app development and administration.

It's likely that data protection and privacy influence your architecture and the functions of your application.

Consider any implications as early as possible in your development process. Security monitoring is done with audit logging. SAP BTP writes logs for security-relevant events and the written log files are digitally signed to ensure their integrity.

See the following for more information about security best practices:

[CAP Security Guide](#)

[Giving Access Rights to Platform Users](#)

[SAP BTP Security Recommendations](#)

You implement, deploy, and validate your application to ensure it meets both functional and performance requirements. Prioritizing secure deployment and configuration at this stage helps you launch your application with strong protections in place—minimizing vulnerabilities and aligning with enterprise-grade security standards.

Delivering your application marks the transition from development to production, where your application becomes accessible to users. This is a critical point for enforcing security controls. For example, a retail company deploying an e-commerce application must ensure secure payment processing and defend against runtime threats such as:

[SQL injection](#)

[Cross-site scripting \(XSS\)](#)

[Cross-Site Request Forgery \(CSRF\)](#)

By applying secure deployment practices—such as hardening configurations, validating inputs, and enabling runtime protection—you reduce the risk of exploitation and ensure compliance with data protection regulations

like the GDPR.

By implementing built-in security features offered by the SAP Cloud Application Programming Model (CAP), you can significantly enhance your application defense. This includes leveraging:

Parameterized queries (for example, `cds.select`, `.where`) to prevent SQL injection.

CDS constraints (for example, `@assert.format`) for robust input validation.

CSRF protection for UI applications, such as checkout forms.

Furthermore, CAP's built-in authentication and authorization mechanisms protect user access. Together, these practices help reduce vulnerabilities, support GDPR compliance, and keep user trust.

The following table summarizes the security guidelines you need to be familiar with:

Delivering Secure Applications Deployed to SAP BTP

Security Guideline

Description

Secure Environment Configuration

Configure the SAP BTP runtimes (for example, SAP BTP, Cloud Foundry runtime, SAP BTP, Kyma runtime with secure settings, such as restricted network access. See:

SAP BTP Cloud Foundry Runtime

Secure Development in the Kyma Environment | SAP Help Portal

Validate Security During Testing

Conduct security tests (for example, penetration testing) during validation to identify and fix vulnerabilities before go-live.

Implement Secure Deployment Pipelines

Use CI/CD pipelines with security checks (for example, code scanning, dependency validation) to ensure safe deployments. See:

Introducing Continuous Integration and Delivery (CI/CD)

Get Started with an SAP Cloud Application Programming Model Project in SAP Continuous Integration and Delivery | SAP Tutorials

Secure Application Secrets Management

Use SAP Credential Store to securely manage secrets like API keys or database credentials. See SAP Credential Store.

Following these guidelines will significantly improve the deployment of your application to SAP BTP and enable rigorous validation processes. This approach is critical for safeguarding against potential threats, mitigating vulnerabilities, and ensuring compliance with rule-based standards. For more practical examples on how to implement security in CAP, see CAP Security Guide | capire.

URL: <https://help.sap.com/docs/btp/comparison-btp-runtimes/technical-capabilities-security-and-resilience>

Title: Security and Resilience | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)Comparison: SAP BTP, Kyma Runtime and SAP BTP, Cloud Foundry Runt...Security and Resilience

Comparison: SAP BTP, Kyma Runtime and SAP BTP, Cloud Foundry RuntimeEnglish

Provide feedback on our search

à

Security and Resilience

Learn about the security and resilience aspects.

Security and Resilience

Category

SAP BTP, Kyma runtime

SAP BTP, Cloud Foundry runtime

Backup and restore

Yes, but requires continuity planning.

See Kyma environment backup

Yes, but requires continuity planning.

See Resilience, High Availability, and Disaster Recovery

Workload isolation

Can be configured on multiple levels

Can be configured on multiple levels

Multi A-Z support

Offering three availability zones.

See Resilience Best Practices for Kyma runtime.

Offering three availability zones.

See Resilience Best Practices for Cloud Foundry runtime.

URL: <https://help.sap.com/docs/btp/sap-btp-neo-environment-security-recommendations-ed2ef9c59a8245c9b9505d6bf8305cfb/sap-btp-neo-environment-security-recommendations>

Title: SAP BTP, Neo Environment Security Recommendations | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo Environment Security Recommendations

SAP BTP, Neo Environment Security RecommendationsEnglish

Provide feedback on our search

à

SAP BTP, Neo Environment Security Recommendations

These recommendations help you evaluate the security of the configuration of SAP BTP, Neo environment.

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for security recommendations about other environments, see SAP BTP Security Recommendations.

Remember

As part of the cloud shared responsibility model (restricted access), you're responsible for determining if any of these recommendations are relevant for your environment and to what extent.

The security recommendations are provided as a courtesy, without a warranty, and may be subject to change.

For more information, see the disclaimer.

Note

Not all SAP BTP services are listed yet. We've started with the core services and are extending this list service-by-service.

If your service is missing, see also the Security section of the your service documentation on the SAP Help Portal.

See also Explanation of Table Headings.

Component

Priority

Secure Operations Map

Title

Default Setting or Behavior

Recommendation

More Information

Last Update

Index

Filter:

[No selection]

Filter:

[No selection]

Filter:

[No selection]

Component

Priority

Secure Operations Map

Title

Default Setting or Behavior

Recommendation

More Information

Last Update

Index

Agent Activation for Dynatrace Service for SAP BTP•&V6öÖÖVæFVIClient Security•@oken Lifecycle"" FV`ault, Dynatrace API tokens don't have an expiry date unless configured explicitly. •W6R G—æ G ace API token with an expiration date. Periodically rotate the token to mitigate the potential exposure of a secret. •6WGW wV—FR é 2024-03-20"%E Ô GA-0001

SAP Audit Log•&V6öÖÖVæFVIAudit & Fraud Management"udit•F†R 4 Audit Log is a platform service that centrally collects and stores all audit logs generated on your behalf by the SAP BTP Neo platform services you use. Audit logs can be accessed and downloaded programmatically via the Audit Log Retrieval API. By default, logs are retained for 201 days, after which they are automatically and permanently deleted. If a longer retention period is required, it can be extended up to a maximum of 365 days using the Audit Log Retention API. •F†R Audit Log Retrieval API enables programmatic access to your audit logs stored in the SAP BTP Neo environment. To prevent data loss and meet long-term compliance or regulatory requirements, it is strongly recommended to retrieve and export audit logs on a regular basis and store them in a central, organization-managed system of your choice. This is particularly important if your retention needs exceed the maximum period supported by the Audit Log Retention API, after which logs are permanently deleted and cannot be recovered.

Audit Log Retention API Usage for the Neo Environment

Audit Log Retrieval API Usage for the Neo Environment

2026-06-25"%E Ô ÄäÓ

HTML5 Application Runtime"7 itical•W6W" b —FVçF—G' Ö æ vVÖVçIAuthenticate Routes

The routes are maintained in the application descriptor file. By default, they are all together protected by an authentication service using the SAML authentication method.

If you have defined logout page, this page has public access.

Make sure that when you define routes to resources, such as backend services or destinations, the resources are all together protected by an authentication service either by default or by specifying an authentication method.

Use the authentication type None only if all routes are to public pages.

Securing HTML5 Applications - Authentication and Application Descriptor File - Authentication"# #BÓ RÓ)BTP-HEL-0001

HTML5 Application Runtime•&V6öÖÖVæFVIRoles & Authorizations

Restricted Access for Users

By default, the AccountDeveloper role is assigned to the pre-defined NonActiveApplicationPermission permission for viewing the non-active versions of the application.

Limit the access to routes leading to security sensitive sites by configuring user authorization. You can assign a permission to such a specific route using security constraints in the application descriptor file. After that, you can assign a role to the permission and then assign a user to the role, both by using the SAP BTP cockpit.

The roles may be pre-defined, such as the AccountDeveloper role, or customized. You can customize roles using the SAP BTP cockpit. The custom roles can be reused across multiple applications.

Managing Roles and Permissions

Authorization

2024-05-02"%E Ô„TÂÓ

HTML5 Application Runtime•&V6öÖÖVæFVINetwork Security" &öving HTTP Headers"æ÷B ÆÂ ...EE †V FW'2 are forwarded from the application to a backend or from the backend to the application. The HTTP headers that are forwarded by default are either part of the HTTP standard or are frequently used by Web applications or SAP servers." FB F†R ...EE †V FW'2 F† B 6†÷VÆB &R `orwarded between the application and the backend. Add the required header name to the headerWhiteList attribute in the application descriptor file." &öving HTTP Headers"# #BÓ RÓ)BTP-HEL-0003

HTML5 Application Runtime•&V6öÖÖVæFVINetwork Security"7W7FöÖ &W7 öç6R †V FW'0

Custom response headers are optional and don't have any default.

Add custom response headers to your application to comply with the security standards of your browser. Add the required header name and value to the responseHeaders attribute in the application descriptor file."7W7FöÖ Response Headers"# #BÓ RÓ)BTP-HEL-0004

HTML5 Application Runtime•&V6öÖÖVæFVIData Privacy & Protection

File System – No Sensitive Data

The file names used for deploying HTML5 applications are not intended for personal data.” void sensitive and personal data as part of HTML5 application data. This includes file names.

Create an HTML5 Application

Importing an HTML5 Application

2024-05-02”%E Ô„TÂÓ P

Mobile Services•&V6öÖÖVæFVIAuthentication & Single Sign-On”6Æ–VçB assword Policy•F†R 70word policy is enabled by default, including default parameter values, such as Expiration Time Frame, Minimum Length, Retry Limit, Lock Timeout and so on. The default is the minimum level of security.”Væ le the password policy based on your company policy.”FVf–æ–æR 6Æ–VçB assword Policy“# #BÓ BÓ yBTP-MBN-0001

Mobile Services•&V6öÖÖVæFVIAuthentication & Single Sign-On” uthentication Method for Client Application Security•v†Vâ •ou configure app security, OAuth 2.0 is the default and recommended security type. Other security types are available.•W6R ðAuth to ensure app security.

Application Authentication

Managing OAuth Authentication

2024-04-17”%E ÔÔ\$âÓ

Mobile Services•&V6öÖÖVæFVIRoles & Authorizations”6öæf–wW ing Access Control

Default roles are not set.

Setting roles is especially important when a back-end service has no authorization mechanism.

Use role settings to protect an application so that only privileged users can access it.”FVf–æ–æR 66W72 6öçG&öÉ

2024-04-17”%E ÔÔ\$âÓ @

àf

Related Informationà^

SAP BTP Security, Neo Environment

Best Practices for SAP BTP

URL: <https://help.sap.com/docs/btp/sap-btp-security-recommendations-c8a9bb59fe624f0981efa0eff2497d7d/displaying-security-recommendations>

Title: *Displaying Security Recommendations | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Security RecommendationsDisplaying Security Recommendations

SAP BTP Security RecommendationsEnglish

Provide feedback on our search

à

Displaying Security Recommendations

We've numerous recommendations for SAP BTP and it can be hard to see just the ones you want. Here we try to give you some tips on how to display just the information you want to see.

Too Many Columnsà^

On smaller screens, this table is difficult to display. We've the following suggestions that can help:

Hide the side panes of the SAP Help Portal. The side panes enable you to navigate the structure of the documentation or provide feedback. To use more screen real estate for the content, close these panes. The following figure shows the controls used to close the side panes.

áÕ

Page With Navigation and Comments Panes Open

The following figure shows the table with the side panes closed.

áÕ

Page With Navigation and Comments Panes Closed

Once you find the information you need, hide the columns you don't need.

Control to Show and Hide Table Columns

Saving and Sharing Searchesà^

The table already provides filters for the table as a whole and within some of the columns. Unfortunately you can't save those searches directly from the SAP Help Portal. However, you can replicate the use of these filters with URL parameters. Then save these filter configurations as URLs and share them.

The table as a whole and the filters have their own names, which you provide in the URL parameters.

List of Filter Parameters

Table or Column
Filter URL Parameter
Complete table
seclist
Service
seclist-service
Priority
seclist-priority
Secure Operations Map
seclist-som
Topic
seclist-topic
Last Update
seclist-last_update
Index
seclist-index
Example

Show all recommendations that refer to certificates:

<https://help.sap.com/docs/BTP/c8a9bb59fe624f0981efa0eff2497d7d/531f33def8074ccdb6f1f784a34dafcb.html?seclist=certificates>

Example

Show all recommendations for the Cloud Connector service:

<https://help.sap.com/docs/BTP/c8a9bb59fe624f0981efa0eff2497d7d/531f33def8074ccdb6f1f784a34dafcb.html?seclist-service=Cloud%20Connector>

Example

Show only the recommendation BTP-IAS-0001:

<https://help.sap.com/docs/BTP/c8a9bb59fe624f0981efa0eff2497d7d/531f33def8074ccdb6f1f784a34dafcb.html?seclist-index=BTP-IAS-0001>

Example

Show all critical recommendations for the Cloud Connector service:

<https://help.sap.com/docs/BTP/c8a9bb59fe624f0981efa0eff2497d7d/531f33def8074ccdb6f1f784a34dafcb.html?seclist-service=Cloud%20Connector&seclist-priority=Critical>

URL: <https://help.sap.com/docs/btp/sap-btp-security-recommendations-c8a9bb59fe624f0981efa0eff2497d7d/explanation-of-table-headings>

Title: *Explanation of Table Headings | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Security RecommendationsExplanation of Table Headings

SAP BTP Security RecommendationsEnglish

Provide feedback on our search

à

Explanation of Table Headings

Not all the table headings of our recommendations are immediately understandable so we provide an explanation.

Explanation of Table Headings

Component

Priority

Secure Operations Map

Title

Default Setting or Behavior

Recommendation

More Information

Last Update

Index

The name of the service or component to which the setting belongs.

Defines the criticality of the recommendation.

For an explanation of the priority levels, see the following Explanation of Priority table.

The Secure Operations Map is a reference model to structure the broad area of security for content, discussions, and as a basis for a 360° view on security.

For more information about the Secure Operations Map, see Security Overview as part of the SAP Security Optimization Services Portfolio.

A general heading to summarize what the setting is about.

Describes the usage of the security setting, including any context, or default setting behavior (if available).

Defines our recommendation for this configuration.

A link to documentation that explains how you can achieve the recommendation.

Date of the last significant change.

See also What's New.

A stable unique reference to identify the recommendation.

àf

Explanation of Priority

Priority

Description

Critical

Exposes the system to significant risk or threatens system reliability.

Recommended

Improves the security of the landscape and significantly reduces the attack surface.

Advanced

Extends the recommendation to a higher standard. The recommendation either extends the security standards to higher level of protection or to additional areas, such as your organization-specific requirements.

Related Informationà^

SAP BTP Security Recommendations

URL: <https://help.sap.com/docs/btp/sap-btp-security-recommendations-c8a9bb59fe624f0981efa0eff2497d7d/sap-btp-security-recommendations>

Title: SAP BTP Security Recommendations | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Security Recommendations

SAP BTP Security RecommendationsEnglish

Provide feedback on our search

à

SAP BTP Security Recommendations

These recommendations help you evaluate the security of the configuration of SAP BTP.

Remember

As part of the cloud shared responsibility model (restricted access), you're responsible for determining if any of these recommendations are relevant for your environment and to what extent.

The security recommendations are provided as a courtesy, without a warranty, and may be subject to change.

For more information, see the disclaimer.

If your service is missing, see also the Security section of the your service documentation on the SAP Help Portal.

See also Explanation of Table Headings and Displaying Security Recommendations.

For applications and services on the SAP BTP, Neo Environment, see SAP BTP, Neo Environment Security Recommendations.

Component

Priority

Title

Default Setting or Behavior

Recommendation

More Information

Filter:

[No selection]

Filter:

[No selection]

Component

Priority

Title

Default Setting or Behavior

Recommendation

More Information

Malware Scanning•&V6öÖÖVæFV**Strong Authentication for REST APIs**

The service supports basic authentication or mTLS to access the REST APIs.

The certificate created for the mTLS binding or service key has a validity of 364 days. Otherwise the credentials for the binding or service key doesn't expire.

Use mTLS to bind applications to the service in productive environments.

Rotate credentials before they expire or once a year if they don't expire.

Initial Setup

Frequently Asked Questions

Cloud Logging

Critical•6WGF—æR W uthentication with Identity Authentication service

Without SAML configuration, authentication defaults to basic authentication which should not be used for production.

Basic authentication suffers from inherent security vulnerabilities, interceptable and unencrypted format transmission of credentials.

Set up authentication with SAP Cloud Identity Services - Identity Authentication."6öæf—wW ation Parameters for SAML

Cloud Logging

Recommended•W F FR FW VæFVçB Æ—' aries"—b •ou use the optional client libraries to add fields to the logs, check for updates to these libraries. We regularly provide updates to fix issues and make improvements in our code.

The logging libraries are on Github as open source. •patch the Github project for new releases and update them when new releases become available."—æ6ÇVFR Æövv—æR Æ—' aries

Cloud Logging

Recommended

Monitor and update bindings

Service binding credentials contain client certificates that expire after 90 days by default. After certificates' expiration, clients cannot authenticate with the service instance anymore.

Rotate client certificates:

Automate your deployment process to rotate client certificates in accordance with the certificate lifetime. Once setup, regularly check that the re-binding process matches with the configured lifetime.

Rotate root CA Certificate:

Pay attention on when to rotate root CA Certificate: it should only be rotated if you want to invalidate all bindings at once.

Ingest via OpenTelemetry API Endpoint

Ingest via Kyma Runtime

When to rotate the ingestion root CA certificate

Identity Authentication"7 itical" FV`ault Authentication of Administrators•F†R FV`ault authentication method for the administration console is user name and password." Çpays protect the administration console application with multifactor authentication."6öæf—wW&R &—6²Ô& 6VB uthentication for an Application

Identity Authentication•&V6öÖÖVæFVIPassword Policies

The service supports multiple levels of password security. The default setting is Standard. The main difference between Standard and Enterprise is the enforcement of password change.

If these policies don't meet your corporate requirements, create custom policies.

If password-based authentication is mandatory for you, we recommend Enterprise over Standard, because it's the only option to fix leaked accounts.

Better is the deactivation of passwords for employees if applicable. See BTP-IAS-0006.

Configure Custom Password Policy

Identity Authentication"7 itical•6VÆbÖ&Vv—7G ation of End Users

For business-to-consumer (public) scenarios, self-registration may be required. By default, self-registration is disabled (value = internal) and can be configured per application.

Corporate identity lifecycle processes make self-registration undesirable in most business-to-employee (B2E) and business-to-business (B2B) scenarios.

For more information, see Scenarios

Keep self-registration disabled (value = internal). Actively manage use cases that require the function.

User Access to the Application
Identity Authentication

For business-to-consumer (public) scenarios, social sign-on may be required. By default, social sign-on is disabled (value = internal) and can be configured per application.

Corporate identity lifecycle processes make social sign-on undesirable in most business-to-employee (B2E) and business-to-business (B2B) scenarios.

For more information, see Scenarios

Keep social sign-on disabled (value = internal). Actively manage use cases that require the function.

Disable Social Sign-On for an Application
Identity Authentication

Advanced
Default Authentication of End Users
Default authentication method for end users to authenticate with the service is user name and password.

Disable password authentication for end users by setting up a risk-based authentication (RBA) rule which excludes the User Name and Password authentication method.

Configure Kerberos Authentication
Enable Users to Generate and Authenticate with Certificates

Enable or Disable FIDO2 Biometric Authentication for an Application

Configure Default Risk-Based Authentication for All Applications in the Tenant

Risk-Based Authentication for an Application

Identity Authentication

Advanced

Audit Data
SAP Audit Log uses the SAP Audit Log on the Cloud Foundry environment for audit logging. The retention time is 90 days.

To keep audit log entries longer, download and archive the log entries regularly.

See also BTP-AUD-0001.

Access Audit Logs (AWS, Azure Infrastructure)

à

Related Information

SAP BTP Security

Best Practices for SAP BTP

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/04cbd0f30d524612aa438ed0b0eed217.html>

Title: On-Premise User Store | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo Environment...Security ConfigurationOn-Premise User Store

SAP BTP, Neo EnvironmentEnglish

Provide feedback on our search

à

On-Premise User Store

If you already have an existing on-premise system with a populated user store, you can configure SAP BTP applications to use that on-premise user store. This approach is similar to implementing identity federation with a corporate identity provider. In that way, applications do not need to keep the whole user database, but request the necessary information from the on-premise system.

Context

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for

documentation about other environments, see SAP Business Technology Platform .

Applications can use the on-premise system to:

- check credentials

- search for users

- retrieve user details

- retrieve information about the groups a specific user is a member of. You can use this information for user authorizations. See Managing Roles.

You can use two types of on-premise user store:

SAP Single Sign-On with a SAP NetWeaver Application Server for Java System - the applications on SAP BTP connect to the SAP on-premise system using Destination API (and, if necessary, SAP HANA Cloud Connector), and make use of the user store there.

Microsoft Active Directory - this is an LDAP server that can serve as an on-premise user store. The applications on SAP BTP connect to the LDAP server using SAP Cloud Connector, and make use of the user store there.

Alternatively to the above scenarios, you can implement identity federation with a Identity Authentication tenant, where the tenant is configured to use an on-premise user store. See:

Identity Authentication Tenant as an Application Identity Provider

(Identity Authentication documentation) Corporate User Store

Related Information

Using an SAP System as an On-Premise User Store

Using Microsoft Active Directory as an On-Premise User Store

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/310f39e504024079933066db8b6c6d00.html>

Title: Principal Propagation to OAuth-Protected Applications | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo EnvironmentSecurity, Neo

EnvironmentOAuth 2.0 ServicePrincipal Propagation to OAuth-Protected Applications

SAP BTP, Neo EnvironmentEnglish

Provide feedback on our search

à

Principal Propagation to OAuth-Protected Applications

Propagate users from external applications with SAML identity federation to OAuth-protected applications running in the Neo environment of SAP BTP. Exchange the user ID and attributes from a SAML assertion for an OAuth access token, and use the access token to access the OAuth-protected application.

Prerequisites

You have an application external to SAP BTP. The application is integrated with a third-party library or system functioning as a SAML identity provider. That application has a SAML assertion for each authenticated user.

Note

How the external application and its SAML identity provider work together and communicate is outside the scope of this documentation. They can be separate applications, or the external application may be using a library integrated in it.

Note

If you are using a separate third-party identity provider system for this scenario, make sure you have configured correctly trust between the external application and the identity provider system. Refer to the identity provider vendor's documentation for details.

You have configured SAP BTP for identity federation. See Configure the Local Service Provider.

You have developed an OAuth-protected application. See OAuth 2.0 Authorization Code Grant.

You have deployed the OAuth-protected application at SAP BTP. See Deploying and Updating Java Applications.

Context

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for documentation about other environments, see SAP Business Technology Platform .

This scenario follows the SAML 2.0 Profile for OAuth 2.0 Client Authentication and Authorization Grants

specification. The scenario is based on exchanging the SAML (bearer) assertion from the third-party identity provider for an OAuth access token from the SAP BTP authorization server. Using the access token, the external application can access the OAuth-protected application.

The graphic below illustrates the scenario implemented in terms of SAP BTP.

An external application has a SAML assertion on behalf of a successfully logged user. The application needs to prepare that user and its relevant information (attributes, privileges, and so on) to the OAuth-protected application running at SAP BTP.

The external application passes the SAML assertion to SAP BTP.

To access the OAuth-protected application at SAP BTP, however, the external application needs an OAuth 2.0 access token, not a SAML assertion.

If the SAML assertion contains all required information (see the procedure below) SAP BTP generates the corresponding access token. In this way, the external application can act on behalf of the user authenticated by the identity provider, within its granted privileges at SAP BTP, and within the time limits of the access token.

The external application passes the received access token to the OAuth-protected application at SAP BTP.

If the access token is correct and the user has the required privileges, the OAuth-protected application returns the requested resources.

Procedure

Configure SAP BTP for trust with the SAML identity provider. See [Configure Trust to the SAML Identity Provider](#).

Register the external application as an OAuth client in SAP BTP. See [Register an OAuth Client](#).

Make sure the SAML (bearer) assertion that the external application presents contains the following information:

SAML Assertion Element

Value Description

Example

Name ID

The authenticated user ID.

<

>

<saml:NameID

Format="urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified"

xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">p12356789

</saml:NameID>

Audience

The local service provider name for your SAP BTP account (in Cockpit Security Trust Local Service Provider Local Provider Name).

If you are using the default identity provider configuration for your account, take the audience value from the table below.

Region Host

Description

Required Audience Value

hana.ondemand.com

Productive landscape, data center Europe

https://netweaver.ondemand.com

ap1.hana.ondemand.com

Productive landscape, data center Asia-Pacific (Australia)

ap1.hana.ondemand.com

https://us1.hana.ondemand.com

Productive landscape, data center United States (US East)

https://us1.hana.ondemand.com/

See [Regions and Hosts Available for the Neo Environment](#).

<

>

<saml:Audience>myLocalProvider</saml:Audience>

<

>

<saml:Audience>https://us1.hana.ondemand.com/</saml:Audience>

âE

ã

<saml:Audience>ap1.hana.ondemand.com</saml:Audience>

Issuer ID

The issuer must have as value the OAuth client ID registered at SAP BTP (in Cockpit Security OAuth Clients <your client> Client ID).

âE

ã

<saml:Issuer

Format="urn:oasis:names:tc:SAML:2.0:nameid-format:entity"

xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">myClientID

</saml:Issuer>

Issuer Certificate

The identity provider signing certificate stored in the trust configuration of SAP BTP for this identity provider (in Cockpit Security Trust Application Identity Provider <your identity provider General Signing Certificate).

Sample Code

âE

ã

<ds:X509Certificate> </ds:X509Certificate>

(Optional) User Attributes

The attributes that will be assigned to the SAP BTP user.

âE

ã

<Attribute Name="mail">

<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema"

xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

xsi:type="xs:string">test@sap.com

</AttributeValue>

</Attribute>

<Attribute Name="first_name">

<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema"

xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

xsi:type="xs:string">Jon

</AttributeValue>

</Attribute>

àf

See the SAML Assertion Format specification for more information.

In the code of the OAuth-protected application, you can retrieve the user attributes using the relevant SAP BTP API. See User Attributes.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/3438252775d84bdfa211e79147561c99.html>

Title: Security, Neo Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo EnvironmentSecurity, Neo Environment

SAP BTP, Neo EnvironmentEnglish

Provide feedback on our search

à

Security, Neo Environment

Authorization and trust management, OAuth, key and certificate management, principal propagation and other security features in the Neo Environment.

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for documentation about other environments, see SAP Business Technology Platform .

Security Recommendations

We provide a list with our recommendations for the configuration of our services. These recommendations help you to meet your compliance goals and secure your business.

See SAP BTP, Neo Environment Security Recommendations.

Our customer success organization, uses these recommendations as a base to create a security baseline template.

For more information, go to <https://support.sap.com/sos> and choose Media Library SAP CoE Security Services - Security Baseline Template.

Transport Layer Security (TLS) Connectivity Support

Neo environment uses encrypted communication channels based on HTTPS/TLS, supporting TLS version 1.2 or higher.

Make sure you use HTTP clients (such as Web browsers) that support TLS version 1.2 or higher for connecting. In the TLS headers x-scp-tls-version and x-scp-tls-cipher returned by the Neo environment, the application receives information about the TLS version and cipher with which the connection is established.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/80edbe70b8f3478d8a59c21a91a47aa6.html>

Title: Platform Identity Provider for Tools | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo EnvironmentSecurity, Neo

EnvironmentPlatform Identity Provider for Tools

SAP BTP, Neo EnvironmentEnglish

Provide feedback on our search

à

Platform Identity Provider for Tools

Configure the platform identity provider to be used for authentication in service and platform tools (for example, Neo console client, Cloud Connector, SAP Git Service, and so on). The default user base is provided by SAP ID Service. You can switch to an Identity Authentication tenant if you want to use a custom user base.

Overview

Note

The platform identity provider for tools is not used for accessing the SAP BTP cockpit. For accessing the SAP BTP cockpit, you use the custom identity provider for platform users configured at global account level. For more information, see Establish Trust and Federation of Custom Identity Providers for Platform Users.

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for documentation about other environments, see SAP Business Technology Platform .

By default, the console client, and service and platform tools are configured to use SAP ID Service as the platform identity provider for tools (providing the user base for subaccount members). SAP ID Service, however, uses the SAP user base (providing, for example, your s- or p-user). If you want to have subaccount members from your custom user base, and use custom security configuration (such as two-factor user authentication, or corporate user store, for example), you can switch to a custom Identity Authentication tenant as a platform identity provider.

Note

There is a difference between a platform identity provider for tools and application identity provider at SAP BTP. The diagram below describes the basic features of platform identity providers and application identity providers, and provides a brief comparison between them.

Note

Changing the platform identity provider for tools settings (Security Trust Platform Identity Provider for Tools in the SAP BTP cockpit) does not affect the application identity provider settings (Security Trust Application Identity Provider in the SAP BTP cockpit) for this subaccount. See Application Identity Provider.

The platform identity provider you configure will be used for accessing service and platform tools, such as:

Console Client for the Neo Environment

Git Service

Cloud Connector (Neo environment)

SAP Solutions Management Service for SAP BTP when BASIC (user name and password) authentication is used in applications

SAP HANA system from SAP HANA Studio (see Tutorial: Add an SAP HANA System)

Prerequisite: Configure Trust at Global Account Level

Context

To configure an Identity Authentication tenant as a platform identity provider for your Neo subaccount, you need to have a trust configuration at global account level with it. For more information, see Establish Trust and Federation of Custom Identity Providers for Platform Users.

Note

When you configure trust at global account level, the trusted Identity Authentication tenant creates an application with the name SAP Business Technology Platform. All security settings in this application apply to all Neo subaccounts.

Configure the Platform Identity Provider at Neo Subaccount Level

Procedure

In your web browser, open the SAP BTP cockpit, and navigate to your Neo subaccount.

See Navigate in the Cockpit.

Go to Security Trust Platform Identity Provider for Tools.

The screen shows the platform identity provider in use. By default, this is SAP ID Service.

Choose the Select Identity Authentication Tenant button.

A list of all tenants available for your current Neo subaccount appears.

Select the required tenant from the list.

The screen now shows the Identity Authentication tenant as the platform identity provider in use.

You can reset to SAP ID Service (using the respective button) or change to another tenant (if available).

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/a1ab5c4cc117455392cd0a512c7f890d.html>

Title: Managing Member Authorizations in the Neo Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP, Neo Environment...Managing Members Using the CockpitManaging Member Authorizations in the Neo Environment

SAP BTP, Neo EnvironmentEnglish

Provide feedback on our search

à

Managing Member Authorizations in the Neo Environment

SAP BTP includes predefined platform roles that support the typical tasks performed by users when interacting with the platform. In addition, subaccount administrators can combine various scopes into a custom platform role that addresses their individual requirements.

Caution

SAP Business Technology Platform, Neo environment will sunset on December 31, 2028, subject to terms of customer or partner contracts.

For more information, see SAP Note 3351844 .

Tip

This documentation refers to SAP Business Technology Platform, Neo environment. If you are looking for documentation about other environments, see SAP Business Technology Platform .

A platform role is a set of permissions, or scopes, managed by the platform. Scopes are the building blocks for platform roles. They represent a set of permissions that define what members can do and what platform resources they can access (for example, configuration settings such as destinations or quotas). Most scopes follow a “Manage” and “Read” pattern. For example, manageXYZ comprises the actions create, update, and delete on platform resource XYZ. However, some areas use a different pattern, for example, Application Lifecycle Management.

Predefined Platform Rolesà^

Predefined platform roles cannot be changed. However, global account administrators can copy from predefined roles, and then modify the copies.

SAP BTP includes the following predefined platform roles:

Role

Description

Administrator

Manage subaccount members

You can also manage subscriptions, trust, authorizations, and OAuth settings, and restart SAP HANA services on HANA databases.

Furthermore, you can view heap dumps and download a heap dump file.

In addition, you have all permissions granted by the developer role, except the debug permission.

Note

This role also grants permissions to view the Connectivity tab in the SAP BTP cockpit.

Cloud Connector Admin

Open secure tunnels via Cloud Connector from on-premise networks to your subaccounts.

Note

This role also grants permissions to view the Connectivity tab in the SAP BTP cockpit.

Developer

Supports typical development tasks, such as deploying, starting, stopping, and debugging applications. You can also change loggers and perform monitoring tasks, such as creating availability checks for your applications and executing MBean operations.

Note

By default, this role is assigned to a newly created user.

Support User

Designed for technical support engineers, this role enables you to read almost all data related to a subaccount, including its metadata, configuration settings, and log files. For you to read database content, a database administrator must assign the appropriate database permissions to you.

Application User Admin

Assigned by the subaccount administrator to a subaccount member. Manage user permissions on application level to access Java, HTML5 applications, and subscriptions. You can control permissions directly by assigning users to specific application roles or indirectly by assigning users to groups, which you then assign to application roles. You can also unassign users from the roles or groups.

Note

This role does not let you manage subaccount roles and perform actions at the subaccount level (for example, stopping or deleting applications).

The following graphic illustrates the predefined Administrator, Developer, and Support User roles and their amount of scopes:

Amount of Platform Scopes

The Admin role includes all platform scopes available on SAP BTP. The Developer and Support User are subsets of the Admin role.

Custom Platform Roles

Administrators of a subaccount can define custom platform roles based on their needs by assembling the different scopes they want their custom platform role to include. Custom platform roles are managed at subaccount level and can be changed at any time.

Subaccount administrators can combine various scopes into a custom platform role that addresses their individual requirements. Scopes are the building blocks for platform roles. They represent a set of permissions that define what members can do and what platform resources they can access (for example, configuration settings such as destinations or quotas).

The following example illustrates how custom platform roles in SAP BTP typically look like regarding their amount of scopes:

Number of Platform Scopes

Related Information

Platform Scopes

Manage Custom Platform Roles

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/aaaad9424e7442eab5d44b20f0ecbfd7.html>

Title: Setting Up Your Security and Compliance Model | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's GuideSet Up and PlanSetting

Up Your Security and Compliance Model

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Setting Up Your Security and Compliance Model

Applications on SAP BTP are exposed to the Internet and should therefore fulfill the highest possible security requirements to prevent unauthorized access.

Security Concepts

The level of security you implement varies depending on your use case and your company's general security requirements. However, there are a few best practices that we recommend, regardless of your implementation.

Setting Up Authentication

Your initial access to SAP BTP depends on the default identity provider. After consuming the initial starter scenarios and testing, switch to integrating your own identity and access management solution, where you have control over your own security policies.

Setting Up Identity Lifecycle

As people join, change roles, and eventually leave your organization, you care for the onboarding, maintenance, and offboarding of their users in your systems. If you're a small organization, you can use manual processes, otherwise you need to automate.

Setting Up Authorization

The methods for assigning authorizations on SAP BTP include manual assignment, federation, and provisioning. In practice, you use all these methods according to the situation.

Setting Up Access to Remote Systems

Use SAP Connectivity service to enable your SAP BTP applications to access remote services on the Internet or in your on-premise systems. For connecting to Internet services, we recommend that you use APIs with destinations, and for cloud-to-on-premise scenarios, we recommend that you use destinations and the Cloud Connector.

Complying with Data Protection and Privacy Requirements

All companies must respect data protection and privacy rights of individuals. Data protection and privacy most likely influences the architecture and functionalities of your application and should be considered as early as possible in the development process.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/about-roles-in-cloud-foundry-environment>

Title: About Roles in the Cloud Foundry Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformAdministration and OperationsAdministration and Operations in the Cloud Foundry EnvironmentAbout Roles in the Cloud Foundry Environment

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

About Roles in the Cloud Foundry Environment

Roles determine which features users can view and access, and which actions they can initiate.

Cloud Foundry includes predefined roles that are specific to the navigation level in the SAP BTP cockpit; for example, the roles at the level of the organization differ from the ones for the space. Each role comes with a set of permissions. Roles apply to all operations that are associated with the organization or the space, irrespective of the tool used (Eclipse-based tools, SAP BTP cockpit, and cf CLI).

The following roles can be assigned to users in the Cloud Foundry environment on SAP BTP:

Level

Role

Role Description

Organization

Org Manager

Manages the organization.

When you create an org, you get the Org Manager role in that org by default.

Org Auditor

Provides read-only access to user information and org quota usage information.

Org User

Provides read-only access to the list of other organization users and their roles.

Note

When creating an org member, you can choose one or more of the following roles:

Org Manager

Org User

Org Auditor

When creating a space member, they get the Org User role by default.

Space

Space Manager

Manages a space within an organization.

Space Developer

Manages applications, services, and space-scoped service brokers in a space.

Caution

The Space Developer role has broad rights within Cloud Foundry and, in particular, has access to the credentials used in various services and app bindings as well as other sensitive data. For more information, see [Giving Access Rights to Platform Users](#).

Space Auditor

Provides read-only access to a space.

Space Supporter

Allows you to troubleshoot and debug applications and service bindings in a space.

Note

To add the Space Supporter role using the `set-space-role` command, you need to have installed version 8 of the Cloud Foundry Command Line Interface (cf CLI). See <https://docs.cloudfoundry.org/cf-cli/install-go-cli.html>.

Note

Managing members and roles for an organization takes place on the navigation level of the subaccount to which the organization is assigned.

For more information about organization and space roles in Cloud Foundry, see <https://docs.cloudfoundry.org/concepts/roles.html>.

Related Information

About User Management in the Cloud Foundry Environment

Add Org Members

Add Organization Members Using the Cloud Foundry Command Line Interface

Add Space Members

Add Space Members Using the Cloud Foundry Command Line Interface

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/accessing-administration-using-apis-of-sap-authorization-and-trust-management-service>

Title: Accessing Administration Using APIs of the SAP Authorization and Trust Management Service | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Account

Administration Using APIsAccessing Administration Using APIs of the SAP Authorization and ...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Accessing Administration Using APIs of the SAP Authorization and Trust Management Service

The REST services of the SAP Authorization and Trust Management service (XSUAA) provide APIs that enable you to manage entities, such as roles, shadow users, and access tokens in global accounts, directories, and multi-environment subaccounts.

Note

To manage Neo subaccounts, use the Neo APIs. For more information, see [Using Platform APIs](#).

API Overview

The following table provides an overview of the APIs. For more information about the APIs and their API endpoints, see [SAP Business Accelerator Hub](#) in the related links.

APIs of SAP Authorization and Trust Management Service

API

Description

User Management (System for Cross-domain Identity Management (SCIM))

Provides functions to administrate the SAP Authorization and Trust Management service of the Cloud Foundry environment. Provision users from identity providers and manage roles and role collections. Use this API to manage shadow users; users the service provisions from your identity provider to the subaccount.

See SAP BTP XS Advanced UAA (Cloud Foundry) for more information.

Authorization

Provides functions to administrate the SAP Authorization and Trust Management service of Cloud Foundry environment. Manage service instances of the SAP Authorization and Trust Management service. You can also manage roles, role templates, and role collections of your subaccount.

Identity Provider Management

Provides functions to manage identity providers in in the Cloud Foundry environment.

Security Settings

Provides functions to manage the security settings of an account in Cloud Foundry environment. Use this API to manage access token validity and signing keys.

Related Information

APIs of SAP Authorization and Trust Management Service service on SAP Business Accelerator Hub

Using Platform APIs

Rate Limiting

Limits for Technical Artifacts of the SAP Authorization and Trust Management Service

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/add-org-members-using-cockpit>

Title: Add Org Members | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Org

MembersAdd Org Members

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Add Org Members

In the SAP BTP cockpit, add users as org members and assign roles to grant the users access to information, such as user and quota information in a Cloud Foundry org.

Prerequisites

You have the Org Manager role for the org in question.

Note

When you enable Cloud Foundry and the org is created, the Org Manager role is assigned automatically to you. For more information, see About Roles in the Cloud Foundry Environment.

The users exist in a trusted platform identity provider.

For more information, see About User Management in the Cloud Foundry Environment.

Procedure

Navigate to your subaccount in the cockpit. Make sure that Cloud Foundry is enabled. For more information, see Navigate to Orgs and Spaces.

In the navigation area, choose Cloud Foundry Org Members.

The screen displays all members currently assigned to the org in a list.

Choose Add Members.

Enter one or more e-mail addresses.

Use commas (,), spaces (), semicolons (;), or line breaks to separate members.

Enter the Origin for the identity provider, which hosts the members you just added.

The default identity provider is sap.ids. For more information, see Default Identity Provider.

If the new members are platform users from a custom identity provider, enter the origin.

Select the corresponding origin of the Identity Authentication tenant.

Note

The option to select an origin appears only if you have two or more identity providers.

For more information about finding the origin, see Establish Trust and Federation of Custom Identity Providers for Platform Users.

Select the org roles you want to assign.

For more information, see [About Roles in the Cloud Foundry Environment](#).

Choose **Add**.

Next Steps

To change the roles of a member, see [Edit Org Members](#).

To remove all the roles of a member, see [Delete Org Members](#).

This action removes the member from the organization and any spaces in the org.

If the users need to view or manage applications in spaces, add the users to the relevant spaces, too.

For more information, see [Add Space Members](#).

Related Information

[Add Organization Members Using the Cloud Foundry Command Line Interface](#)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/add-roles-to-role-collection>

Title: [Add Roles to a Role Collection | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Define a Role CollectionAdd Roles to a Role Collection

SAP Business Technology PlatformEnglish

[Provide feedback on our search](#)

à

Add Roles to a Role Collection

You can add roles to a role collection.

Context

The roles are derived from role templates that are provided by applications. For more information, see the [related links](#).

Procedure

Open the SAP BTP cockpit.

Go to your global account and subaccount (see [Navigate in the Cockpit](#)).

Choose **Security** **Role Collections**.

To add roles, choose the role collection name.

Go to the **Roles** section and choose **Edit**.

To add a role to the role collection, choose the input field. The role selection screen opens.

Use the dropdown list or the F4 function key under **Role Name** to display the roles that are available. The roles are sorted alphabetically. Choose the role you want to add. You can also select multiple roles from the list below.

Choose **Add**.

Save your changes.

Related Information

[Role Collections and Roles in Global Accounts, Directories, and Subaccounts](#)

[Protecting Your Application](#)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/add-roles-to-role-collections-on-application-level>

Title: [Add Roles to Role Collections on the Application Level | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Building Roles and Role Collections for ApplicationsAdd Roles to Role Collections on the Application Level

SAP Business Technology PlatformEnglish

[Provide feedback on our search](#)

à

Add Roles to Role Collections on the Application Level

Roles are used to define the type of access granted to an application.

Context

A role is an instance of a role template; you can build a role based on a role template and assign the role to a role collection. Role collections are then assigned to SAML 2.0 groups or users. The role template defines the type of access permitted for an application, for example: the authorization scope, and any attributes that need to be applied. Attributes define information that comes with the respective user, for example 'cost center' or 'country' (see the [related link](#)). This information can only be resolved at run time.

Note

The User Account and Authentication service automatically creates default roles for all role templates that do

not include attribute references. They have the same name as the role template. You can't delete them. You can recognize them because their description contains Default Instance.

Procedure

Open the SAP BTP cockpit.

Go to your global account and subaccount (see [Navigate in the Cockpit](#)).

Choose Security in the navigation pane or go to Cloud Foundry Spaces <your_space> <your_application>.

Choose Security Roles in the navigation pane.

Here you see a complete list of all roles sorted by role templates. It also contains information about attributes used in this role and about the role collections the role has been added to. On the right side, you find the action buttons.

Note

You cannot edit or delete predefined roles for default role collections. For this reason, the action buttons are grayed out. For more information, see the related link.

To directly assign a role to role collections, choose the action button  (Add to role collection) in the same row.

A new window shows all role collections that are available in your global account or subaccount.

Select the role collections to which you want to add your role.

Choose Add.

The number in the role collections column counts up. You have now assigned this role to the role collections you selected earlier.

Related Information

Attributes

Role Collections and Roles in Global Accounts, Directories, and Subaccounts

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/add-space-members-using-cockpit>

Title: Add Space Members | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Space

MembersAdd Space Members

SAP Business Technology Platform

Provide feedback on our search

à

Add Space Members

You can add space members and assign roles to them at the space level in the SAP BTP cockpit.

Prerequisites

You have the Space Manager or Org Manager role.

If you only have the Space Manager role, the users you want to add to the space must already have the Org User role.

If you have the Org Manager role, you can assign space roles to users even if they're not members of the org yet.

Note

When you add users who aren't yet members of an org to a space in that org, they get the Org User role by default. This makes them members of the org as well.

The users exist in a trusted platform identity provider.

For more information, see [About User Management in the Cloud Foundry Environment](#).

Procedure

Navigate to Cloud Foundry Spaces in the SAP BTP cockpit. For more information, see [Navigate to Orgs and Spaces](#).

Choose a space to which you'd like to add members. For more information, see [Navigate to Orgs and Spaces](#).

In the navigation area, choose Space Members.

The screen displays all members currently assigned to the space in a list.

Choose Add Members.

Enter one or more e-mail addresses.

Use commas (,), spaces (), semicolons (;), or line breaks to separate members. The changes you make to the roles of a member take effect immediately.

Enter the Origin for the identity provider, which hosts the members you just added.

The default identity provider is sap.ids.

For more information, see [Default Identity Provider](#).

If the new members are platform users from a custom identity provider, enter the origin.

Select the corresponding origin of the Identity Authentication tenant.

For more information about finding the origin, see [Establish Trust and Federation of Custom Identity Providers for Platform Users](#).

Select the space roles you want to assign.

For more information, see [About Roles in the Cloud Foundry Environment](#).

Choose **Add**.

Next Steps

You also have the following options:

[Edit Space Members](#)

[Delete Space Members](#)

Related Information

[Add Org Members Using the Cockpit](#)

[Add Space Members Using the Cloud Foundry Command Line Interface](#)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/add-users-from-sap-id-service-for-multi-environment-subaccounts>

Title: [Add Users from SAP ID Service for Multi-Environment Subaccounts | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Default Identity ProviderAdd Users from SAP ID Service for Multi-Environment Subaccounts

SAP Business Technology PlatformEnglish

[Provide feedback on our search](#)

à

[Add Users from SAP ID Service for Multi-Environment Subaccounts](#)

Before you can assign role collection to a user from SAP ID service, ensure that this user exists in your subaccount.

Prerequisites

The user you want to add to your subaccount must have an SAP user account (for example, an S-user or P-user).

For more information, see [Create SAP User Accounts](#).

Context

When you create your own trial account, your SAP user is automatically created and assigned to SAP ID service. When you onboard new members to your subscribed app, add them to your subaccount. Then you can assign a role collection to the user.

Procedure

Create users and assign role collections to users in **Security Users**.

It's possible to create users in custom identity providers and in the SAP ID service.

For more information, see [Working with Users](#).

Related Information

[Platform Identity Provider for Tools](#)

[Mapping Role Collections](#)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/adding-authentication-and-authorization>

Title: [Adding Authentication and Authorization | SAP Help Portal](#)

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology

PlatformDevelopmentDevelopment in the Cloud Foundry EnvironmentAdding Authentication and Authorization

SAP Business Technology PlatformEnglish

[Provide feedback on our search](#)

à

[Adding Authentication and Authorization](#)

Developers create authorization information for business users in their environment and deploy this information in an application. They make this available to administrators, who complete the authorization setup and assign the authorizations to business users.

Developers store authorization information as design-time role templates in the xs-security.json security

descriptor file. Using the cockpit, administrators of the environment assign the authorizations to business users. The following sections contain the process of adding authentication and authorization checks for protecting your applications, links to a number of associated tutorials, extended tasks for creating authorization artifacts, as well as reference information, including the syntax required to set the properties and values defined in the application security descriptor file.

Using the SAP Authorization and Trust Management service or the SAP Cloud Identity Services^ SAP BTP is currently replacing the authorization management done by the SAP Authorization and Trust Management service, with an integrated solution with the SAP Cloud Identity Services – Authorization Management. This service is integrated into the SAP Cloud Identity Services, which offers authentication, authorization, user provisioning and management in one place.

Currently, there are still use cases where the usage of the old model with the SAP Authorization and Trust Management service is simpler when it comes to the technical setup, especially in the administration for business users.

For decision considerations on when to use the SAP Authorization and Trust Management service and when to use the SAP Cloud Identity Services - Authorization Management service as the authorization management system on SAP BTP, you can follow this decision tree that will be regularly updated:

Developers use the Cloud Application Programming model for authorization policies. For more information, see Authorization and Access Control.

Protecting Your Application^

Application security is maintained in the application security descriptor file (xs-security.json). You can use this file to define application-based security artifacts, which are the building blocks for authorizations. In this section, you can learn how to create this file and use it to create a service instance of the SAP Authorization and Trust Management service. Following this single tenant scenario, move on in increasing complexity to procedures that depict how to propagate user information between applications or services, add multitenancy to your application, and set up instance-based authorizations.

Tutorials for Authentication and Authorizations^

Use tutorials to get familiar with the SAP Authorization and Trust Management service in the Cloud Foundry environment of SAP BTP.

For more information, see Tutorials for the SAP Authorization and Trust Management Service.

Tasks On Demand^

Here you can find information regarding accessing the UAA admin APIs for creating XSUAA artifacts, as well as the process of configuring redirect URLs.

In addition, as an application developer, you may want to create role collections for immediate use. For example, to deliver role collections that administrators can use in the SAP BTP cockpit and easily assign to users in an onboarding process.

For more information, see Create Role Collections with Predefined Roles.

Reference Information^

For the syntax required to set the properties and values defined in the application security descriptor file (xs-security.json), see Application Security Descriptor Configuration Syntax.

Related Information^

SAP Authorization and Trust Management Service

Configuring Authorization Policies

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/application-security-descriptor-configuration-syntax>

Title: Application Security Descriptor Configuration Syntax | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Reference

InformationApplication Security Descriptor Configuration Syntax

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Application Security Descriptor Configuration Syntax

The syntax required to set the properties and values defined in the xs-security.json application security descriptor file.

âE

ã

```

{
  "xsappname" : "node-hello-world",
  "scopes"
: [ {
  "name" : "$XSAPPNAME.Display",
  "description" : "display" },
  {
  "name" : "$XSAPPNAME.Edit",
  "description" : "edit" },
  {
  "name" : "$XSAPPNAME.Delete",
  "description": "delete",
  "granted-apps": ["$XSAPPNAME(application,business-partner)"]
  }
],
  "attributes" : [ {
  "name" : "Country",
  "description" : "Country",
  "valueType" : "string" },
  {
  "name" : "CostCenter",
  "description" : "CostCenter",
  "valueType" : "string" }
],
  "role-templates": [ {
  "name"
: "Viewer",
  "description"
: "View all books",
  "default-role-name": "Viewer: Authorized to Read All Books",
  "scope-references"
: [
  "$XSAPPNAME.Display" ],
  "attribute-references": [
  {
  "name" : "Country",
  "default-values" : [
  "USA", "Germany"
  ]
  }
  ],
  },
  {
  "name"
: "Editor",
  "description"
: "Edit, delete books",
  "scope-references"
: [
  "$XSAPPNAME.Edit",
  "$XSAPPNAME.Delete" ],
  "attribute-references" : [
  "Country",
  "CostCenter"]
  }
  ]
}

```

```

}
],
"role-collections": [
{
"name": "UserViewerRC",
"description": "User Viewer Role Collection",
"role-template-references": ["$XSAPPNAME.Viewer"]
}
],
"authorities":["$ACCEPT_GRANTED_AUTHORITIES"],
"oauth2-configuration": {
"token-validity": 900,
"redirect-uris": ["https://myapp.cfapps.eu10.hana.ondemand.com","https://myapp.mydomain.com/my/logout"],
"credential-types": ["binding-secret","x509"]
},
"xsenableasynservice":"true"
}
}

```

Tip

Try out the tutorials for the SAP Authorization and Trust Management service to get familiar with using the application security descriptor in the Cloud Foundry environment of SAP BTP.

See Tutorials for the SAP Authorization and Trust Management Service.

xsappname

Use the xsappname property to specify the name of the application that the security description applies to.

Example

Example

```
"xsappname" : "<app-name>",
```

Naming Conventions

Bear in mind the following restrictions regarding the length and content of an application name in the xs-security.json file:

The following characters can be used in an application name of the Cloud Foundry environment at SAP BTP:

aA–zZ, 0–9, - (hyphen), _ (underscore), / (forward slash), and \ (backslash).

The maximum length of an application name is 100 characters.

tenant-mode (Custom Option)

Use the custom tenant-mode property to define the way the tenant's OAuth clients get their client secrets.

During the binding of the xsuaa service, the UAA service broker writes the tenant mode into the credential section. The application router uses the tenant mode information for the implementation of multitenancy with the application service plan.

Sample Code

Example

Example

```

{
  "xsappname"
  : "<application_name>",
  "tenant-mode"
  : "shared",
  "scopes"
  : [
    {
      "name"
      : "$XSAPPNAME.Display",
      "description"
      : "display"
    }
  ]
}

```

Syntax

"tenant-mode" : "shared"

The following tenant modes are available:

Tenant Modes

Value

Description

dedicated

Default value. An OAuth client gets a separate client secret for each subaccount.

shared

An OAuth client always gets the same client secret. It's valid in all subaccounts. The application service plan uses this tenant mode.

external

A tenant has multiple subscriptions to applications. For each subscription to an application, the tenant gets an OAuth client with a client secret.

scopes^

In the application security file (xs-security.json), the scopes property defines an array of one or more security scopes that apply for an application. You can define multiple scopes; each scope has a name and a short description. The list of scopes defined in the xs-security.json file is used to authorize the OAuth client of the application with the correct set of local and foreign scopes; that is, the permissions the application requires to be able to respond to all requests.

^

~

"scopes": [

{

"name" : "\$XSAPPNAME.Display",

"description" : "display"

},

{

"name" : "\$XSAPPNAME.Edit",

"description" : "edit"

},

{

"name" : "\$XSAPPNAME.Delete",

"description" : "delete",

"granted-apps" : ["\$XSAPPNAME(application,business-partner)"]

}

]

^

Local Scopes

All scopes in the scopes file is used to authorize the OAuth client of the application with the correct set section are local, that is, application specific. Local scopes are checked by the application's own application router or checked programmatically within the application's runtime container. In the event that an application needs access to other services of the Cloud Foundry environment on behalf of the current user, the provided access token must contain the required foreign scopes. Foreign scopes are not provided by the application itself; they're checked by other sources outside the context of the application.

In the xs-security.json file, "local" scopes must be prefixed with the variable <\$XSAPPNAME> at run time. The variable is replaced with the name of the corresponding local application name.

Tip

The variable <\$XSAPPNAME> is defined in the application's deployment manifest description (manifest.yml).

Foreign Scopes

Usually, "foreign" scopes include the service plan and the name of the application to which the scope belongs.

For more information, see Referencing the Application Use the following syntax:

\$XSAPPNAME(<service_plan>,<xsappname>).<local_scope_name>

Example

```
"$XSAPPNAME(application,business-partner).Create"
```

Granting Scopes to Another Application

If you want to grant a scope from this application to another application for a user scenario, this application needs to grant access to the scope for the application that wants to use this scope. Using the `granted-apps` property in the scopes section, you can specify the application you want to grant your scope to. The other application (referenced as `<service_plan>`, `<foreign_xsappname>`) receives the scope as a “foreign” scope. For more information, see the related link.

Here is the syntax in the security descriptor of the application that grants the scope. For more information, see [Referencing the Application](#).

```
"granted-apps" : [ "$XSAPPNAME(<service_plan>,<foreign_xsappname>)" ]
```

Example

```
"granted-apps" : [ "$XSAPPNAME(application,business-partner)" ]
```

If you want to grant a scope from this application to another application for a client credentials scenario, use the `grant-as-authority-to-apps` property in the scopes section. In this case, the scopes are granted as authorities. Specify the other application by name. For more information, see the related link.

Here is the syntax in the security descriptor of the application that grants the scope:

```
"grant-as-authority-to-apps" : [ "$XSAPPNAME(<service_plan>,<foreign_xsappname>)" ]
```

Example

```
"grant-as-authority-to-apps" : [ "$XSAPPNAME(application,business-partner)" ]
```

Naming Conventions

Bear in mind the following restrictions regarding the length and content of a scope name:

The following characters can be used in a scope name: `aA–zZ`, `0–9`, `-` (hyphen), `_` (underscore), `/` (forward slash), `\` (backslash), and `:` (colon).

Scope names can't start with a leading `.` (period). For example, `.myScopeName1`.

The maximum length of a scope name, including the fully qualified application name, is 193 characters.

For other limits when using the properties, see [Limits for the Application Security Descriptor](#).

attributes

In the application security descriptor (`xs-security.json`), the `attributes` property enables you to define an array, listing one or more attributes that are applied to the role templates also defined in the `xs-security.json` element is only relevant for user scenarios file. You can define multiple attributes.

```
âE
```

```
ã
```

```
"attributes" : [
```

```
{
```

```
"name" : "Country",
```

```
"description" : "Country",
```

```
"valueType" : "s" },
```

```
{
```

```
"name" : "CostCenter",
```

```
"description" : "CostCenter",
```

```
"valueType" : "string" }
```

```
],
```

The `attributes` element is only relevant for a user scenario. Each element of the `attributes` array defines an attribute. These attributes can be referenced by role templates. There are multiple sources of attributes:

Static attributes

Use the SAP BTP cockpit to assign the value of the attributes. You can use the static value.

Attributes from an identity provider

You can reference the attributes provided by an identity provider. The token is issued by the configured identity provider during authentication. You find the attribute value in the configuration of your identity provider. The attributes provided by the identity provider, appear as an attribute in the JSON web token, if the user has assigned the corresponding roles. You can use the attributes to achieve instance-based authorization checks.

Unrestricted attributes

In this case, you want to express that it's not necessary to set a specific value for this attribute. The behavior is the same as if the attribute would not exist for this role.

For more information, see the related link about attributes.

The attributes definition can take the following properties:

attributes Properties

Key

Description

Example

name

The name of the attribute with a value to apply when building the role template

Country

description

A short summary of the attribute defined

Country

valueType

The type of value expected for the defined attribute; possible values are: string (or s), int (integer), or date
int

valueRequired

By default, every attribute needs dedicated attribute values. The default value is true.

For more information, see Relationship Between default-values of attribute-references and valueRequired.

true

Naming Conventions

Bear in mind the following restrictions regarding the length and content of attribute names in the xs-security.json file:

The following characters can be used to declare an xs-security attribute name in the Cloud Foundry environment: "aA"-"zZ", "0"-"9", "_" (underscore)

The maximum length of a security attribute name is 64 characters.

For other limits when using the properties, see Limits for the Application Security Descriptor.

role-templates

In the application-security file (xs-security.json), the role-templates property enables you to define an array listing one or more roles (with corresponding scopes and any required attributes), which are required to access a particular application module. You can define multiple role-templates, each with its own scopes and attributes.

Role templates can be delivered with default values for each attribute reference. When you deploy role templates with default values for each attribute reference, you create default roles.

attribute-references can contain a JSON array of multiple objects.

âE

ã

"role-templates": [

{

"name"

: "Viewer",

"description"

: "View all books",

"default-role-name"

: "Viewer: Authorized to Read All Books",

"scope-references"

: [

"\$XSAPPNAME.Display"

],

"attribute-references": [

{

"name" : "Country",

"default-values" : [

"USA", "Germany"

]

}

]

àf

attribute-references can contain a JSON array of string.

A role template must be instantiated. This is especially true with regard to any attributes defined in the role template and the specific attribute values, which are subject to customization and, as a result, can't be provided automatically. Role templates that only contain "role-templates": [{ "name" : "Viewer", "description" : "View all books", "default-role-name" : "Viewer: Authorized to Read All Books", "scope-references" : ["\$SAPPNAM.Display"], "attribute-references": ["Country"] },] "local" role-templates: [scopes can be instantiated without user interaction. The same is also true for "foreign" scopes where the scope owner has declared consent in a kind of allowlist (for example, either for "public" use or for known "friends").

Note

The resulting (application-specific) role instances need to be assigned to the appropriate user groups.

role-template Properties

Key

Description

Example

name

The name of the role to build from the role template

Viewer

description

A short summary of the role to build

View all books

default-role-name

The name of the role in Unicode

The name can be up to 255 characters long. The naming conventions of role-templates don't apply here.

Viewer: Authorized to Read All Books

scope-references

The security scope to apply to the application-related role

\$SAPPNAM.Display

attribute-references

One or more attributes to apply to the built role. You can use a JSON array of objects or of string.

If you use an array of objects, name is the name of the attribute. Use the attribute name specified in the attributes section.

default-values, for example "default-values": ["LeaveRequestWorkflow"]. If you don't want to configure default values, don't specify the default-values element.

For more information, see Relationship between default-values of attribute-references and valueRequired.

Tip

If you want to deliver attributes that aren't restricted by attribute values, set "valueRequired": false.

Sample Code

âE

ã

```
{
  "name" : "Country",
  "default-values" : ["USA", "Germany"]
}
```

(an array of objects)

["Country"] (an array of string)

Naming Conventions

Bear in mind the following restrictions regarding the length and content of role-template names in the xs-security.json file:

The following characters can be used to declare an xs-security role-template name: "aA"-"zZ", "0"-"9", "." (period), "-" (hyphen), "_" (underscore).

The maximum length of a role-template name is 64 characters.

For other limits when using the properties, see Limits for the Application Security Descriptor.

role-collections

The optional role-collections property enables you to define role collections with predefined roles.

Administrators use these predefined role collections. They can assign them to users during the initial setup of SAP BTP.

The role-collections property only makes sense if application developers reference role templates that can create default roles at deployment time.

Note

The role-collections element can only reference role templates of the same subaccount.

Sample Code

⌵

⌵

```
"role-collections": [  
  {  
    "name": "Employee",  
    "description": "Employee roles",  
    "role-template-references": [  
      "$XSAPPNAME.Employee"  
    ]  
  }  
]
```

role-collections Properties

Key

Description

Example

name

The name of the role collection to build

Caution

If you change the name of a role collection and update the service instance, you delete the role collection with the old name and create a role collection with the new name. This means that the newly created role collection doesn't have any user assignments.

Employee

description

A short summary of the role collection to build

Employee roles

role-template-references

The role templates referenced by the role collections property

\$XSAPPNAME.Employee

Syntax \$XSAPPNAME(<service_plan>,<xsappname>)

Example

\$XSAPPNAME(application,myapp2)

Naming Conventions

Bear in mind the following restrictions regarding the length and content of role-collections names in the xs-security.json file:

The maximum length of a role-collection name is 64 characters.

The maximum length of a role-collection description is 1000 characters.

The role-template-references (mandatory) element is an array with references to role template definitions from the Cloud Foundry application or from other Cloud Foundry applications.

Tip

We recommend that you reference all role templates using either the \$XSAPPNAME or \$XSAPPNAME(<service_plan>,<XSAPPNAME>) prefix to link to the correct application where the role template is defined (see Referencing the Application).

Conditions

The role templates must fulfill one of the following conditions regarding attributes:

Either they don't have attribute references.

Or default attribute values are defined. It's also possible to add the "valueRequired" : false property to an attribute.

This makes sure that a default role is automatically created for the role-templates after developers have deployed the application. The role collections use the predefined roles, which have been created automatically. For other limits when using the properties, see Limits for the Application Security Descriptor.

authorities

To enable one (sending) application to accept and use the authorization scopes granted by another application, each application must be bound to its own instance of the xsuaa service. This is required to ensure that the applications are registered as OAuth 2.0 clients at the UAA. You must also add an authorities property to the security descriptor file of the sending application that is requesting an authorization scope. In the authorities property of the sending application's security descriptor, you can either specify that all scope authorities configured as grantable in the receiving application should be accepted by the application requesting the scopes, or alternatively, only individual, named, scope authorities:

Request and accept all authorities flagged as "grantable" in the receiving application's security descriptor:

Sample Code

Specifying Scope Authorities in the Sending Application's Security Descriptor

âE

ã

```
"authorities":["$ACCEPT_GRANTED_AUTHORITIES"]
```

Request and accept only the "specified" scope authority that is flagged as grantable in the specified receiving application's security descriptor. For more information, see Referencing the Application.

Sample Code

Specifying Scope Authorities in the Sending Application's Security Descriptor

âE

ã

```
"authorities":["<ReceivingApp>.ForeignCall", "<ReceivingApp2>.ForeignCall",]
```

âf

Since both the sending application and the receiving application are bound to UAA services using the information specified in the respective application's security descriptor, the sending application can accept and use the specified authority from the receiving application. The sending application is now authorized to access the receiving application and perform some tasks.

Note

The granted authority always includes the prefixed name of the application that granted it. This information tells the sending application, which receiving application has granted which set of authorities.

The scope authorities listed in the sending application's security descriptor must be specified as "grantable" in the receiving application's security descriptor.

Tip

To flag a scope authority as "grantable", add the grant-as-authority-to-apps property to the respective scope in the receiving application's security descriptor.

For more information, see the related link.

oauth2-configuration (Custom Option)

Use the custom oauth2-configuration property to define custom values for the OAuth 2.0 clients, such as the token validity and redirect URIs.

The xsuaa service broker registers and uses these values for the configuration of the OAuth 2.0 clients.

Sample Code

âE

ã

```
"oauth2-configuration": {  
  "token-validity": 43200,  
  "redirect-uris": [  
    "https://myapp.cfapps.eu10-004.hana.ondemand.com",  
    "https://myapp.mydomain.com/my/content"],  
  "refresh-token-validity": 1800,  
  "credential-types": ["binding-secret", "x509"],
```

```
"system-attributes": ["groups","rolecollections"],
"allowedproviders ": ["origin_key1","origin_key2"]
}
```

The following configuration keys are available:

oauth2-configuration Properties

Key

Description

Example

token-validity

Sets the token lifetime in seconds for access tokens issued by SAP Authorization and Trust Management service. The value ranges from 60 seconds to 86400 seconds, in other words, from 1 minute to 24 hours.

Default: 43200 seconds (12 hours)

Recommendation

Relaxing the token policy means that users reauthenticate less. However, increasing the token validity also means that if a malicious user manages to steal a token, that malicious user has access until the token expires. Keep token validity in the subaccount as short as possible, but not less than 30 minutes.

Note

This change applies to applications, which consume or subscribe to this instance. These values override the values set for the subaccount.

For more information, see [Configure Token Policy for SAP Authorization and Trust Management Service](#).

1800 (30 minutes)

refresh-token-validity

Sets the token lifetime in seconds for refresh tokens issued by SAP Authorization and Trust Management service. The value ranges from 60 seconds to 31536000 seconds, in other words, from 1 minute to 1 year.

Default: 604800 seconds (7 days)

604800 (7 days)

redirect-uris

This key contains a list of the redirect URIs that SAP BTP checks for when redirecting. If your landscape domain or custom domain aren't on this list, including wildcards, the Authorization and Trust Management Service won't redirect users there.

We support explicit wildcards, namely domain relaxing and arbitrary paths. For example: "https://

*.mydomain.com/callback/**"

Caution

If you use wildcards, we recommend that you make your URIs as specific as possible. By using wildcards, you open up the redirect for multiple web sites. Wildcards increase the risk of redirecting to malicious web sites.

For more information, see [Listing Allowed Redirect URIs](#).

```
["https://<application_>hostname1>.<landscape_domain><path>","https://<application_>hostname2>.<custom_domain><path>"]
```

credential-types

Specifies the types of secrets available for binding applications to the service instance. The first type listed is the default type of secret. Otherwise, specify the type of secret when you create the binding or service key.

For more information, see [Service Instance Secrets](#).

The default value is binding-secret.

Recommendation

Use binding-secret or x509 so you can rotate the secret of a single binding without affecting other bindings of the service instance.

For more information, see [Rotating Secrets](#).

```
["binding-secret"]
```

system-attributes

Includes the system attributes in the JWT. If you don't define a value, the system includes the attributes for groups and role collections by default. If the size of the JWT becomes an issue for you, you can explicitly remove them. For example: "system-attributes": [],

You can also have the service include a refresh token of a trusted identity provider.

For more information, see [Include Tokens from Corporate Identity Providers](#) or [SAP Cloud Identity Services](#) in

Tokens of the SAP Authorization and Trust Management Service.

Values:

"groups" includes the xs.saml.groups attribute.

"rolecollections" includes the xs.rolecollections attribute.

"ias-corporate-idp-token" includes the token of the corporate identity provider trusted by your SAP Cloud Identity Services tenant.

"ias-token" includes the token of the trusted SAP Cloud Identity Services tenant.

["groups","rolecollections"]

allowedproviders

Includes an array of allowed identity providers. The default is that all identity providers are allowed.

As an option, developers can configure on application level which identity providers can be used for business users to log on to a certain application. The value of allowedproviders is the origin key of your identity provider. You find the origin key in your subaccount in the Security Trust Configuration page of your identity providers.

Recommendation

We recommend that you configure allowed identity providers on subaccount level. For more information, see Using Multiple Identity Providers from the Same Subaccount.

["origin_key1","origin_key2"]

xsenableasynservice (Custom Option)â

The xsenableasynservice element controls whether the cf create-service and cf update-service commands of the Cloud Foundry command line interface (cf CLI) are executed synchronously (false) or asynchronously (true).

Remember

The Cloud Controller of Cloud Foundry times out after 60 seconds for the synchronous execution of the commands. For this reason, we recommend that you use asynchronous execution for multitenant applications or reuse services.

Note

You usually need to wait for the completion of cf create-service and cf update-service even if you use asynchronous mode. Otherwise you might run into conflicts due to parallel update operations on the OAuth 2.0 clients.

Sample Code

âE

ã

"xsenableasynservice":"true"

Value

Description

false

Cloud Foundry command line interface commands are executed synchronously.

true (default)

Cloud Foundry command line interface commands are executed asynchronously.

Referencing the Applicationâ

If you want to grant scopes to an application for example, you must reference this application. Depending on where the application is located, you can reference an application in multiple ways:

Referencing the application of the current xs-security.json file

Referencing a foreign application that is located in the same subaccount

Application References

Description

Syntax

Application in the current xs-security.json file

\$XSAPPNAME

Application in the same subaccount

\$XSAPPNAME(<service_plan>,<xsappname>)

Note

Currently, you can only use the application service plan.

Example

\$XSAPPNAME(application,business-partner)

Reference to any service instance in the same subaccount and space

`$XSSERVICENAME(<service_instance_name>)`

This is the service instance name you used when you created it.

You can use these references with the following properties:

Properties

Property

Description

Example

granted-apps

Granting scopes to other applications.

Sample Code

␣

␣

```
"granted-apps" : [ "$XSAPPNAME(application,business-partner)"]
```

␣

␣

```
"granted-apps" : [ "$XSAPPNAME(application,business-partner1)","$XSAPPNAME(application,business-partner2)"]
```

grant-as-authority-to-apps

Use this property if you want to grant a scope to other applications for a client credential scenario.

Sample Code

␣

␣

```
"grant-as-authority-to-apps" : [ "$XSAPPNAME(application,business-partner)"]
```

␣

␣

```
"grant-as-authority-to-apps" : [ "$XSAPPNAME(application,business-partner1)","$XSAPPNAME(application,business-partner2)"]
```

authorities

Granting authorities (for a client credentials scenario)

Sample Code

␣

␣

```
"authorities":["$XSAPPNAME(application,business-partner)"]
```

scope-references

Referencing scopes in role templates

Sample Code

␣

␣

`$XSAPPNAME.Display`

foreign-scope-references

Using this property, you can reference scopes in foreign applications (for a user scenario).

Sample Code

␣

␣

```
"foreign-scope-references":["$XSAPPNAME(application,business-partner)"]
```

␣

␣

```
"foreign-scope-references":["$XSAPPNAME(application,business-partner1)","$XSAPPNAME(application,business-partner2)"]
```

Relationship Between default-values of attribute-references and valueRequired

When you define role templates and attributes in the `xs-security.json` file, you need to know that there's a relationship between default-values of attribute-references in the role template and `valueRequired` in the attribute. What is important to know is that you configure `valueRequired` in the current attribute definition

independently from any role template. The attributes are later referenced in the role templates using the attribute-references element.

This means that an attribute can be referenced in multiple role templates. You can set default-values for the first role template and not for the second one. If you define an attribute with "valueRequired": true" (see rows 1 and 3), a default role can be generated automatically for the first role template only, but not for the second one.

Configuration Examples

Use Case

Role Template

Attribute

A default role with default values is generated automatically. Administrators must set attribute values for their roles.

␣

␣

"default-values": ["<attribute_value>"]

␣

␣

"valueRequired" : true

or no valueRequired key at all

A default role with default values is generated automatically. Administrators don't have to set attribute values for their role. A role that isn't restricted by attributes (unrestricted) is created.

␣

␣

"default-values": ["<attribute_value>"]

␣

␣

"valueRequired" : false

A default role is generated automatically. Administrators don't have to set attribute values for their roles. A role that isn't restricted by attributes (unrestricted) is created.

No default-values element

␣

␣

"valueRequired" : false

Restriction

When you define role templates and attributes, observe the following configuration restriction:

Do not add attribute-references without default-values, where attribute is defined with "valueRequired" : true.

When you update role templates and attributes, observe the following configuration restrictions:

Do not change default-values of attribute-references.

Do not change the "valueRequired" property from false to true.

Related Information

Attributes

Tutorials for the SAP Authorization and Trust Management Service

Security Considerations for the SAP Authorization and Trust Management Service

Configuration Options for the SAP Authorization and Trust Management Service

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assign-roles-in-kyma-environment>

Title: Assign Roles in the Kyma Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Secure

Administration and Operations in the Kyma EnvironmentAssign Roles in the Kyma Environment

SAP Business Technology PlatformEnglish

Provide feedback on our search

␣

Assign Roles in the Kyma Environment

Kyma uses roles to manage access within the cluster, which give the assigned users the permissions suitable for their purposes.

Prerequisites

The cluster-admin role is assigned to your account.

Note

After creating a Kyma cluster, you become an admin of this instance and the cluster-admin role is assigned to you by default. As the cluster-admin, you can assign roles to other users. Only the administrator who created the current subaccount can use the SAP BTP cockpit to assign the cluster-admin role to other members.

Context

You can assign roles to a group of users only if you use a custom identity provider. Assigning roles in Kyma is based on the Kubernetes role-based access control (RBAC). You can see the list of available roles in Kyma dashboard when you create a Role Binding. Once you become the admin, your user name is read from the SAP BTP (RBAC) concept and is passed to the Kyma provisioner to be bound to the cluster-admin role in Kyma.

Procedure

Log in to Kyma dashboard. The URL is in the Overview section of your subaccount.

In Kyma dashboard, select or create the namespace in which you want to assign roles.

To create a role binding, go to Configuration > Role Bindings

Create. Fill in the required fields:

As Name, insert the name of your binding.

As Role Type, choose ClusterRole.

As Role, choose the required role from the list.

As Kind, choose User.

As User name, insert the user email address.

Select Create.

Results

The users have the required permissions within the specified namespace. If the users don't have additional Cluster Role Binding to list the namespaces, they can still access the Kyma dashboard overview but must enter the required namespace name manually.

Next Steps

If the permissions of the default role aren't sufficient, clone the role and add the missing resources.

Related Information

Role-Based Access Control (RBAC) in Kyma

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assign-user-groups-to-role-collections>

Title: Assign User Groups to Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Assigning Role Collections to Users or User GroupsAssign User Groups to Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Assign User Groups to Role Collections

You can assign users groups to a role collection by adding them to the role collection.

Prerequisites

You're using a custom identity provider. For more information, see Trust and Federation with Identity Providers.

Context

You can assign user groups from custom identity providers to a role collection. After having chosen the identity provider, enter the user group name.

Procedure

Open the SAP BTP cockpit.

Go to your global account and subaccount (see Navigate in the Cockpit).

Choose Security > Role Collections.

Choose the role collection to which you want to assign user groups.

Go to the User Groups section and choose Edit.

Select the identity provider where the user group is stored.

Enter the name of the user group.

Note

If you're using SAP Cloud Identity Services, you can find the name of the user group in the administration

console under Users & Authorizations User Groups. For more information, see the related link.

(Optional) To add other user groups, choose →X (Add a user group).

Save your changes.

Related Information→

User groups in the SAP Cloud Identity Services

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assign-users-to-role-collections>

Title: Assign Users to Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Assigning Role Collections to Users or User GroupsAssign Users to Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

→

Assign Users to Role Collections

You can assign users to role collections by adding them to the desired role collection in the SAP BTP cockpit. Use this function to manage user authorizations and access control within your global account or subaccount in the cloud platform.

Context→

You can assign users to a role collection. After having entered the user's user ID, choose the name of the trust configuration and the e-mail address.

Procedure→

Open the SAP BTP cockpit.

Go to your global account or subaccount (see Navigate in the Cockpit).

Choose Security Role Collections.

Choose the role collection to which you want to assign users.

Go to the Users section and choose Edit.

Enter the user ID, identity provider, and e-mail address of the user that you want to assign to the role collection.

(Optional) To add more users, choose →X (Add a user).

Save your changes.

You've now assigned this user to the role collection. The user has the authorizations of the role collection.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assigning-abap-developer-user-to-abap-developer-role>

Title: Assigning the ABAP Developer User to the ABAP Developer Role | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Creation of Developer UsersAssigning the ABAP Developer User to the ABAP Developer Role

SAP Business Technology PlatformEnglish

Provide feedback on our search

→

Assigning the ABAP Developer User to the ABAP Developer Role

Add the developer user as business user to the ABAP instance.

You have created an employee record for the new developer user (see Creating an Employee Record for a New Developer).

Caution

The SAP_BR_DEVELOPER role is pre-defined by SAP and only intended for the initial set-up of a system.

Please create your own business roles based on the required business role template.

For information about creating a business role based on a development-related business catalog, see Business Catalogs for Development Tasks.

Log on to the administration launchpad of the ABAP environment as administrator (see Logging on to the Administration Launchpad of the ABAP Environment).

On the SAP Fiori launchpad, choose the Maintain Business Users tile.

Choose New.

In the following dialog, choose the employee record of the new developer user from the list.

Confirm the system message that you want to create a new user.

On the Assigned Business Roles tab, choose Add.

Select the checkbox for the ABAP developer role that you have created before (see Prerequisites).
Choose OK and save your entries.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assigning-abap-environment-administrator-role-to-new-administrator-user>

Title: *Assigning the ABAP Environment Administrator Role to the New Administrator User | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Creation of Additional Administrator Users (Optional)Assigning the ABAP Environment Administrator Role to the New Admini...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Assigning the ABAP Environment Administrator Role to the New Administrator User

Add the new administration user as administrator to the ABAP instance.

You have logged on to the administration launchpad of the ABAP environment as administrator (see Logging on to the Administration Launchpad of the ABAP Environment). You have created an employee record for another, new administrator.

On the SAP Fiori launchpad, choose the Maintain Business Users tile.

Choose New.

In the following dialog, choose the employee record of the new administrator from the list.

Confirm the system message that you want to create a new user.

Add the time zone to the business user data.

On the Assigned Business Roles tab, choose Add.

Select the checkbox for the predefined administrator business role SAP_BR_ADMINISTRATOR.

Select the checkbox for other administrator roles that are available for your organization and choose OK.

Choose OK.

Choose Save.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/assigning-role-collections-to-users-or-user-groups>

Title: *Assigning Role Collections to Users or User Groups | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Working with Role CollectionsAssigning Role Collections to Users or User Groups

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Assigning Role Collections to Users or User Groups

You can assign role collections to users and user groups.

Prerequisitesà^

You have administration rights in this subaccount or global account. For more information, see Security Administration: Managing Authentication and Authorization or Role Collections and Roles in Global Accounts, Directories, and Subaccounts.

The roles defined by your application developers in the application security descriptor are available in the SAP BTP cockpit. For more information, see Adding Authentication and Authorization.

The users are stored in identity providers that are connected to SAP BTP.

Default identity provider (SAP ID service). For more information, see Default Identity Provider.

Custom identity provider. For more information, see User Management in SAP Cloud Identity Services.

You perform the following tasks to assign role collections to users and user groups stored by identity providers.

The identity providers are connected to SAP BTP using trust configurations.

Note

Custom identity providers can provide user groups and users whereas default identity providers can only provide individual users.

Assign Users to Role Collections

Delete Users from Role Collections

Assign User Groups to Role Collections

Delete User Groups from Role Collections

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/attributes>

Title: Attributes | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Building Roles and Role Collections for ApplicationsAttributes

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Attributes

Attributes use information that is specific to the user, for example the user's country. If the application developer in the Cloud Foundry environment of SAP BTP has created a country attribute to a role, this restricts the data a business user can see based on this attribute.

A lot of applications provide purely functional role templates which grant access for all data of a certain type within your subaccount. Roles for such role templates are generated automatically. Some other applications also provide the possibility for administrators to restrict access not only by functional authorizations, but also by instance-based authorizations. That means that users can only work with a certain subset of the data in your subaccount.

The restriction can be either based on information within the respective role, or on user-specific information provided by the identity provider. This makes instance-based authorizations specific for each customer because the respective roles cannot be generated automatically. Instead, administrators must create them. Typical restrictions depend on information like the user's country or cost center.

Each restriction is represented by a dedicated attribute which belongs to a role template of the application.

Note

Application developers can define attribute references in the application security descriptor file (xs-security.json): For more information, see Application Security Descriptor Configuration Syntax.

For each attribute, administrators have multiple options to specify the value which restricts data access:

Static attributes

They are stored in the role. The user is given the attribute value when the administrator assigns the role collection with this role to the user.

Attributes from a custom identity provider

Since an identity provider provides the business users, you can dynamically reference all attributes that come with the SAML 2.0 assertion. You define the attributes and the attribute values in the identity provider. In the Cloud Foundry environment of SAP BTP, administrators can use the attributes to refine the roles.

Note

If you want to reference attributes from your identity provider, you must know the exact identifier of the attribute. Go to the SAML 2.0 or OpenID Connect configuration of your identity provider and use the attributes as they are defined there.

Unrestricted attributes

In this case, you want to express that it is not necessary to set a specific value for this attribute. The behavior is the same as if the attribute would not exist for this role.

Related Informationà

Specify Attributes in a Role

Specify Attributes in a New Role

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/authenticationmethod>

Title: authenticationMethod | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Routing Configuration FileauthenticationMethod

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

authenticationMethod

The method used to authenticate user requests, for example: "route" or "none" (no authentication).

Code Syntax

âE

ã

"authenticationMethod" : "route"

Property

Type

Mandatory

Values

authenticationMethod

String

No

route (default)

Authentication type is defined in the routes configuration

none

Disables authentication for all routes

Caution

If authenticationMethod is set to "none", login with User Account and Authentication (UAA) is disabled.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/btp-security>

Title: Security | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecurity

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Security

Use the security features and functions of SAP BTP to support the security policies of your organization.

Security Recommendationsà^

We provide a list with our recommendations for the configuration of our services. These recommendations help you to meet your compliance goals and secure your business.

See SAP BTP Security Recommendations.

Our customer success organization uses these recommendations as a base to create a security baseline template.

For more information, go to <https://support.sap.com/sos> and choose Media Library SAP CoE Security Services - Security Baseline Template.

User Modelà^

SAP BTP distinguishes between platform users (account management, custom development, and operations) and business users (for the applications).

See User and Member Management.

Authorizationsà^

You can configure authorizations using roles and role collections for your global account, subaccount, directory, or individual applications.

See Security Administration: Managing Authentication and Authorization.

Identity Providersà^

All users of SAP BTP are stored in identity providers, either in the default or in a custom identity provider. SAP BTP needs a copy of the user, sometimes called a shadow user. You assign the shadow user authorizations to access resources in SAP BTP. When a user authenticates, SAP BTP forwards the request to the identity provider.

For more information, see Trust and Federation with Identity Providers.

Note

For the China (Shanghai) region, a different default identity provider is used.

For more information, see this blog article on SAP Community.

Default Identity Providerà^

We provide a default identity provider for both platform users and business users (in applications) at SAP BTP.

The default identity provider enables single sign-on to your SAP applications and services.

Use the default identity provider as a preconfigured user store in your starter scenarios or for testing. You can also use the default identity provider as a backup identity provider if access to your custom identity provider fails.

See Default Identity Provider.

Identity Authentication Serviceà^

Identity Authentication service provides authentication and single sign-on in the cloud.

We recommend that you configure the Identity Authentication service as the identity provider and connect Identity Authentication to your own corporate identity provider. Identity Authentication provides features that the default identity provider doesn't, such as the ability to connect your corporate identity provider or to define security policies.

See Trust and Federation with Identity Providers.

For more information about Identity Authentication, see SAP Cloud Identity Services - Identity Authentication.

Transport Layer Security (TLS) Connectivity Supportà^

SAP BTP uses encrypted communication channels based on HTTPS/TLS, supporting TLS version 1.2 or higher.

Note

TLS versions 1.0 and 1.1 are no longer supported.

Make sure you use HTTP clients (such as web browsers) that support TLS version 1.2 or higher for connecting to SAP BTP.

Note

You can optionally use TLS 1.3 in the Custom Domain Manager. This option allows the use of TLS 1.3 with applications running on SAP BTP. It's not allowed to use TLS 1.3, for example for the SAP BTP cockpit or SAP Cloud Identity Services. These services are still using TLS 1.2.

See What Is Custom Domain.

Audit Loggingà^

Use the Audit Log Retrieval API to view the audit logs stored for your subaccount. Use the audit log viewer to display the audit logs for your Cloud Foundry account, produced by SAP applications and services you've subscribed to. See Audit Logging in the Cloud Foundry Environment.

Credential Storeà^

SAP Credential Store provides a repository for passwords and keys for applications that are running on SAP BTP, Cloud Foundry environment. It enables the applications to retrieve credentials and use them for authentication to external services, or to perform cryptographic operations and TLS communication.

See SAP Credential Store.

Malware Scanningà^

Use the SAP Malware Scanning service to scan business documents for malware. Integrate this service with your custom-developed apps running on the Cloud Foundry runtime. When your apps upload business documents, your apps can call the SAP Malware Scanning service to check for viruses or other malware.

For more information, see SAP Malware Scanning Service.

Related Informationà^

SAP Authorization and Trust Management Service

Audit Logging in the Cloud Foundry Environment

Principal Propagation

Data Protection and Privacy

Security in the Kyma Environment

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/building-roles-and-role-collections-for-applications>

Title: Building Roles and Role Collections for Applications | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Security

Administration: Managing Authentication and AuthorizationBuilding Roles and Role Collections for Applications

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Building Roles and Role Collections for Applications

As an administrator, you can maintain application roles and role collections which can be used in user management.

The user roles are derived from role templates that are defined in the security description (xs-security.json) of applications that have been registered as OAuth 2.0 clients at the User Account and Authentication service during application deployment. The application security-descriptor file also contains details of the authorization scopes that are used for application access and defines any attributes that need to be applied. The roles you

create can be added to role collections.

You can perform the following tasks:

Create and delete user roles

User roles define authorization scopes and are based on the role templates and scopes defined in the application's security descriptor file

Add user roles to one or more "role collections"

Configure and manage role collections

Tip

Using the SAP BTP cockpit, you can assign the role collections to users directly or indirectly over attributes, such as groups.

Related Information

Add Roles to Role Collections on the Application Level

Mapping Role Collections

Protecting Your Application

Working with Role Collections

Limits for Technical Artifacts of the SAP Authorization and Trust Management Service

Adding Authentication and Authorization

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/change-logging-and-read-access-logging>

Title: *Change Logging and Read-Access Logging | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecurityData

Protection and PrivacyChange Logging and Read-Access Logging

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Change Logging and Read-Access Logging

Change logging records changes to personal data, while read-access logging records access to sensitive personal data. You may be required to gather this information for auditing purposes or legal requirements.

Use the appropriate API to retrieve logs.

For the Cloud Foundry, see Audit Log Retrieval API Usage for Subaccounts in the Cloud Foundry Environment.

Note

For any applications you develop, you must ensure they include logging functions. SAP BTP does not provide audit logging functions for custom developments.

Logs are deleted regularly.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/configure-credential-type-for-html5-application-repository-service-instances>

Title: *Configure the Credential Type for HTML5 Application Repository Service Instances | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Security and Data

Privacy ConfigurationConfigure the Credential Type for HTML5 Application Repository Se...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Configure the Credential Type for HTML5 Application Repository Service Instances

When you create an HTML5 application repository service instance key or bind a service instance to an application, values for client_id and client_secret are generated. The client_secret is the equivalent to a password.

As of January 28, 2021, the credential type binding_secret is automatically used for the client_secret value of new HTML5 application repository service instance keys. This increases the security because the credential type binding_secret creates a new client_secret for each binding and service key.

If you have older HTML5 application repository service instances, the client_secret value is the same for all bindings and service keys because the HTML5 application repository still uses the credentials type instance_secret for older HTML5 application repository service instances. To configure the more secure credential type binding_secret for your older HTML5 application repository service instances, please follow the instructions in Configure the Credential Type binding_secret for HTML5 Application Repository Service

Instances.

As an alternative to the credential type `binding_secret`, you can also use the credential type `x.509` to authenticate your apps with X.509 certificates. For more information, see [Credential Type x509 for HTML5 Application Repository Service Instances](#).

Configure the Credential Type `binding_secret` for HTML5 Application Repository Service Instances[^]
Extract the UUID part of the `xsappname` from the of the existing instance. For example:

Sample Code

```
â€”  
~  
cf create-service-key <serviceInstanceName> <serviceInstanceKeyName>  
â€”
```

Sample Code

```
â€”  
~  
cf service-key <serviceInstanceName> <serviceInstanceKeyName>  
.....  
"clientsecret": "HksDYy9RxYFUQeOHIzprqBam3vQ=", //Old instance secret  
...  
"xsappname": "fec39a25-a570-46b0-8ac9-1691f8d663cc!b6711|html5-apps-repo-uaa!b6711",  
.....  
â€”
```

Copy the UUID. In this example: `fec39a25-a570-46b0-8ac9-1691f8d663cc`

Create a file `instance-xs-security.json`, such as the following:

Sample Code

```
â€”  
~  
{  
  "xs-security": {  
    "xsappname": "fec39a25-a570-46b0-8ac9-1691f8d663cc",  
    "oauth2-configuration": {  
      "credential-types": ["binding-secret"]  
    }  
  }  
}
```

Update the service instance:

Sample Code

```
â€”  
~  
cf update-service <serviceInstanceName> -c instance-xs-security.json  
â€”
```

Check that the instance now creates binding secrets as follows:

Sample Code

```
â€”  
~  
cf create-service-key <serviceInstanceName> <serviceInstanceKeyNameNew>  
â€”
```

Sample Code

```
â€”  
~  
cf service-key <serviceInstanceName> <serviceInstanceKeyNameNew>  
.....  
"clientid": "sb-fec39a25-a570-46b0-8ac9-1691f8d663cc!b6711|html5-apps-repo-uaa!b6711",  
"clientsecret": "8c902673-00d4-471f-9ebb-4463d4073fda$7Nlo5batSFZCF1RNGcpNkRfo4mDj6vq-  
cEIDFIcvcwg=", //New binding secret (long)  
"identityzone": .....,
```

```
"identityzoneid": .....,
```

```
.....
```

```
âf
```

Credential Type x509 for HTML5 Application Repository Service Instancesâ

To use the HTML5 application repository service and authenticate with X.509 certificate, you need to acquire the required key, certificate, and base URLs. These are provided when you create an instance of the HTML5 application repository service and a binding or a service key for the instance.

When you bind an HTML5 applications repository service instance to an application, you have to explicitly provide the required configuration parameters for the authentication with x.509:

```
cf bind-service <application> <service-instance> -c parameters.json
```

The same applies if you create service keys:

```
cf create-service-key <service-instance> <key-name> -c parameters.json
```

The configuration for the credential type x509 must be wrapped with xsuaa. You have to use exactly the following format for the configuration:

```
âE
```

```
â
```

```
{
```

```
"xsuaa": {
```

```
"credential-type": "x509",
```

```
"x509": {
```

```
"key-length": 2048, // specifies the byte length of the generated private key,
```

```
// defaults to 2048
```

```
"validity": 7, // specifies the number of time units in validity-type,
```

```
// defaults to 7, thus the complete validity defaults to 7 days
```

```
"validity-type": "DAYS" // specifies the validity time unit,
```

```
// only DAYS, MONTHS and YEARS are supported,
```

```
// defaults to DAYS
```

```
}
```

```
}
```

```
}
```

```
âf
```

Note

The following applies to existing HTML5 application repository service instances:

Before you create a binding to a service instance or a service key as described above, you have to update of the service instance of your existing HTML5 application repository service instance. Use parameters to provide the configuration during the update of the existing service instance:

```
cf update-service <service-instance> -c update-instance-xs-security.json
```

To configure the credential type x509 for existing HTML5 application repository service Instances, please follow the instructions below:

Configuring Credential Type x509 for Existing HTML5 Application Repository Service Instances

To configure the credential type x509 for your existing HTML5 application repository service instances, perform the following steps:

Extract the UUID part of the xsappname from the service key or the binding for the service instance. For example:

Sample Code

```
âE
```

```
â
```

```
cf service-key <serviceInstanceName> <existingServiceInstanceKeyName>
```

```
.....
```

```
"clientsecret": "HksDYy9RxYFUQeOHIzprqBam3vQ=", //Old instance secret
```

```
...
```

```
"xsappname": "fec39a25-a570-46b0-8ac9-1691f8d663cc!b6711|html5-apps-repo-uaa!b6711",
```

```
.....
```

```
âf
```

Copy the UUID. In this example: fec39a25-a570-46b0-8ac9-1691f8d663cc

Create a file update-instance-xs-security.json with the following format:

Sample Code

âE

ã

{

"xs-security": {

"xsappname": "fec39a25-a570-46b0-8ac9-1691f8d663cc", //The UUID that was extracted before

"oauth2-configuration": {

"credential-types": ["x509"]

}

}

àf

Update the service instance:

cf update-service <serviceInstanceName> -c update-instance-xs-security.json

Create a file parameters.json, such as the following: :

Sample Code

âE

ã

{

"xsuaa": {

"credential-type": "x509",

"x509": {

"key-length": 2048,

"validity": 7,

"validity-type": "DAYS"

}

}

}

(Note that the values of the "x509" properties used here are just examples.)

Create a binding or a service key with the credential type x509 configuration (parameters.json file). For example:

cf create-service-key <serviceInstanceName> <serviceInstanceKeyNameNew> -c parameters.json

Check that the instance now creates a certificate and that the credential-type is "x509", as follows:

cf service-key <serviceInstanceName> <serviceInstanceKeyNameNew>

The following binding is generated as a result:

âE

ã

{

.....

"certificate": "-----BEGIN CERTIFICATE-----...-----END CERTIFICATE-----\n-----BEGIN CERTIFICATE-----..-----

END CERTIFICATE-----\n-----BEGIN CERTIFICATE-----...-----END CERTIFICATE-----\n",

"clientid": ".....",

"credential-type": "x509",

.....

}

àf

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/configure-custom-identity-provider-for-kyma>

Title: Configuring a Custom Identity Provider for Kyma | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Authentication in the Kyma EnvironmentConfiguring a Custom Identity Provider for Kyma

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Configuring a Custom Identity Provider for Kyma

Enable the Kyma environment with a custom identity provider (IdP).

Prerequisites

If you choose to use SAP Cloud Identity Services as a custom IdP, you have configured your tenant as an OpenID Connect (OIDC) provider for your Kyma cluster. For details, see [Configure OpenID Connect Application for Authorization Code Flow](#).

Tip

When using SAP Cloud Identity Services as a custom IdP, make sure you have public client flows enabled.

You have the Kyma dashboard URL (<https://dashboard.kyma.cloud.sap>) and the localhost for kubectl authentication (<http://localhost:8000>) configured as allowed callback URLs at your IdP provider, so that authenticated users can be redirected back to the Kyma application. See [Redirect URIs, Post Logout Redirect URI Rules](#).

Tip

It is recommended to use SAP Cloud Identity Services tenant as a custom IdP. It allows you to use SAP Cloud Identity Services as a proxy to integrate your corporate identity provider. See [Get Your Tenant](#). You could also configure SAP Cloud Identity Services to use a third-party IdP if you already have one.

Context

When you create a new Kyma instance in the SAP BTP cockpit from the Service Marketplace, you can configure your custom OpenID Connect IdP to authenticate users in your Kyma runtime.

If you've already created your Kyma environment, you can also apply the custom IdP configuration and set up administrators during your Kyma instance update operation by providing the details as an array of strings in the respective fields.

Procedure

Go to [Services > Service Marketplace and Creating Kyma Instances](#).

In the Additional Parameters view, go to `Oidc`, choose `List`, and fill in the following fields:

`Client ID` - the client ID for the OpenID client

`Groups Claim` - the name of a custom OpenID Connect claim for specifying user groups

Note

An identity provider token consists of fields (claims) that are included in it. For example:

```
âE
{
  sub: "john.doe@sap.com"
  groups: ["SAP fans", "Identity Provider", "OpenID"]
}
```

When you configure `Username Claim`, Kubernetes knows which field (claim) includes the user represented by a given token.

Similarly, when you configure `Groups Claim`, Kubernetes knows to which groups the user is assigned.

`Issuer URL` - the URL of the OpenID issuer (use the https schema)

`Signing Algs` - the list of allowed cryptographic algorithms used for token signing. The allowed values are defined by RFC 7518.

`Username Claim` - the name of a custom OpenID Connect claim for specifying a username

`Username Prefix` - the prefix for an OIDC username for Kyma runtime. If you don't provide it, username claims other than "email" are prefixed by the issuerURL to avoid clashes. To skip any prefixing, provide the value as `-`.

`Groups Prefix` - if specified, causes claims mapping to group names to be prefixed with the provided value. To skip any prefixing, provide the value as `-`.

`Required Claims` - describes a required claim in the ID Token. If set, the claim is verified to be present in the ID Token with the matching value.

`Administrators` - the list of usernames meant to be administrators. Users identified with those usernames get the role `cluster-admin` during provisioning of your Kyma runtime.

You can also provide the configuration as a JSON object:

```
âE
{
  "oidc": {
    "list": [
```

```
{
  "issuerURL": "{issuerURL}",
  "clientId": "{clientId}",
  "usernameClaim": "sub",
  "groupsClaim": "groups",
  "signingAlgs": ["RS256"],
  "usernamePrefix": "-",
  "groupsPrefix": "-",
  "requiredClaims": ["first-claim=value", "second-claim=value"]
},
]
```

àf

Note

If you want to revert to the default settings, use the following configuration:

âE

ã

```
"oidc": {
  "list": [
    {
      "clientId": "12b13a26-d993-4d0c-aa08-5f5852bbdff6",
      "groupsClaim": "groups",
      "issuerURL": "https://kyma.accounts.ondemand.com",
      "groupsPrefix": "-",
      "signingAlgs": ["RS256"],
      "usernameClaim": "sub",
      "usernamePrefix": "-",
      "requiredClaims": ["-"]
    },
  ]•
  "administrators": [
    "example_3@mail.com",
    "example_4@mail.com"
  ]
}
```

The email addresses must be recognized by <https://kyma.accounts.ondemand.com>.

Select Create.

Resultsà^

Your Kyma environment is instantiated with a custom IdP.

Related Informationà^

Authentication in the Kyma Environment

Custom OpenID Connect Configuration

OpenID Connect (OIDC)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/create-role-collections-with-predefined-roles>

Title: Create Role Collections with Predefined Roles | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Tasks On

DemandCreate Role Collections with Predefined Roles

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Create Role Collections with Predefined Roles

As an application developer, you want to create role collections for immediate use. You want to deliver role collections that administrators can use in the cockpit, and easily assign to users, for example in an onboarding process.

Prerequisites

You have the Space Developer role in this subaccount (see the related link).

Context

You define the role collections in the application security descriptor file (xs-security.json). These role collections reference role templates. As soon as you've deployed your application, the cockpit displays the role collections. They contain predefined roles.

Procedure

Deploy an application you want to use for creating security artifacts.

Edit the application descriptor file (xs-security.json) and add the role-collections property. For more information, see Application Security Descriptor Configuration Syntax.

Sample Code

```
{
  "role-templates": [
    {
      "name": "Viewer",
      "description": "View Users",
      "scope-references": [
        "$XSAPPNAME.Display"
      ]
    },
    {
      "name": "Manager",
      "description": "Maintain Users",
      "scope-references": [
        "$XSAPPNAME.Display",
        "$XSAPPNAME.Update"
      ]
    }
  ],
  "role-collections": [
    {
      "name": "UserManagerRC",
      "description": "User Manager Role Collection",
      "role-template-references": [
        "$XSAPPNAME.Viewer",
        "$XSAPPNAME.Manager"
      ]
    }
  ]
}
```

Go to the folder where the application security descriptor (xs-security.json) file is stored.

To deploy the security information, create a service using your xs-security.json file.

```
cf create-service xsuaa application <service_name> -c xs-security.json
```

Example

```
cf create-service xsuaa application rolecoll-serv -c xs-security.json
```

(If you do not use a manifest file) Bind your application to the service.

```
cf bind-service <application_name> <service_name>
```

Example

cf bind-service rcpropertyapp rolecoll-serv

You have created a role collection that is visible in the cockpit. It contains predefined roles. Using the cockpit, administrators can assign this role collection to users.

Related Information[^]

About Roles in the Cloud Foundry Environment

Adding Authentication and Authorization

Deploy Business Applications in the Cloud Foundry Environment

Mapping Role Collections

Tutorials for the SAP Authorization and Trust Management Service

Application Security Descriptor Configuration Syntax

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/create-routes>

Title: Create Routes | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...About Routes in the CockpitCreate Routes

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Create Routes

You can configure the URLs through which end users can reach your applications.

Prerequisites[^]

You must have the Space Developer or the Space Supporter role.

Context[^]

Routes belong to a space but they're globally unique, regardless of the organization that controls a space. If a route with a URL exists, you can't create a route with the same URL.

Procedure[^]

Navigate to your Cloud Foundry space.

Choose Routes from the left hand-side navigation.

Choose Create Route.

In the dialog, enter the following parameters:

Parameter"FWF –Ç0

Domain

From the dropdown menu, you can choose either a shared domain (for example, the default cfapps.<region>.hana.ondemand.com) or a private domain that you've previously created using the CF CLI.

From the dropdown menu, you can choose either a shared domain or a private domain that you've previously created using the CF CLI.

For more information on private domains, see <https://docs.cloudfoundry.org/devguide/deploy-apps/routes-domains.html#private-domains>.

Host Name

The host name is your desired subdomain. In the URL, it's added before the selected domain, as follows:

<https://<host name>.<domain>>

The host name can contain up to 63 characters.

Path (Optional)

In addition to the domain and subdomain, you can also add a path. You can use paths if you want to create routes for multiple applications available for the same host name and domain. The path becomes part of the URL as follows:

<https://<host name>.<domain>/<path>>

You can see the preview of your route at the bottom of the dialog.

When you're happy with your route, choose Create.

Next Steps[^]

Once you've created a route, you must map it to your application. For more information, see Map Routes to Applications.

Additionally, you also have the option to bind it to a route service instance by choosing à (Bind Route Service) from the Actions column. For more information, see Bind Routes to Service Instances.

Related Information[^]

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/create-space-quota-plans>

Title: Create Space Quotas | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Space QuotasCreate Space Quotas

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Create Space Quotas

You can use the SAP BTP cockpit to create space quotas.

Prerequisitesà^

You have the Org Manager role for the org in which you want to create a space quota.

Procedureà^

Navigate to the subaccount that contains the spaces to which you want to add quotas.

In the navigation menu, choose Cloud Foundry Space Quotas.

Choose Create Space Quota.

Enter a name for your space quota and add limits for the following:

Space Memory (MB): Total amount of memory a space can have

Routes: Total number of routes

Service Instances: Total number of service instances

Memory per Instance (MB): Maximum amount of memory an application instance can have

App Instances: Total number of application instances

(Optional) Allow Paid Service: Switch on if you'd like to allow the provisioning of instances of paid service plans.

Note

The value of -1 represents an unlimited amount.

Note

If the space quota limit for a resource exceeds the org quota limit, the org quota limit applies.

Choose Create.

Example: Creating a Space Quota in the Cockpità^

Related Informationà^

Entitlements and Quotas

Create Space Quota Plans Using the Cloud Foundry Command Line Interface

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/create-users>

Title: Create Users | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Working with UsersCreate Users

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Create Users

As an administrator, you can create shadow users in your subaccount. When you create a shadow user, you must know and specify which identity provider stores the user.

Prerequisitesà^

You've administration rights in this subaccount. For more information, see Security Administration: Managing Authentication and Authorization or Role Collections and Roles in Global Accounts, Directories, and Subaccounts.

Contextà^

All users in the subaccounts of SAP BTP are stored in identity providers, either in the default or in a custom identity provider. SAP BTP creates a copy of the user in the subaccount when a user-related action happens. The copy of the user in the subaccount is called shadow user. It's also possible to switch off the creation of shadows users (see the related link).

A new hire starts to work in your company next month. As an administrator, you want to provide a user, enable login to the SAP BTP subaccount, and provide the necessary authorizations for this new hire. You create the

actual user in the identity provider. However, you can't assign subaccount authorizations to an individual user in an identity provider. You need a shadow user in the SAP BTP subaccount to assign authorizations. After having created a shadow user, you can assign role collections. Thus, you make sure that the new hire can log on to the subaccount and that the necessary authorizations are in place when the new hire starts.

If you switched off the creation of shadow users in the trust configuration of your custom identity providers, new users created in the identity provider don't have a user copy (shadow user) in the respective SAP BTP subaccount. You, as a subaccount administrator, have full control of who can log on to this subaccount. The new user can log on to the subaccount if you've created a shadow user with the same email address in the SAP BTP subaccount. Now, you can grant authorizations by assigning role collections.

You can alternatively grant authorizations in the subaccount by mapping role collections to the user group if the user belongs to a user group in the identity provider.

As an administrator, you can create shadow users in your subaccount and you must determine which identity provider stores the user. You can then give the user authorizations by assigning role collections to the user.

Procedure

Open the SAP BTP cockpit.

Go to your global account and/or subaccount (see Navigate in the Cockpit).

Choose Security Users.

Choose Create.

The SAP BTP cockpit displays a new row where you can enter the user data.

Enter the user ID and email address.

Note

The email address of the user is the user identifier for all account levels (global account, directory, multi-environment subaccount) and for the Cloud Foundry environment.

Note

To specify the last name and first name of the user, maintain the names in the identity provider that stores the user. This information is automatically added to the shadow users when the user logs on with their identity provider using a URL such as:

<https://<myapplication>.cfapps.<region>.hana.ondemand.com/>

For example: <https://my-application.cfapps.eu10.hana.ondemand.com/>

Logging on with the SAP BTP cockpit or the command-line interface isn't enough.

Choose the identity provider where the user is stored. The dropdown list displays the identity providers configured in the trust configuration of your subaccount.

Save your changes.

You can now proceed to assign role collections to the new user.

Related Information

Switch Off Automatic Creation of Shadow Users

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/creating-new-space-members-and-assigning-space-developer-roles-to-them>

Title: *Creating New Space Members and Assigning Space Developer Roles to Them* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Creation of Developer UsersCreating New Space Members and Assigning Space Developer Roles to...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Creating New Space Members and Assigning Space Developer Roles to Them

For your developers, create new members in the space for the ABAP environment and assign developer roles to them.

Context

Note

If you have run the booster Prepare an Account for ABAP Development, you can skip this step.

Procedure

Log on to the SAP BTP cockpit as Cloud Foundry administrator.

Choose the tile for the Cloud Foundry subaccount.

In the navigation area, choose Spaces.

Choose the space for the ABAP environment.
In the navigation area, choose Members.
All members currently assigned to the space are shown in a list.
Choose Add Members.
Enter e-mail addresses of your developer users.
You can use commas, spaces, semicolons, or line breaks to separate members.
Select the space developer role for the users and save your changes.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/default-identity-provider>

Title: Default Identity Provider | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Trust and Federation with Identity ProvidersDefault Identity Provider

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Default Identity Provider

SAP ID service is the default identity provider for both platform users and business users (in applications) at SAP BTP. You can start using it without further configuration.

Recommendation

We strongly recommend that you configure your custom tenant of SAP Cloud Identity Services as the identity provider and connect SAP Cloud Identity Services to your own corporate identity provider.

For more information, see Trust and Federation with Identity Providers.

Note

For China (Shanghai) region, a different default identity provider is used.

For more information, see this blog article on SAP Community.

For Government Cloud (US) region, a different default identity provider is used.

SAP ID service provides:

A central user store

A Single Sign-On (SSO) service. It enables users to log on once and get access to all your applications.

Use SAP ID service as a preconfigured user store in your starter scenarios or for testing. You can also use the default identity provider as a backup identity provider if access to your custom identity provider fails. SAP ID service is the place where you register to get initial access to SAP BTP.

SAP ID Service Authenticates Users

If you're a new user, you can use the self-service registration option at the SAP Web site The SAP website registers you with your SAP user ID, which also registers you with SAP ID service.

Managing Usersâ

To add users to a subaccount, the users must exist in an identity provider.

For more information about adding users to our default identity providers, see Create SAP User Accounts.

To add new users to a subscribed app or service, such as Web IDE, add those users to your subaccount.

For more information, see Add Users from SAP ID Service for Multi-Environment Subaccounts.

Multifactor Authenticationâ

For SAP ID service, you can ask users hosted by this identity provider to enable multifactor authentication as a self-service. There's no mechanism to enforce users in SAP ID service to use this function.

Recommendation

To enforce multifactor authentication, we recommend that you trust SAP Cloud Identity Services - Identity Authentication and configure enforcement. Optionally, integrate SAP Cloud Identity Services with your corporate identity provider and enforce the policy there.

For more information, see:

Establish Trust and Federation of Custom Identity Providers for Platform Users

Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services

For more information about your users of SAP ID service can enable multifactor authentication themselves, see How to Enable Multi-Factor Authentication (MFA) on the SAP Support Portal.

Note

Some user interfaces don't offer an interactive way to support multifactor authentication, such as time-based

one time passwords (TOTP). Instead, such tools offer fixed logon ID and password fields. For such tools, enter your password directly followed, without any spaces or dividers, by the TOTP offered by your multifactor device.

User ID: MylogoniD

Password: MystrongpasswordMytotppasscode

For some tools, this behavior affects log on to the tool itself:

Cloud Foundry command-line interface (cf CLI)

Alternatively, you can log on through a browser instead.

For more information, see Log On Manually With a Custom Identity Provider.

SAP Business Technology Platform command-line interface (btp CLI)

Alternatively, you can log on through a browser instead.

For more information, see Log in with Single Sign-On.

For other tools, this behavior doesn't affect log on to the tool itself, but log on to the platform when establishing connections or deploying software and such. For example:

Cloud Connector

SAP Business Application Studio

SAP Web IDE

Trust and Identity Providers

The system preconfigures trust between your subaccount and SAP ID service by default, so you can start using the service without further configuration.

For web-based access, such as through a browser, you can hide the default trust.

For more information, see Hide Logon Link for Default Identity Provider.

For non-interactive logons, such as with CLI tools or password grant flow, you can make a custom identity provider the default.

For more information, see btp update security/settings.

To use a custom identity provider, establish trust with your custom identity provider. We describe a custom trust configuration using the example of SAP Cloud Identity Services.

For more information, see Trust and Federation with Identity Providers.

Related Information

Security

Platform Identity Provider for Tools

Working with Users

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/define-role-collection>

Title: Define a Role Collection | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Working with Role CollectionsDefine a Role Collection

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Define a Role Collection

To define a role collection, you can create a new role collection or copy an existing one. Add the roles, users, and user groups as needed.

Context

One way to define a role collection is to create a new role collection. After you've entered a name and description, you find the new role collection in the list of role collections. You can then add the roles you need and assign users and user groups.

If you have an existing role collection that you want to use as a template, it's a good idea to copy it. The copied role collection includes all of the roles of the origin. However, it doesn't include the users or user groups. You can give it a new name and description. You can find the copy in the list of role collections and assign users and user groups.

Procedure

Open the SAP BTP cockpit.

Go to your global account and subaccount (see Navigate in the Cockpit).

Choose Security Role Collections.

To create a new role collection, choose Create. To copy an existing role collection, choose Copy at the end of

the row.

Enter a new name and description. If you copied an existing role collection, you can see the included roles.

Save your changes.

You can now add or remove roles and assign users or user groups.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/delete-roles-from-role-collection>

Title: Delete Roles from a Role Collection | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Define a Role

CollectionDelete Roles from a Role Collection

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Delete Roles from a Role Collection

You can delete roles from a role collection.

Contextà^

The roles are derived from role templates that are provided by applications. For more information, see the related links.

Procedureà^

Open the SAP BTP cockpit.

Go to your global account and subaccount (see Navigate in the Cockpit).

Choose Security Role Collections.

To delete roles, choose the role collection name.

To drill down into the role details, choose the chevron on the right side of the row.

Choose Edit.

Choose the áô (Select multiple roles) button.

Select the roles you want to delete from the role collection.

Choose Remove.

Confirm the popup.

Save your changes.

Repeat to delete more roles.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/delete-space-members>

Title: Delete Space Members | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Space

MembersDelete Space Members

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Delete Space Members

Delete all roles of a space member in the SAP BTP cockpit. As a consequence, the member is removed from the space.

Prerequisitesà^

You have the Space Manager or Org Manager role.

The users exist in a trusted platform identity provider.

For more information, see About User Management in the Cloud Foundry Environment.

Procedureà^

Navigate to Cloud Foundry Spaces in the SAP BTP cockpit. For more information, see Navigate to Orgs and Spaces.

Choose the space from which you'd like to remove members.

In the navigation area, choose Space Members.

The screen displays all members currently assigned to the space in a list.

To remove all the roles of a member, choose à= (Delete).

This action removes the member from the space.

Related Informationà^

Managing Space Members

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/delete-user-groups-from-role-collections>

Title: Delete User Groups from Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Assigning Role Collections to Users or User GroupsDelete User Groups from Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Delete User Groups from Role Collections

You can unassign users groups from a role collection by deleting them from the role collection.

Procedureà^

Open the SAP BTP cockpit.

Go to your global account and subaccount (see Navigate in the Cockpit).

Choose Security Role Collections.

Choose the role collection from which you want to unassign a user group.

Go the to User Groups section and choose à= (Delete).

Confirm the popup and save your changes.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/delete-users-from-role-collections>

Title: Delete Users from Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Assigning Role Collections to Users or User GroupsDelete Users from Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Delete Users from Role Collections

You can unassign users from a role collection by deleting them from the role collection.

Procedureà^

Open the SAP BTP cockpit.

Go to your global account and subaccount (see Navigate in the Cockpit).

Choose Security Role Collections.

Choose the role collection from which you want to unassign users.

Choose Edit.

Choose à= (Delete) in the row of the user you want to unassign.

Save your changes.

You've now unassigned this user by deleting the user from the role collection.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/edit-org-members-using-cockpit>

Title: Edit Org Members | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Org MembersEdit Org Members

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Edit Org Members

Remove existing roles or assign new roles to an org member in the SAP BTP cockpit.

Prerequisitesà^

You have the Org Manager role for the org in question.

Note

When you enable Cloud Foundry and the org is created, the Org Manager role is assigned automatically to you.

For more information, see About Roles in the Cloud Foundry Environment.

The users exist in a trusted platform identity provider.

For more information, see About User Management in the Cloud Foundry Environment.

Procedureà^

In the navigation area in the cockpit, choose Cloud Foundry Org Members.

The screen displays all members currently assigned to the org in a list.

Find the org member in the list and choose ⌵ (Edit).
Select or unselect the roles you want to assign or remove.
For more information, see About Roles in the Cloud Foundry Environment.
Choose Save.
The changes you make to the roles of a member take effect immediately.
Related Information⌵
Add Org Members Using the Cockpit
Delete Org Members Using the Cockpit

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/edit-space-members>

Title: Edit Space Members | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Space MembersEdit Space Members

SAP Business Technology PlatformEnglish

Provide feedback on our search

⌵

Edit Space Members

Remove existing roles or assign new roles to a space member in the SAP BTP cockpit.

Prerequisites⌵

You have the Space Manager or Org Manager role.

The users exist in a trusted platform identity provider.

For more information, see About User Management in the Cloud Foundry Environment.

Procedure⌵

Navigate to Cloud Foundry Spaces in the SAP BTP cockpit. For more information, see Navigate to Orgs and Spaces.

Choose the space in which you'd like to edit the space roles of any of its members.

In the navigation area, choose Space Members.

The screen displays all members currently assigned to the space in a list.

Choose ⌵ (Edit).

Select or unselect the space roles you want to assign or remove.

For more information, see About Roles in the Cloud Foundry Environment.

Choose Save.

The changes you make to the roles of a member take effect immediately.

Related Information⌵

Add Space Members

Delete Space Members

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/establish-trust-and-federation-between-uaa-and-identity-authentication>

Title: Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Business UsersEstablish Trust and Federation Between SAP Authorization and Trus...

SAP Business Technology PlatformEnglish

Provide feedback on our search

⌵

Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services

Use your SAP Cloud Identity Services tenant as an identity provider or a proxy to your own identity provider hosting your business users. This method avoids the upload and download of SAML meta data by using OpenID Connect (OIDC) to establish trust.

Prerequisites⌵

You have subaccount administrator permissions.

You have a tenant of SAP Cloud Identity Services.

For more information, see Get Your Tenant in the documentation for SAP Cloud Identity Services.

The SAP Cloud Identity Services tenant is associated with the customer IDs of the relevant global account of

SAP BTP.

For more information, see [Reuse SAP Cloud Identity Services Tenants for Different Customer IDs in the documentation for SAP Cloud Identity Services](#).

Contextà

Note

The content in this section is not relevant for Government Cloud (US) regions.

Consider the following restrictions and tips before you start.

Restriction

You can only establish trust with a single tenant of SAP Cloud Identity Services per subaccount using this method.

Your SAP Cloud Identity Services tenant can be changed only when no SAP Cloud Identity Services-based subscriptions (for example, SAP Build Work Zone using authentication with SAP Cloud Identity Services, SAP Build Apps, or SAP Integration Suite, advanced event mesh) exist.

If you have an SAML trust configuration for a certain tenant already, you can't add an OIDC trust configuration to the same tenant in addition. Instead, migrate the SAML trust configuration to OIDC (see [Migration from SAML Trust to OpenID Connect Trust with SAP Cloud Identity Services](#)).

Consider the upper limits for trust configurations in the subaccount. See [Limits for the Subaccount](#).

Tip

We recommend that you use SAP Cloud Identity Services as identity provider and connect a potential corporate identity provider there. If you don't have a tenant yet, check [Getting a Tenant](#).

For more information, see [Corporate Identity Providers and Configure Conditional Authentication for an Application in What Is Identity Authentication and SAP Cloud Identity Services](#)

We provide APIs so you can perform this procedure programmatically. For more information, see the [Identity Provider Management API on SAP Business Accelerator Hub](#).

Procedureà

In the SAP BTP cockpit, go to your subaccount (see [Navigate in the Cockpit](#)) and choose **Security Trust Configuration**.

Choose **Establish Trust**.

The Choose Tenant wizard opens.

Choose the SAP Cloud Identity Services tenant and choose **Next**.

The identity providers listed are the SAP Cloud Identity Services tenants associated with your customer ID.

For more information, see the preceding prerequisites.

You can change the name and the description of the tenant, display and change the origin key.

The origin key can have 36 characters at maximum. Only use the following characters for the origin key of the trust configuration.

aA–zZ, 0–9, - (hyphen), _ (underscore)

Choose the domain configured with the SAP Cloud Identity Services tenant and continue with **Next**. It's also possible to use **Default** as domain.

Available for User Logon is switched on. Provide a link text for user logon (see [Using Multiple Identity Providers from the Same Subaccount](#)).

If unsure, keep the parameter **Create Shadow Users on User Logon** switched on. After logon, SAP BTP automatically creates a shadow user. Logon failures would occur if the shadow user doesn't exist. An administrator can then assign role collections to the shadow user.

If unsure, keep the parameter **Default for Noninteractive Logon** as suggested by the wizard (only for logon to a command line interface). If you switch on this parameter, it sets another identity provider as default for noninteractive logon (for more information, see [btp update security/settings](#)). Continue with **Next**.

Review your configuration and confirm using **Finish**.

Resultsà

You've configured trust in your tenant of the SAP Cloud Identity Services, which is your identity provider. SAP Cloud Identity Services creates an application with the prefix SAP BTP subaccount and the display name of your subaccount in the administration console for SAP Cloud Identity Services. Some attributes of the application are managed by SAP, such as the application type, and are read-only.

SAP BTP automatically creates applications in SAP Cloud Identity Services for subscriptions to BTP applications and service instances of the Identity service of SAP BTP. Newly created applications in SAP Cloud

Identity Services are automatically set as child applications of the application that represents the relevant SAP BTP subaccount. Child applications inherit configurations such as the subject name identifier, authentication configuration, and branding from the parent application representing the subaccount.

Example

If your subaccount is named My Subaccount, the resulting application in SAP Cloud Identity Services would be SAP BTP subaccount My Subaccount.

Older applications start with XSUAA_.

Tip

To troubleshoot problems with tokens from SAP Cloud Identity Services, see Logging OpenID Connect Tokens in the documentation for SAP Cloud Identity Services.

Restriction

If the OIDC issuer is changed in the trust configuration, the trust breaks. To update the trust configuration on the SAP BTP side, open the details of the trust configuration and choose Refresh. This button refreshes the trust configuration to reflect changes in the SAP Cloud Identity Services tenant, for example the issuer value.

Next Steps

If you don't need the default identity provider anymore, set it to inactive or hide the logon link.

Related Information

Default Identity Provider

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/establish-trust-and-federation-of-custom-identity-providers-for-platform-users>

Title: Establish Trust and Federation of Custom Identity Providers for Platform Users | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Platform

UsersEstablish Trust and Federation of Custom Identity Providers for P...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Establish Trust and Federation of Custom Identity Providers for Platform Users

You want to use a custom identity provider for the platform users of SAP BTP in different environments and at the different account levels: global account, directory, and subaccount. By default, platform users in multi-environment subaccounts are users in the default identity provider.

Prerequisites

You have a tenant of SAP Cloud Identity Services.

Note

For the custom identity provider for platform users, you can have up to three SAP Cloud Identity Services tenants per global account. Multiple global accounts can share the same SAP Cloud Identity Services tenant. For more information, see Tenant Model and Licensing in the documentation for SAP Cloud Identity Services. The SAP Cloud Identity Services tenant is associated with the customer IDs of the relevant global account of SAP BTP.

For more information, see Reuse SAP Cloud Identity Services Tenants for Different Customer IDs in the documentation for SAP Cloud Identity Services.

Make sure that the email addresses of all users in your identity provider are unique and correct.

Note

The email address of the user is the user identifier for all account levels (global account, directory, multi-environment subaccount) and for the Cloud Foundry environment.

Context

Note

The content in this section is not relevant for China (Shanghai) and Government Cloud (US) regions. Platform users perform technical development, deployment, and administration tasks. For example, they perform subaccount administration in the SAP BTP cockpit or access the Cloud Foundry command line interface (CF CLI). By hosting these users in your own identity provider, you gain a number of advantages over hosting them in the default identity provider.

Integrate the management of these users with your corporate identity management strategy, hosted on your own identity providers. You control your own user lifecycle and single sign-on strategies throughout the entire landscape.

Enforce your own password and authentication policies, such as stronger passwords or multifactor authentication.

Note

The content in this section is only relevant for platform users and not business users.

For more information about establishing trust for business users, see [Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services](#).

Establish a trust relationship with a custom identity provider in your global account in SAP BTP. The following procedure guides you through the trust configuration with your custom identity provider.

Procedure

Go to your global account (see [Navigate in the Cockpit](#)) and choose **Security Trust Configuration** in the SAP BTP cockpit.

Choose **Establish Trust**.

The identity providers listed are the SAP Cloud Identity Services tenants associated with your customer ID.

Select an identity provider from the list of available tenants and choose **Next**.

Enter a name and a description of the new trust configuration. If possible, set the origin key. The origin key always ends with `-platform`. Continue with **Next**.

Note

The origin key is a technical identifier of an identity provider for platform users. Administrators need it when managing users. Platform users from the identity provider need the origin key when signing in with certain tools, such as the Cloud Foundry command-line interface or service dashboards.

You can only set the origin key once for the whole landscape. You can't change the origin key later.

The whole origin key including `-platform` can have at maximum 36 characters. Only use the following characters for the origin key of the trust configuration.

aA–zZ, 0–9, - (hyphen), _ (underscore)

Choose your desired domain of the tenant and continue with **Next**. For a good single sign-on experience, choose the same domain for all SAP BTP accounts and non SAP BTP applications that use this tenant.

The wizard shows you a preview of your configuration. To complete your new trust configuration, choose **Finish**.

Remember

If the OIDC issuer was changed in the trust configuration, the trust breaks, but the global account automatically repairs the trust after 24 hours.

To update the trust configuration on the SAP BTP side, open the details of the trust configuration and choose **Refresh**. This button immediately refreshes the trust configuration to reflect changes in the SAP Cloud Identity Services tenant, for example the issuer value.

Results

You've configured trust in your tenant of SAP Cloud Identity Services, which is your identity provider. SAP Cloud Identity Services creates an application with the name `SAP Business Technology Platform`. Administrators can change this name. Some attributes of the application are managed by SAP, such as the application type, and are read-only.

Tip

To troubleshoot problems with tokens from SAP Cloud Identity Services, see [Logging OpenID Connect Tokens](#) in the documentation for SAP Cloud Identity Services.

Next Steps

Add platform users to your orgs and spaces.

For more information about adding members with the SAP BTP cockpit, see [Add Org Members](#) and [Add Space Members](#).

For more information about adding members with the command-line interface, see [Add Organization Members Using the Cloud Foundry Command Line Interface](#) and [Add Space Members Using the Cloud Foundry Command Line Interface](#).

Add platform users at different levels (global account, directory, subaccount) from the custom identity provider.

For more information, see [Working with Users](#).

Note

For subaccounts in the Neo environment, the identity provider is offered in the value help only if a user in that identity provider has created at least one Neo subaccount in the corresponding global account and Neo region.

Tip

If the identity provider isn't available in the value help for Neo subaccount members, log on to the global account with a user from that identity provider and create a new Neo subaccount. If it's not needed otherwise, you can delete it.

Recommendation

We recommend that you keep at least one global account administrator from the default identity provider. You can then use this administrator to log on in the rare instance that access to the custom identity provider fails. Log on to the SAP BTP cockpit as a user from the custom identity provider. In the Trust Configuration page, the Open link in the SAP BTP Cockpit column contains the URL (for example, <https://emea.cockpit.btp.cloud.sap/cockpit/?idp=cidppuxhm.accounts.ondemand.com>) for the user to log on with the custom identity provider. Copy the link and send it to your platform user colleagues. Remember if you have the cockpit open and if you want to work in parallel, your current session may be shared by your browser. Open the link in a private or incognito browsing mode.

For more information, see Log On with a Custom Identity Provider to the SAP BTP Cockpit.

If you want to impose, for example, two-factor authentication for platform users, you must configure two-factor authentication in all the SAP Cloud Identity Services applications involved. Multifactor authentication is used as an example.

For more information, see Multi-Factor Authentication in the documentation for the SAP Cloud Identity Services service. Keep all settings for SAP Cloud Identity Services applications the same.

Tip

Instead of configuring two-factor authentication in all the SAP Cloud Identity Services applications, you could also configure it once in your corporate identity provider.

Note

For all the Neo datacenters where you have subaccounts, you might have to configure a separate SAML application (for example, SAP Cloud Platform hhw9g3jrx) in SAP Cloud Identity Services.

Integrate your SAP Cloud Identity Services tenant with your identity authentication management solution.

For more information, see Corporate Identity Provider in the documentation for SAP Cloud Identity Services.

Work in the SAP BTP command-line interface (btp CLI).

To log on to a global account, you need to provide the hostname of the tenant (for example, ar9ibaxhm) with the `--idp` parameter. See Log in with a Custom Identity Provider.

To work with users and role collections on global account, directory, or subaccount level, you need to provide the origin key with the `--of-idp` parameter in the following commands: `btp list security/user`, `btp get security/user`, `btp delete security/user`, `btp assign security/role-collection`, `btp unassign security/role-collection`.

Both values can be found in the cockpit under Security ! Trust Configuration ! Custom Platform Identity Providers.

As an administrator, you want to determine which of the SAP Cloud Identity Services tenants' domains SAP BTP should use for platform user login. For this reason, you specify a custom domain for an SAP Cloud Identity Services tenant. You can use the `btp update security/trust` command and specify the domain in the `--domain` parameter.

Work in the Cloud Foundry command-line interface (CF CLI).

For more information, see Log On with a Custom Identity Provider to the Cloud Foundry Environment Using the Cloud Foundry Command-Line Interface.

The Kyma environment has a separate configuration for the identity provider. We recommend that you also configure your Kyma environment to use SAP Cloud Identity Services as your custom identity provider.

For more information, see Configure a Custom Identity Provider for Kyma.

Related Information

User and Member Management

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/establish-trust-and-federation-with-uaa-using-any-saml-identity-provider>

Title: Establish Trust and Federation with UAA Using Any SAML Identity Provider | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Business UsersEstablish Trust and Federation with UAA Using Any SAML Identity P...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Establish Trust and Federation with UAA Using Any SAML Identity Provider

Integrate trust between the SAP BTP subaccount and any SAML 2.0 identity provider.

Context

Tip

Avoid multiple trust configurations in the same subaccount. We recommend that you use SAP Cloud Identity Services as identity provider and connect a potential corporate identity provider there. We strongly recommend OpenID Connect (OIDC). If you use SAML 2.0, connect an SAP Cloud Identity Services tenant and then add your corporate identity provider. If you don't have a tenant yet, check [Getting a Tenant](#).

For more information, see the announcement of December 31, 2024 in the release notes.

To establish trust, configure the trust configuration of the SAML 2.0 identity provider in your subaccount using the SAP BTP cockpit. Next, register your subaccount in User Account and Authentication service using the administration console of your SAML 2.0 identity provider. To complete federation, maintain the federation attributes of the SAML 2.0 user groups. This makes sure that you can assign authorizations to user groups.

Establish Trust with Any SAML 2.0 Identity Provider in a Subaccount

You want to use an SAML 2.0 identity provider. This is where the business users for SAP BTP are stored.

Prerequisites

You have subaccount administrator permissions.

You have downloaded the SAML 2.0 metadata file from your SAML 2.0 identity provider using the relevant URL.

For more information, see the documentation of your identity provider.

Context

You want to establish a trust relationship with an SAML 2.0 identity provider in your subaccount in SAP BTP.

The following procedure guides you through the trust configuration.

Procedure

Go to your subaccount (see [Navigate in the Cockpit](#)) and choose **Security Trust Configuration** in the SAP BTP cockpit.

Choose **Add SAML Trust**.

Enter a name and a description that make it clear that the trust configuration refers to your identity provider.

Note

Make sure that the users who are supposed to log on to this identity provider understand the name of the trust configuration.

To get the relevant metadata, get to the metadata of your identity provider.

Copy the SAML 2.0 metadata and paste it into the **Metadata** field.

To validate the metadata, choose **Parse**. Take care that the **Subject** and **Issuer** fields are filled with the relevant data from your SAML 2.0 identity provider.

The name of the new trust configuration now shows the value of your identity provider. It represents your custom identity provider.

Check whether the fields for the single sign-on URLs and the single logout URLs are filled.

Choose **Add SAML Trust**.

To get the SAML metadata of your subaccount, choose the **Download SAML Metadata** button.

You download an XML file with the SAML metadata of your subaccount. Its name is `saml-<subdomain>-sp.xml`.

Use this file to import the SAML metadata into your identity provider.

Register SAP BTP Subaccount in Any SAML 2.0 Identity Provider

An SAML service provider interacts with an SAML 2.0 identity provider to authenticate users signing in by means of a single sign-on (SSO) mechanism. In this scenario, the User Account and Authentication (UAA) service acts as a service provider representing a single subaccount. To establish trust between an identity provider and a subaccount, you must register your subaccount by providing the SAML details for web-based authentication in the identity provider itself.

Context

Administrators must configure trust on both sides, in the service provider and in the SAML identity provider.

This description tries to guide you through the configuration of your identity provider. The trust configuration on the side of the SAML 2.0 identity provider must contain the following items:

Metadata for web-based authentication or the relevant configuration information

If available, the metadata contains the configuration information, including the signing certificate and the required URLs. You can create the metadata file of your subaccount using the **SAML Metadata** button in **Security Trust Configuration** of your subaccount.

Use e-mail as the unique name ID attribute, and map the user attribute Groups to the assertion attribute Groups (capitalized). This attribute is required for the assignment of roles.

This makes sure that there is a trust relationship between your SAM 2.0 identity provider and the subaccount. Your administrators use the administration console of your SAML 2.0 identity provider to register the subaccount.

To establish trust from a tenant of your identity provider to a subaccount, assign a metadata file and define attribute details. The SAML 2.0 assertion includes these attributes. With the UAA as SAML 2.0 service provider, they are used for automatic assignment of UAA authorizations based on information maintained in the identity provider.

Procedure

Open the administration console of your SAML 2.0 identity provider.

Go to the configuration of your SAML 2.0 identity provider.

Add a new SAML service provider as described in the documentation of your identity provider.

(If applicable) Choose a name for your identity provider that clearly identifies it as your new service provider.

Save your changes.

Users see this name in the login screen when the authentication is requested by the UAA service. Seeing the name, they know which application they currently access after authentication.

Choose the SAML 2.0 configuration and import the relevant metadata XML file. Save your changes.

Note

Use the saml-<subdomain>-sp.xml metadata file of your subaccount. You can create the file using Download SAML Metadata in Security Trust Configuration of your subaccount.

Take care that the fields of the SAML configuration are filled. The metadata provides information, such as the name, the URLs of the assertion consumer service and single logout endpoints, and the signing certificate.

Choose or create the name ID attribute and select E-mail as a unique attribute. Save your changes.

Choose or create a user attribute, and enter Groups (capitalized) as attribute name for the Groups user attribute. Save your changes.

Related Information

Settings for Default SAML Federation Attributes of Identity Providers for Business Users

Settings for Default SAML Federation Attributes of Identity Providers for Business Users^a

This table shows the attribute settings of the identity provider and the values administrators use to establish trust between the SAML 2.0 identity provider and a subaccount.

Since there are multiple identity providers you can use, we display the parameters and values of SAP Cloud Identity Services. Use the information in this table as a reference for the configuration of your identity provider.

Settings of SAP Cloud Identity Services for SAML 2.0 Trust

Section in the User Interface

Description

Recommended Value

SAML 2.0 Configuration

Configures the trust with a service provider using an uploaded metadata file.

Upload the metadata file from the SAP Authorization and Trust Management service.

Default Name ID Format

Configures the attribute that the identity provider uses to identify the users. The attribute is sent as the name ID for the authenticated user in SAML assertions.

Possible settings:

User ID

E-Mail

Display Name

Login Name

Employee Number

E-Mail

Note

We recommend that you use exactly this name ID format.

Attributes

To assign authorizations indirectly, provide the user groups in the assertion attribute Groups (capitalized).

You can change the default names of the assertion attributes that the application uses to recognize the user attributes. You can use multiple assertion attributes for the same user attribute.

Some possible settings:

Groups

first_name

last_name

email

You can choose from a number of user attributes and add them.

Select the Groups user attribute and enter Groups as assertion attribute. You must set this attribute to enable that the assignment of role collection to user groups. For more information, see the related link.

Caution

Use exactly this spelling:

Groups

Example

In the following, you see what John Doe's SAML 2.0 assertion looks like if Default Name ID Format was set to E-Mail and Assertion Attribute to Groups.

Sample Code

âE

ã

```
<Assertion xmlns="urn:oasis:names:tc:SAML:2.0:assertion" xmlns:ns2="http://www.w3.org/2000/09/xmldsig#"
xmlns:ns3="http://www.w3.org/2001/04/xmenc#" ID="A-de4246c0-397e-4df0-baf0-cde399d55422"
IssueInstant="2017-10-23T08:52:39.494Z" Version="2.0">
<Issuer>company-security.accounts.ondemand.com</Issuer>
<ds:Signature xmlns:ds="http://www.w3.org/2000/09/xmldsig#">
...
</ds:Signature>
<Subject>
<NameID Format="urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress">john.doe@example.com</
NameID>
<SubjectConfirmation Method="urn:oasis:names:tc:SAML:2.0:cm:bearer">
<SubjectConfirmationData InResponseTo="a3h3d679ae07c8cj2ih97d22i7d79a0"
NotOnOrAfter="2017-10-23T09:02:39.494Z" Recipient="https://authentication.example.hana.ondemand.com/
saml/SSO/alias/company-prod-example"/>
</SubjectConfirmation>
</Subject>
<Conditions NotBefore="2017-10-23T08:47:39.494Z" NotOnOrAfter="2017-10-23T09:02:39.494Z">
<AudienceRestriction>
<Audience>aws-live-eu10</Audience>
</AudienceRestriction>
</Conditions>
<AuthnStatement AuthnInstant="2017-10-23T08:52:39.494Z" SessionIndex="S-SP-83d68a13-25fe-44b8-
a139-649ca3e99363" SessionNotOnOrAfter="2017-10-23T20:52:39.494Z">
..
</AuthnStatement>
<AttributeStatement>
<Attribute Name="Groups">
<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/
/XMLSchema-instance" xsi:type="xs:string">iot-acme-monitoring</AttributeValue>
<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/
/XMLSchema-instance" xsi:type="xs:string">new-group-01</AttributeValue>
<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/
/XMLSchema-instance" xsi:type="xs:string">new-group-02</AttributeValue>
</Attribute>
<Attribute Name="email">
```

```
<AttributeValue xmlns:xs="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/
XMLSchema-instance" xsi:type="xs:string">john.doe@example.com</AttributeValue>
</Attribute>
</AttributeStatement>
</Assertion>
```

àf

Related Information

Map Role Collections to User Groups

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/hide-logon-link-for-default-identity-provider>

Title: Hide Logon Link for Default Identity Provider | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Using Multiple Identity Providers from the Same SubaccountHide Logon Link for Default Identity Provider

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Hide Logon Link for Default Identity Provider

You use one or multiple custom identity providers for business users as well as the default identity provider primarily for platform users. To provide a good logon experience for your business users, you want to hide the default identity provider, which remains active.

Prerequisitesà^

You have configured a custom trust configuration for a custom identity provider, for example SAP Cloud Identity Services, and set it to active.

You've checked the Available for User Logon checkbox in your custom trust configuration.

The default trust configuration (SAP ID service) is active.

Contextà^

To hide the default identity provider at logon time, proceed as follows:

Procedureà^

Go to your subaccount (see Navigate in the Cockpit) and choose Security Trust Configuration in the SAP BTP cockpit.

You see the list of trust configurations: the default trust configuration and the custom trust configuration(s).

Choose à8 (Edit) for the default trust configuration. It has the status Default.

To hide the default trust configuration (SAP ID service) for logon, uncheck the Available for User Logon checkbox.

Save your changes.

The default trust configuration is now hidden but remains active.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/html5-apps-routes>

Title: routes | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Routing Configuration Fileroutes

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

routes

Defines all route objects, for example: source, target, and, destination.

Routes Properties

Route Configuration Examples

For more information about Basic authentication options, see SAP Note 3015211.

Application Router: Routes Properties

Property

Type

Mandatory

Description

source

RegEx

Yes

Describes a regular expression that matches the incoming request URL.

A request matches a particular route when its path contains the given pattern. To ensure the RegEx matches the complete path, use the following form: `^$``.

Note

Be aware that RegEx is applied to the full URL, including query parameters.

httpMethods

Array of uppercase HTTP methods

No

HTTP methods that are served by this route; the supported methods are: DELETE, GET, HEAD, OPTIONS, POST, PUT, TRACE, and PATCH.

Tip

If this option isn't specified, the route serves any HTTP method.

target

String

No

Defines how the incoming request path is rewritten for the corresponding destination or static resource.

destination

String

No

The name of the destination to which the incoming request is forwarded. The destination name can be a static string or a regular expression that defines how to dynamically fetch the destination name from the source property or from the host.

For more information about additional destination properties, see Application Routes and Destinations.

service

String

No

The name of the service to which the incoming request is forwarded.

endpoint

String

No

The name of the endpoint within the service to which the incoming request is forwarded. It must only be used in a route containing a service attribute.

localDir

String

No

The directory from which application router serves static content (for example, from the application's web/module).

preferLocal

Boolean

No

Defines from which subaccount the destination is retrieved. If preferLocal is true, the destination is retrieved from the provider subaccount. If preferLocal is false or undefined, the destination is retrieved from the subscriber subaccount.

replace

Object

No

An object that contains the configuration for replacing placeholders with values from the environment.

Note

It is only relevant for static content.

authenticationType

String

No

Specifies the authentication method for the route. You can use these values:

ias: Uses the Identity Authentication service (IAS). Users are redirected to an IAS login.

xsuaa: Uses the SAP Authorization and Trust Management service (XSUAA). Users are redirected to an XSUAA login.

basic: Uses HTTP Basic authentication. This option supports SAP HANA users, the SAP ID service, and the Identity Authentication service (IAS).

none: No authentication is required for the route.

If you do not define the authenticationType, the application router selects the authentication method based on its service bindings:

If bound only to the Identity Authentication service (IAS), it uses ias.

If bound only to the SAP Authorization and Trust Management service (XSUAA), it uses xsuaa.

If the application router is bound to both IAS and XSUAA, it automatically determines which authentication service to use by calling the SAP BTP security endpoint. In this case, IAS is preferred if both services are available in the current subaccount.

Note

This automatic detection requires an additional call to the SAP BTP security endpoint, which may impact response time.

For more information about Basic authentication options, see SAP Note 3015211.

csrfProtection

Boolean

No

Toggle whether this route needs CSRF token protection. The default value is "true". The application router enforces CSRF protection for any HTTP request that changes state on the server side, for example: PUT, POST, or DELETE.

scope

Array/String/Object

No

The authorization scope required to access the target path. The scope itself is defined in the application's security descriptor (xs-security.json), for example, "\$XSAPPNAME.Display" or "\$XSAPPNAME.Create".

cacheControl

String

No

A string representing the value of the Cache-Control header, which is set on the response when serving static resources. By default the Cache-Control header isn't set.

The cacheControl property is only effective when one of the following settings is performed:

localDir property is set

Service pointing to HTML5 Application Repository ("service": "html5-apps-repo-rt") is set

identityProvider

String

No

The name of the identity provider you use if it's provided in the definition of the route. If it isn't provided, the route is authenticated with the default identity provider.

Note

If authenticationType is set to Basic Authentication or None, don't define the identityProvider property.

dynamicIdentityProvider

Boolean

No

Enables dynamic identity provider provisioning.

If dynamicIdentityProvider is true, the end user can set the identity provider (IDP) for the application's login process by filling the request query parameter sap_idp with the IDP origin key. If the IdentityProvider property is defined in the route, its value is overwritten by the sap_idp query parameter value. The default value for dynamicIdentityProvider is false.

Note

Route order is important. The first matching route will be used. Therefore, it is recommended to sort the routes

from the most specific source to the more generic one. For example:

Sample Code

```
âE
ã
"routes": [
{
"source": "^/sap/backend/employees(.*)$",
"target": "$1",
"destination": "sfsf"
},
{
"source": "^/sap/backend/(.*)$",
"target": "$1",
"destination": "erp",
}
]
```

Code Syntax

```
âE
ã
"routes": [
{
"source": "^/sap/ui5/1(.*)$",
"target": "$1",
"destination": "ui5",
"scope": "$XSAPPNAME.viewer",
"authenticationType": "xsuaa",
"csrfProtection": true
}
]
```

Note

The properties service, destination, and localDir are optional. However, at least one of them must be defined.

httpMethodsâ

The httpMethods option allows you to split the same path across different targets depending on the HTTP method. For example:

Sample Code

```
âE
ã
"routes": [
{
"source": "^/app1/(.*)$",
"F &vWB# "/before/$1/after",
'&‡GG ÖWF†öG2# ["GET", "POST"]
}
]
```

This route only serves GET and POST requests. Any other method (including extension ones) gets a 405 Method Not Allowed response. The same endpoint can be split across multiple destinations depending on the HTTP method of the requests:

Sample Code

```
âE
ã
"routes": [
{
"source": "^/app1/(.*)$",
"destination" : "dest-1",
```

```

"httpMethods": ["GET"]
},
{
"source": "^/app1/(.*)$",
"destination" : "dest-2",
"httpMethods": ["DELETE", "POST", "PUT"]
}
]

```

This sample code routes GET requests to the target dest-1, DELETE, POST and PUT to dest-2, and any other method receives a 405 Method Not Allowed response. It's also possible to specify catchAll routes, namely routes that don't specify httpMethods restrictions:

Sample Code

```

{
  "routes": [
    {
      "source": "^/app1/(.*)$",
      "destination" : "dest-1",
      "httpMethods": ["GET"]
    },
    {
      "source": "^/app1/(.*)$",
      "destination" : "dest-2"
    }
  ]
}

```

In this sample code, GET requests are routed to dest-1, and all of the rest are routed to dest-2.

localDir

If there's no route defined for serving static content via localDir, a default route is created for "resources" directory as follows:

Sample Code

```

{
  "routes": [
    {
      "source": "^/(.*)$",
      "localDir": "resources"
    }
  ]
}

```

Note

If there is at least one route using localDir, the default route isn't added.

replace

The replace object configures the placeholder replacement in static text resources.

Sample Code

```

{
  "replace": {
    "pathSuffixes": ["index.html"],
    "vars": ["escaped_text", "NOT_ESCAPED"]
  }
}

```

The replace keyword requires the following properties:

Replacement Properties for Static Resource URLs

Property

Type

Description

pathSuffixes

Array

An array defining the path suffixes that are relative to localDir. Only files with a path ending with any of these suffixes are processed.

vars

Array

A whitelist with the environment variables that are replaced in the files matching the suffix specified in pathSuffixes.

The supported tags for replacing environment variables are: `{{ENV_VAR}}` and `{{{ENV_VAR}}}`. If such an environment variable is defined, it's replaced; otherwise, it's just an empty string.

Note

Any variable that is replaced using two-brackets syntax `{{ENV_VAR}}` is HTML-escaped; the triple brackets syntax `{{{ENV_VAR}}}` is used when the replaced values don't need to be escaped and all values remain unchanged. For example, if the value of the environment variable is `ab"cd` the result is `ab"cd`.

If your application descriptor `xs-app.json` contains a route like the one illustrated in the following example,

âE

ã

```
{
  "source": "^/get/home(.*)",
  "target": "$1",
  "localDir": "resources",
  "replace": {
    "pathSuffixes": ["index.html"],
    "vars": ["escaped_text", "NOT_ESCAPED"]
  }
}
```

And your application uses the following `index.html` start file:

Sample Code

âE

ã

```
<html>
<head>
<title>{{escaped_text}}</title>
<script src="{{{NOT_ESCAPED}}}/index.js"/>
</head>
</html>
```

Then, in the `index.html`, `{{escaped_text}}` and `{{{NOT_ESCAPED}}}` are replaced with the value defined in the environment variables `<escaped_text>` and `<NOT_ESCAPED>`.

Note

All `index.html` files are processed; if you want to apply the replacement only to specific files, you must set the path relative to `localDir`. In addition, all files must comply with the UTF-8 encoding rules.

The content type returned by a request is based on the file extension specified in the route. The application router supports the following file types:

.json (application/json)

.txt (text/plain)

.html (text/html) default

.js (application/javascript)

.css (text/css)

The following table illustrates some examples of the `pathSuffixes` properties:

Examples of the `pathSuffixes` Property

Example

Result

```
{ "pathSuffixes": [".html"] }
```

All files with the extension .html under localDir and its subfolders are processed .

```
{ "pathSuffixes": ["/abc/main.html", "some.html"] }
```

For the suffix /abc/main.html, all files named main.html that are inside a folder named abc are processed.

For the suffix some.html, all files with a name that ends with "some.html" are processed. For example:

some.html, awesome.html.

```
{ "pathSuffixes": [".html"] }
```

All files with the name "some.html" are processed. For example: some.html , /abc/some.html.

Route Configuration Examples

Route with a destination and no target

Sample Code

```
â€
```

```
ã
```

```
{
```

```
"source": "^/app1/(.*)$",
```

```
"destination": "app-1"
```

```
}
```

Since there is no target property for that route, no path rewriting will take place. If /app1/a/b is received as a path, then a request to http://localhost:3001/app1/a/b is sent. The source path is appended to the destination URL.

Route with case-insensitive matching

Sample Code

```
â€
```

```
ã
```

```
{
```

```
"source": {
```

```
"path": "^/app1/(.*)$",
```

```
"matchCase": false
```

```
},
```

```
"destination": "app-1"
```

```
}
```

Note

The property matchCase must be boolean. It is optional and has a default value of true.

Route with a destination and a target

Sample Code

```
â€
```

```
ã
```

```
{
```

```
"source": "^/app1/(.*)$",
```

```
"target": "/before/$1/after",
```

```
"destination": "app-1"
```

```
}
```

Route with a service, a target and an endpoint

Sample Code

```
â€
```

```
ã
```

```
{
```

```
"source": "^/odata/v2/(.*)$",
```

```
"target": "$1",
```

```
"service": "com.sap.appbasic.country",
```

```
"endpoint": "countryservice"
```

```
}
```

When a request with path /app1/a/b is received, the path rewriting is done according to the rules in the target property. The request will be forwarded to http://localhost:3001/before/a/b/after.

Note

In regular expressions there is the term capturing group. If a part of a regular expression is surrounded with parenthesis, then what has been matched can be accessed using \$ + the number of the group (starting from 1). In code sample, \$1 is mapped to the (.*?) part of the regular expression in the source property.

Route with dynamic destination and target

Sample Code

```
â€”  
ã€”  
{  
  "source": "^/destination/([^/]+)/(.*)$",  
  "target": "$2",  
  "destination": "$1",  
  "authenticationType": "xsuaa"  
}
```

If you have another destination configured, use this:

Sample Code

```
â€”  
ã€”  
[  
  __  
  'æœœ ÖR' "myDestination",  
  "W l" : "http://localhost:3002"  
  —  
]
```

When a request with the path /destination/myDestination/myTarget is received, the destination will be replaced with the URL from "myDestination", the target will get "myTarget" and the request will be redirected to http://localhost:3002/myTarget.

Note

You can use a dynamic value (regex) or a static string for destination and target values.

The Application Router first looks for the destination name in the manifest.yaml file, and if it is not found, it looks for it in the destination service.

Destination in Host

For legacy applications that do not support relative URL paths, you need to define your URL in the following way to enable the destination to be extracted from the host:

https://<tenant>-<destination>.<customdomain>/<pathofile>

To enable the application router to determine the destination of the URL host, a

DESTINATION_HOST_PATTERN attribute must be provided as an environment variable. For example, When a request with the path https://myDestination.some-approuter.someDomain.com/app1/myTarget is received, the following route is used:

Sample Code

```
â€”  
ã€”  
{  
  "source": "^/app1/([^/]+)/",  
  "target": "$1",  
  "destination": "**",  
  "authenticationType": "xsuaa"  
}
```

In this example, the target will be extracted from the source and the '\$1' value is replaced with "myTarget". The destination value is extracted from the host and the "*" value is replaced with "myDestination".

Route with a localDir and no target

Sample Code

âE

ã

```
{
"source": "^/web-pages/(.*)$",
"target": "$1",
"localDir": "my-static-resources"
}
```

If we receive a request with a path /web-pages/welcome-page.html, the local file at my-static-resources/welcome-page.html under the working directory will be served.

Note

The capturing group used in the target property.

Route with localDir and cacheControl

Sample Code

âE

ã

```
{
"source": "^/web-pages/",
"localDir": "my-static-resources",
"cacheControl": "public, max-age=1000,must-revalidate"
}
```

Route with service "html5-apps-repo-rt" and cacheControl

Sample Code

âE

ã

```
{
"source": "^/index.html$",
"service": "html5-apps-repo-rt",
"authenticationType": "xsuaa",
"cacheControl": "public,max-age=1000,must-revalidate"
}
```

Route with httpMethods restrictions

This option allows you to split the same path across different targets depending on the HTTP method. For example:

Sample Code

âE

ã

```
{
"source": "^/app1/(.*)$",
"target": "/before/$1/after",
"httpMethods": ["GET", "POST"]
}
```

This route only supports GET and POST requests. Any other method (including extensions) will receive a 405 Method Not Allowed response. The same endpoint can be split across multiple destinations depending on the HTTP method of the requests:

Sample Code

âE

ã

```
{
"source": "^/app1/(.*)$",
"destination": "dest-1",
"httpMethods": ["GET"]
},
{
"source": "^/app1/(.*)$",
```

```
"destination" : "dest-2",
"httpMethods": ["DELETE", "POST", "PUT"]
}
```

In the setup above, GET requests will be routed to "dest-1", and all the rest to "dest-2".

Note

localDir and httpMethods are not compatible.

Route with a scope

An application specific scope uses the following format:

<application-name>.<scope-name>

It is possible to configure what scope the user needs to possess in order to access a specific resource. Those configurations are per route. The user should have at least one of the scopes in order to access the corresponding resource.

Sample Code

```
âE
ã
{
"source": "^/web-pages/(.*)$",
"target": "$1",
"scope": ["$XSAPPNAME.viewer", "$XSAPPNAME.reader", "$XSAPPNAME.writer"]
}
àf
```

For convenience if your route only requires one scope, the scope property can be a string instead of an array.

The following configuration is also valid:

Sample Code

```
âE
ã
{
"source": "^/web-pages/(.*)$",
"target": "$1",
"scope": "$XSAPPNAME.viewer"
}

```

You can configure scopes for different HTTP methods, such as GET, POST, PUT, HEAD, DELETE, CONNECT, TRACE, PATCH, and OPTIONS. If some of the HTTP methods are not explicitly set, the behaviour for them is defined by the default property. In case there is no default property specified and the HTTP method is also not specified, the request is rejected by default.

Sample Code

```
âE
ã
{
"source": "^/web-pages/(.*)$",
"target": "$1",
"scope": {
"GET": "$XSAPPNAME.viewer",
"POST": ["$XSAPPNAME.reader", "$XSAPPNAME.writer"],
"default": "$XSAPPNAME.guest"
}
}

```

The application router supports the \$XSAPPNAME placeholder. Its value is taken (and then substituted in the routes) from the UAA configuration.

Note

The substitution is case sensitive.

You can use the name of the business application directly instead of using the \$XSAPPNAME placeholder:

Sample Code

```
âE
```

```

{
  "source": "^/backend/(.*)$",
  "scope": "my-business-application.viewer"
}

```

Routes with an identityProvider

You can define several identity providers for different types of users. In this code example, there are two categories: hospital patients and hospital personnel:

patientsIDP – use for authenticating patients.

hospitalIDP – use for authenticating all hospital personnel (doctors, nurses etc..).

Sample Code

```

{
  [
    {
      "source": "^/patients/sap/opu/odata/(.*)",
      "F &vWB# "/sap/opu/odata$1",
      '&FW7F-æ F-öâ# "backend",
      '& WF†VçF-6 F-öå@type": "xsuaa",
      '&-FVçF—G• &övider": "patientsIDP"
    },
    {
      "source": "^/hospital/sap/opu/odata/(.*)",
      "F &vWB# "/sap/opu/odata$1",
      '&FW7F-æ F-öâ# "backend", "authenticationType": "xsuaa",
      '&-FVçF—G• &övider": "hospitalIDP"
    }
  ]
}

```

A patient who tries to log into the system will be authenticated by patientIDP, and a doctor who tries to log in will be authenticated by hospitalIDP.

Note

If a user logs in as one identity and then wants to perform tasks for another identity type, the user must log out and log back in to the system.

Dynamic provisioning of the subscriber account identity provider is not supported.

Identity provider configuration is only supported in the client side logon redirect flow.

Route with a dynamicIdentityProvider

This is an example of a route where the value of identityProvider is patientsIDP and where dynamic identity provider provisioning is enabled by setting dynamicIdentityProvider to true:

Sample Code

```

{
  [
    {
      "source": "^/patients/index.html",
      "target": "/patients-index.html",
      "service": "html5-apps-repo-rt",
      "identityProvider": "patientsIDP",
      "dynamicIdentityProvider": true
    }
  ]
}

```

In this example, the patientsIDP value for the identityProvider is replaced by hospitalIDP if a request with sap_idp=hospitalIDP is executed, for example, if the request is https://shiva.health-center-approuter.cfapps.hana.ondemand.com/healthreport/patients/index.html?sap_idp=hospitalIDP.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/limits-for-technical-artifacts-of-sap-authorization-and-trust-management-service>

Title: Limits for Technical Artifacts of the SAP Authorization and Trust Management Service | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySAP Authorization and Trust Management ServiceLimits for Technical Artifacts of the SAP Authorization and Trust...
SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Limits for Technical Artifacts of the SAP Authorization and Trust Management Service

To improve the resiliency of the SAP Authorization and Trust Management service, we have introduced limitations on technical artifacts of the service.

Limits for the Service Brokerà^

We allow a maximum of service instances per subaccount.

There is also a maximum of service bindings and service keys in total per service instance. The service rejects attempts to add more bindings or service keys. For more information, see Service Instance Secrets.

Limits for the Service Broker

Service Broker Resource

Upper Limit

Service instances per subaccount

2500

Service bindings and service keys in total per service instances

1000

Limits for the Application Security Descriptorà^

There are limits that apply when you define properties in the application security descriptor.

You define properties in the xs-security.json application security descriptor file for creating or updating service instances. Take care that you don't define more properties than specified in the table.

Limits for Properties

Property

Upper Limit

attributes

50

role-collections

250

role-templates

500

scopes

500

scopes (granted)

Note

Granted means that the scope object refers to applications that are specified using granted-apps or grant-as-authority-to-apps properties

250

Limits for the Global Accountà^

It is possible to configure up to 3 custom identity providers for platform users in a global account.

Limits for the Subaccountà^

There are limits that apply to the subaccount. Administrators can use application roles and create their own roles. They can create and manage role collections, add roles to them, and assign the role collections to business users.

For more information, see Building Roles and Role Collections for Applications and Working with Role Collections.

Limits for Security Artifacts

Security Artifact

Upper Limit

Roles created by administrators

Note

Roles that are automatically generated when a service instance was created or updated are not counted here.
2500

Role collections created by administrators

5000

When establishing trust, subaccount administrators must observe the limits for identity providers.

Limits for Identity Providers

Identity Provider

Upper Limit

SAML identity providers

50

User attribute mappings defined in a subaccount

5000

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/log-in-with-single-sign-on>

Title: *Log in with Single Sign-On | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Log inLog in with Single Sign-On

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Log in with Single Sign-On

Use the single sign-on parameter (`btp login --sso`) to log in to your identity provider through a browser instead of passing username and password on the command line.

Prerequisitesà^

Login through a browser is only available if you use the default server URL that is proposed by the CLI during login (`https://cli.btp.cloud.sap/`). This is the case unless your operator has provided you specifically with a different server URL.

Contextà^

If you have a custom identity provider configured in your global account, use `btp login --sso --idp <TENANT>`. See [Log in with a Custom Identity Provider](#).

Tip

If you like logging in through single sign-on in a browser, you can configure this as the default behavior of `btp login` to save a few keystrokes at login. Use `btp set config --login.sso browser`. See [Change Configuration Settings](#).

Procedureà^

Enter the following and press ENTER to be prompted for the server URL and the subdomain of your global account:

âE

ã

`btp login --sso`

Alternatively, you can pass the server URL and the subdomain of your global account as parameters:

âE

ã

`btp login --sso --url https://cli.btp.cloud.sap/ --subdomain <my-subdomain>`

âf

To suppress the automatic browser-opening, you can run the command as follows:

âE

ã

`btp login --sso manual`

Authenticate directly at your identity provider through your browser.

If you already have an active session, the identity provider immediately transfers a token to the client, which completes your login. Otherwise, you need to enter your credentials.

Resultsà^

You've successfully logged in. You can return to the command line to work in your global account or - at first

login - to select the global account for login.

Related Information

Log in

Log in with a Custom Identity Provider

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/log-on-as-technical-user-with-custom-identity-provider>

Title: SAP Help Portal | SAP Online Help

ProductsWhat's NewExplore SAP

Loading Document...

âƒ

â„

âĶ

à PDF

à Favorite

â=Share

âÀ

âTable of Contents

Loading Table of Contents...

Loading Topic...

âWas this page helpful?

â"Yes

â#No

Copyright

Disclaimer

Privacy Statement

Legal Disclosure

Trademark

Terms of Use

Cookie Preferences

Accessibility & Sustainability

Ask a Question about the SAP Help Portal

Find us on

Share

â=

Your choices regarding cookies on this site

This site uses cookies and related technologies, as described in our Cookie Statement, for purposes that may include site operation, analytics, enhanced user experience, or advertising. You may choose to consent to our use of these technologies, or manage your own preferences.

Privacy Statement | Cookie Statement

Accept All

Deny All

Manage Settings

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/log-on-manually-with-custom-identity-provider>

Title: Log On Manually With a Custom Identity Provider | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Log On with a Custom Identity Provider to the Cloud Foundry Envir...Log On Manually With a Custom Identity Provider

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Log On Manually With a Custom Identity Provider

To log on to Cloud Foundry, using a custom identity provider, use the single sign-on option of the CF CLI.

Prerequisites

You've configured the login screen to display your custom identity provider.

For more information, see Log on with a Browser to the Cloud Foundry CLI and Service Dashboards.

You know the origin key of the identity provider.

For more information, see Establish Trust and Federation of Custom Identity Providers for Platform Users.

Contextà

During logon, the system provides you with a URL to your custom identity provider for you to enter in a web browser. If you're already logged on to your custom identity provider, the system provides a temporary authentication code to complete your logon. If you don't have an active session with your custom identity provider, you need to log on to receive the temporary authentication code.

Procedureà

Open a command line.

Set the target API endpoint to endpoint of your subaccount.

àE

à

cf api https://api.cf.<region>.hana.ondemand.com

Sample Code

àE

à

cf api https://api.cf.eu10.hana.ondemand.com

Log on to the Cloud Foundry environment with single sign-on:

àE

à

cf login --sso

The command-line interface displays a login URL and prompts you to enter a temporary authentication code.

Open the URL that is provided on the screen to go to the logon screen.

If this is the first time you're logging on or your browser cache has been cleaned of cookies, you're prompted to provide the origin key of your custom identity provider or choose the default identity provider.

Otherwise, the sign-in page lists your accounts on custom identity providers with which you previously logged on.

Choose the account of your identity provider.

If you don't have an active session yet, you're prompted to log on to your identity provider.

After you've successfully logged on, you receive a temporary authentication code.

Enter the passcode.

You've logged on successfully. You can now choose your org.

Related Informationà

Log on with a Browser to the Cloud Foundry CLI and Service Dashboards

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/managing-users-and-their-authorizations-using-btp-cli>

Title: Managing Users and Their Authorizations Using the btp CLI | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Commands in the btp CLIManaging Users and Their Authorizations Using the btp CLI

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Managing Users and Their Authorizations Using the btp CLI

User authorizations are managed by assigning role collections to users (for example, Subaccount Administrator). Use the SAP BTP command-line interface (btp CLI) to manage roles and role collections, and to assign role collections to users.

Tip

All of these commands can be executed in the global account, a directory, or in a subaccount. To choose the level, use the btp target command. See Set a Target for Subsequent Commands with btp target.

Managing Users and Assigning Role Collectionsà

Role collections are user-related authorizations that allow access to resources and services. You give users permissions by assigning role collections to them. All users in the global accounts, directories, and subaccounts are stored in identity providers, either in the default or in a custom identity provider. When the first role collection assignment to a user happens, SAP BTP creates a copy of this user in the global account, directory, or subaccount. This copy of the user is called shadow user.

When you do the first role collection assignment to a user through the btp CLI, such a shadow user is created by default. If you want to prevent this, you need to pass the --create-user-if-missing parameter with value false. See Role Collections and Roles in Global Accounts, Directories, and Subaccounts and User and Member Management.

Task

Run the command ...

Command help

List users

btp list security/user

btp list security/user

Get details about a specific user, including role collections

btp get security/user

btp get security/user

Delete a user

btp delete security/user

btp delete security/user

Assign a role collection to a user, user group, or to an attribute

btp assign security/role-collection

btp assign security/role-collection

Unassign a role collection from a user, user group, or from an attribute

btp unassign security/role-collection

btp unassign security/role-collection

Managing Roles[^]

A role is an instance of a role template; you can build a role based on a role template and assign the role to a role collection. See Add Roles to Role Collections on the Application Level.

Task

Run the command ...

Command help

List apps

btp list security/app

btp list security/app

Get details about a specific application

btp get security/app

To get the ID of a specific app, run btp list security/app

.

btp get security/app

List roles

btp list security/role

btp list security/role

Get details about a specific role

btp get security/role

btp get security/role

Create a role

btp create security/role

btp create security/role

Delete a role

btp delete security/role

btp delete security/role

Add a role to a role collection

btp add security/role

btp add security/role

Remove a role from a role collection

btp remove security/role

btp remove security/role

Managing Role Collectionsà^

Role collections consist of roles, which, in turn, are based on role templates. Role collections are specific to account entities, that is, there are different role collections in global accounts, subaccounts, and directories. There are predefined role collections, such as Global Account Administrator and Subaccount Viewer. For more information, see Role Collections and Roles in Global Accounts, Directories, and Subaccounts and Working with Role Collections.

Task

Run the command ...

Command help

List role collections

`btp list security/role-collection`

`btp list security/role-collection`

Get details about a specific role collection

`btp get security/role-collection`

`btp get security/role-collection`

Create a role collection

`btp create security/role-collection`

`btp create security/role-collection`

Change the description of a role collection

`btp update security/role-collection`

`btp update security/role-collection`

Delete a role collection

`btp delete security/role-collection`

`btp delete security/role-collection`

Parent topic: Commands in the btp CLI

Related Informationà^

Working with Global Accounts, Directories, and Subaccounts Using the btp CLI

Setting Entitlements Using the btp CLI

Working with Environments Using the btp CLI

Working with Multitenant Applications Using the btp CLI

Working with External Resource Providers Using the btp CLI

Managing Trust from SAP BTP to an SAP Cloud Identity Services Tenant

Managing Signing Keys for Access Tokens

Managing Security Settings

Managing API Credentials for Calling REST APIs of SAP Authorization and Trust Management Service

Working with Resources of the SAP Service Manager Using the btp CLI

Working with Multi-Region Disaster Recovery Using the btp CLI

Security Administration: Managing Authentication and Authorization

Set a Target for Subsequent Commands with `btp target`

Role Collections and Roles in Global Accounts, Directories, and Subaccounts

btp CLI Command Reference

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/manually-establish-trust-and-federation-between-uaa-and-identity-authentication>

Title: Manually Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Business UsersManually Establish Trust and Federation Between SAP Authorization...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Manually Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services

Use your SAP Cloud Identity Services tenant as an identity provider or a proxy to your own identity provider hosting your business users. Exchange SAML metadata to establish trust with the SAP Cloud Identity Services

tenant and then register your subaccount with the tenant. To complete federation, maintain the federation attributes of the user groups.

Context

Note

Instead of manually exchanging SAML metadata, we recommend that you use the automatic method based on the OpenID Connect (OIDC) protocol.

For more information, see Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services.

Establish Trust with an SAML 2.0 Identity Provider in a Subaccount

You want to use an SAML 2.0 identity provider, for example, SAP Cloud Identity Services. The identity provider authenticates business users for SAP BTP.

Prerequisites

You have subaccount administrator permissions.

You have downloaded the SAML 2.0 metadata file from the SAP Cloud Identity Services tenant using the URL `https://<sap_cloud_identity_services_tenant>.accounts.ondemand.com/saml2/metadata`.

Example

`https://my-ias-tenant.accounts.ondemand.com/saml2/metadata`

For more information, see Tenant SAML 2.0 Configuration in the SAP Cloud Identity Services.

Context

The following procedure describes how to establish trust with an SAP Cloud Identity Services tenant.

Restriction

You've already created a trust configuration with a custom identity provider for applications. In this case, you can't add a trust configuration with the same SAP Cloud Identity Services tenant using another protocol.

Example

If there's already a trust configuration with OpenID Connect, you can't create one using the SAML protocol.

Restriction

Consider the upper limits for trust configurations in the subaccount. See Limits for the Subaccount.

Restriction

We recommend a single trust configuration per subaccount with SAP Cloud Identity Services using the OpenID Connect (OIDC) protocol. If this isn't sufficient, you may use a trust configuration with SAML 2.0.

Nevertheless, we recommend migrating existing SAML 2.0 trusts according to the documentation Migration from SAML Trust to OpenID Connect Trust with SAP Cloud Identity Services.

Procedure

In the SAP BTP cockpit, go to your subaccount (see Navigate in the Cockpit) and choose Security Trust Configuration.

Choose Add SAML Trust.

Enter a name and a description that make it clear to which identity provider that the trust configuration refers.

Note

Make sure that the users who are supposed to log on to this identity provider understand the name of the trust configuration.

Download the relevant metadata (see prerequisites) and save it in an XML file.

Choose the Upload button to insert the SAML 2.0 metadata.

To validate the metadata, choose Parse. The system fills the Subject and Issuer fields with the relevant data from the SAP Cloud Identity Services - your SAML 2.0 identity provider. You see the fields when you choose Show Details.

The name of the new trust configuration now shows the value

`<sap_cloud_identity_services_tenant>.accounts.ondemand.com`. It represents the custom identity provider SAP Cloud Identity Services.

This action also fills the fields for the single sign-on URLs and the single logout URLs.

Provide a link text for user logon (see Using Multiple Identity Providers from the Same Subaccount).

Choose Add SAML Trust.

To get the SAML metadata of your subaccount, choose Download SAML Metadata.

You download an XML file with the SAML metadata of your subaccount. Its name is `saml-<subdomain>-sp.xml`.

Use this file to import the SAML metadata into your identity provider.

Next Steps

Register your SAP BTP subaccount in the SAML 2.0 Identity Provider

Register SAP BTP Subaccount in the SAML 2.0 Identity Provider[^]

An SAML service provider interacts with an SAML 2.0 identity provider to authenticate users signing in by means of a single sign-on (SSO) mechanism. In this scenario, the SAP Authorization and Trust Management service (XSUAA) acts as a service provider representing a single subaccount. To establish trust between an identity provider and a subaccount, you must register your subaccount by providing the SAML metadata to the identity provider. The identity provider is SAP Cloud Identity Services.

Context

Administrators must configure trust on both sides, in the service provider and in the identity provider. This description covers the side of the identity provider (SAP Cloud Identity Services). The trust configuration on the side of the SAP Cloud Identity Services must contain the following items:

Metadata for web-based authentication or the relevant configuration information

The metadata contains the configuration information, including the signing certificate and the required URLs.

Create the metadata file of your subaccount using the Download SAML Metadata button in Security Trust Configuration of your subaccount.

Use e-mail as the unique name ID attribute, and map the user attribute Groups to the assertion attribute Groups (case-sensitive). This assertion attribute is required for the assignment of roles.

We illustrate the process of configuring trust in the service provider by describing how administrators use the administration console of SAP Cloud Identity Services to register the subaccount.

To establish trust from a tenant of SAP Cloud Identity Services to a subaccount, assign a metadata file and define attribute details. The SAML 2.0 assertion includes these attributes. With the SAP Authorization and Trust Management service as SAML 2.0 service provider, they're used for automatic assignment of SAP Authorization and Trust Management service authorizations based on information maintained in the identity provider.

Procedure

Open the administration console of SAP Cloud Identity Services.

https://<sap_cloud_identity_services_tenant>.accounts.ondemand.com/admin

Choose Applications & Resources Applications in the menu or the Applications tile.

To add a new SAML service provider, choose Create.

Enter the required data and choose + Create.

Enter a name for the application that clearly identifies it as your new service provider.

Users see this name in the logon screen when the authentication is requested by the SAP Authorization and Trust Management service. Seeing the name, they know which application they currently access after authentication.

Choose SAML 2.0 as the protocol type.

Choose Trust SAML 2.0 Configuration.

Under Define from Metadata, upload the relevant metadata XML file and choose Save.

Note

Use the saml-<subdomain>-sp.xml metadata file of your subaccount. You can create the file using the Download SAML Metadata button in Security Trust Configuration of your subaccount.

If the contents of the metadata XML file are valid, the parsing process extracts the information required to populate the remaining fields of the SAML configuration. It provides the name, the URLs of the assertion consumer service and single logout endpoints, and the signing certificate.

Choose Default Name ID Format and select E-Mail as a unique attribute. Save your changes.

Choose Attributes, use Add to add an attribute named Groups with a source Identity Provider and the value Groups (case-sensitive). Save your changes.

Note

Be aware that the X.509 certificates exposed in the SAML 2.0 metadata have specific validities. This applies to both SAML service providers and SAML identity providers. Authentication may fail with an error once the X.509 certificates expire.

Ensure that the SAML 2.0 metadata is updated before the X.509 certificate expiry dates.

Sign the certificate with a new signing key. For more information, see Rotate Signing Keys of SAML Token.

Title: Map Role Collections to User Groups | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Mapping Role CollectionsMap Role Collections to User Groups

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Map Role Collections to User Groups

You want to assign a role collection to a user group provided by an identity provider that has a custom trust configuration in SAP BTP. In this case, the assignment is a mapping of a user group to a role collection. Your identity provider provides the user groups using the attribute called Groups. Each value of the attribute is mapped to a role collection as described in this procedure.

Prerequisitesà

You've configured your custom identity provider and established trust with your subaccount.

Remember

The name of the trust configuration is different from SAP ID service. The name of a custom trust configuration to SAP Cloud Identity Services could be as follows:

https://<tenant_id>.accounts.ondemand.com

You've configured the identity provider so that it conveys the user's group memberships in the groups attribute.

For business users, see Map User Attributes from a Corporate Identity Provider for Business Users.

For platform users, see Map User Attributes from a Corporate Identity Provider for Platform Users.

You've created role collections.

Contextà

The identity provider provides the users, who can belong to user groups. It's efficient to map user groups to role collections. The role collection as a reusable element contains the authorizations that are necessary for this user group. Mappings save time when you want to add a new user. Simply add the user to the respective user group or groups, and the user automatically gets all the authorizations that are included in the role collections.

Procedureà

To map a user group to a role collection, see Assign User Groups to Role Collections.

You can also map role collections to attributes other than groups. For more information, see the related links.

Related Informationà

Trust and Federation with Identity Providers

Map Role Collections to User Attributes

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/mapping-role-collections-in-subaccount>

Title: Mapping Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Working with Role CollectionsMapping Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Mapping Role Collections

You've arranged roles in role collections, and now want to assign or map these role collections to business users.

How you assign users to their authorizations depends on the type of trust configuration and on whether or not you prefer to maintain the authorizations of individual users rather in the identity provider or in SAP BTP. The following options are available:

Directly assign role collections to users.

Map role collections to user groups or other user attributes defined in the identity provider. You initially maintain the mapping between user groups or other user attributes and role collections once in SAP BTP, and maintain group memberships or other attributes of users in the identity provider.

Note

If you're using the default trust configuration with the default identity provider, you directly assign users to role collections. For more information, see Default Identity Provider.

However, if you're using a custom trust configuration, for example, with SAP Cloud Identity Services, you can use more options. For more information about configuring the trust between your subaccount and a custom

identity provider, see Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services. For more information about configuring the trust between your global account and a custom identity provider, see Establish Trust and Federation of Custom Identity Providers for Platform Users.

If you use the same SAP Cloud Identity Services tenant for both platform and business users, the service saves the mapping once per tenant. The mapping applies to both platform users and business users.

Options for Assignment of Role Collections

Trust Configuration

Assignment Options

Default trust configuration (SAP ID service)

Assign Users to Role Collections

Custom trust configuration (for example: a tenant of SAP Cloud Identity Services)

Assigning Role Collections to Users or User Groups

Map Role Collections to User Groups

Map Role Collections to User Attributes

Related Information[^]

Working with Role Collections

Trust and Federation with Identity Providers

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/monitoring-and-troubleshooting>

Title: *Monitoring and Troubleshooting | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySAP

Authorization and Trust Management ServiceMonitoring and Troubleshooting

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Monitoring and Troubleshooting

This section provides information on troubleshooting-related activities for the SAP Authorization and Trust Management service in the Cloud Foundry environment.

Tip

We also recommend that you regularly check the SAP Notes and Knowledge Base for component BC-CP-CF-SEC-IAM in the SAP Support Portal. These contain information about program corrections and provide additional information.

To help you troubleshoot your issue, we also recommend increasing the log verbosity of your application and application router. We provide a script to help you. If for some reason you can't use this script, increase the log verbosity manually, see related link.

To troubleshoot problems with tokens from SAP Cloud Identity Services, see Logging OpenID Connect Tokens in the documentation for SAP Cloud Identity Services.

Our troubleshooting information can be found in Troubleshooting for SAP Authorization and Trust Management Service. Check the individual troubleshooting topics for your error message. If you can't find your problem, create an incident in the component BC-CP-CF-SEC-IAM. For more information, see Monitoring and Troubleshooting.

Related Information[^]

Getting Support

Enable and Provide Application Logs

Auditing and Logging Information for SAP Authorization and Trust Management Service

Authorization and Access Control Cookbook

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/principal-propagation-from-cloud-foundry-to-neo-environment>

Title: *Principal Propagation from the Multi-Cloud Foundation to the Neo Environment | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecurityPrincipal

PropagationPrincipal Propagation from the Multi-Cloud Foundation to the Neo ...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Principal Propagation from the Multi-Cloud Foundation to the Neo Environment

Enable an application in your multi-environment subaccount (for the multi-cloud foundation) to access an OAuth-protected application in a subaccount in the Neo environment without user login (and user interaction) in the second application. For this scenario to work, the two subaccounts need to be in mutual trust, and in trust with the same identity provider. The first application will propagate its logged-in user to the second application using an OAuth2SAMLBearer destination.

The graphic below illustrates the overall setup of the scenario.

Prerequisites

You have a user account with Administrator role in both SAP BTP subaccounts. See [Managing Member Authorizations in the Neo Environment](#).

You have a custom local service provider configuration (this means in cloud cockpit [Security Trust Local Service Provider](#)

you have chosen Configuration Type Custom) in your subaccount in the Neo environment. See [Configure the Local Service Provider](#).

Both accounts have a trust configuration to the same identity provider. See:

[Configure Trust to the SAML Identity Provider \(for the Neo environment\)](#)

[Establish Trust with Any SAML 2.0 Identity Provider in a Subaccount \(for the multi-cloud foundation\)](#)

The application in the Neo environment is protected using OAuth 2.0. See [OAuth 2.0 Service](#).

The application in the multi-environment subaccount is bound to an instance of the following services: [Destination Service](#). See [Create and Bind a Destination Service Instance](#).

xsuaa

You have deployed both applications, each in the corresponding subaccount.

Note

All configuration steps described in this tutorial are done using the cloud cockpit.

Contents

[Create Trust Between the Subaccounts](#)

[Create an OAuth Client](#)

[Create a Destination](#)

[Create Trust Between the Subaccounts](#)

Exchange keys and certificates between the subaccounts, and configure trust between them. This will enable the subaccounts to communicate using HTTP destinations.

Procedure

In the cloud cockpit, log on with the Administrator user.

Save locally the identifying X509 certificate of the subaccount in the Cloud Foundry environment.

In SAP BTP cockpit, navigate to the subaccount in the Cloud Foundry environment.

Navigate to [Connectivity Destinations](#).

Choose [Download Trust](#) and save the X509 certificate identifying this subaccount.

In the subaccount in the Neo environment, create trust to the subaccount in the Cloud Foundry environment.

Navigate to the subaccount in the Neo environment.

Navigate to [Security Trust Application Identity Provider](#).

Choose [Add Trusted Identity Provider](#) and configure the new trust configuration settings:

In the Name field, enter the following:

<your Cloud Foundry domain host>/<Cloud Foundry subaccount ID>

Tip

You can view the Cloud Foundry domain host in cockpit <your global account> <your subaccount> <your space> [Routes](#).

Tip

You can view the subaccount ID in cockpit <your global account> <your subaccount> [Overview](#).

In the [Signing Certificate](#) field, enter the X509 certificate of the Cloud Foundry account.

Note

Make sure you remove the BEGIN CERTIFICATE and END CERTIFICATE parts.

Mark the [Only for IDP-initiated SSO](#) option.

Save the new trust configuration.

Create an OAuth Client

You need an OAuth client to get an access token for the OAuth-protected resources in the application in the Neo environment.

Context

For more information about working with OAuth clients, see [Create an OAuth Client](#).

Procedure

In the cockpit, navigate to the subaccount in the Neo environment.

Navigate to **Security > OAuth > Clients**, and choose **Register New Client**.

Create an OAuth client with the following configuration settings:

Name - the OAuth client name. You will need to provide this name as value of the **Token Service User** property of the destination below.

Authorization Grant - choose the **Authorization Code** option.

Mark the **Confidential** option, and provide a secret (password).

Save the client.

Note

When creating the required OAuthSAMLBearer destination later, you will need the following information from the OAuth client:

ID

Secret

Create a Destination

Context

Connect the two subaccounts by describing the connection properties in a destination. For more information, see [Modeling Destinations](#).

Procedure

Choose the subaccount in the Cloud Foundry environment, and navigate to **Connectivity > Destinations**.

Choose **New Destination**.

In the new destination, provide the following information:

Field

Description

Name

Technical name of the destination. It can be used later on to get an instance of that destination. It must be unique for the global account.

Description

Free-text description.

Type

HTTP

URL

The URL of the protected resource in the Neo environment.

Example: <https://myneoapp.hana.ondemand.com/myprotectedresource/>

Authentication

OAuth2SAMLBearerAssertion

Proxy Type

Internet

Audience

The value of the local service provider name in the subaccount in the Neo environment.

Copy the value from cockpit **<your Neo subaccount> > Security > Trust > Local Service Provider > Local Service Provider Name**.

Client Key

The ID of the OAuth client for the application in the Neo environment.

Token Service URL

Copy the value of **Token Endpoint** from the following place: cockpit **<your Neo subaccount> > Security > OAuth > Branding**.

Token Service User

The ID of the OAuth client for the application in the Neo environment.

Token Service Password

The secret from the OAuth client.

System User

Empty.

authnContextClassRef

urn:oasis:names:tc:SAML:2.0:ac:classes:PreviousSession

nameIdFormat

urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified if the user ID will be propagated to the Neo application or nameIdFormat = urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress if the user email will be propagated to the Neo application.

àf

Save the changes.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/principal-propagation-from-neo-to-cloud-foundry-environment>

Title: *Principal Propagation from the Neo Environment to the Multi-Cloud Foundation | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecurityPrincipal PropagationPrincipal Propagation from the Neo Environment to the Multi-Cloud...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Principal Propagation from the Neo Environment to the Multi-Cloud Foundation

Enable an application in your subaccount in the Neo environment to access another application in a multi-environment subaccount (for the multi-cloud foundation) without user login (and user interaction) in the second application. For this scenario to work, the two subaccounts need to be in mutual trust, and in trust with the same SAP Cloud Identity Services tenant. The second application will propagate its logged-in user to the first application using an OAuth2SAMLSigner destination.

The graphic below illustrates the overall setup of the scenario.

Prerequisitesà

You have a user account with Administrator role in both SAP BTP subaccounts. See Managing Member Authorizations in the Neo Environment.

You have a custom local service provider configuration (signing keys and certificates, etc.) in your subaccount in the Neo environment. See Configure the Local Service Provider.

Both accounts have a trust configuration to the same SAP Cloud Identity Services tenant. See:

Identity Authentication Tenant as an Application Identity Provider (for the Neo environment)

Manually Establish Trust and Federation Between SAP Authorization and Trust Management Service and SAP Cloud Identity Services (for the multi-cloud foundation)

You have developed and deployed both applications, each in the corresponding subaccount.

Note

All configuration steps described in this tutorial are done using the SAP BTP cockpit.

Requirements to the Application in the Neo Environmentà

The application is running on a Java Web Tomcat 9 runtime.

In the source code, the application needs to reference the destination that we are about to create as a later step. The sample source code below illustrates a complete servlet working with the destination with name pptest.

âE

ã

```
package com.sap.cloud.samples;
```

```
import java.io.BufferedReader;
```

```
import java.io.IOException;
```

```
import java.io.InputStreamReader;
```

```
import java.net.URL;
```

```
import java.net.URLConnection;
```

```
import java.security.KeyStore;
```

```
import java.util.List;
```

```

import javax.naming.Context;
import javax.naming.InitialContext;
import javax.net.ssl.HttpURLConnection;
import javax.net.ssl.SSLContext;
import javax.net.ssl.SSLSocketFactory;
import javax.net.ssl.TrustManagerFactory;
import javax.servlet.ServletException;
import javax.servlet.annotation.WebServlet;
import javax.servlet.http.HttpServlet;
import javax.servlet.http.HttpServletRequest;
import javax.servlet.http.HttpServletResponse;
import org.slf4j.Logger;
import org.slf4j.LoggerFactory;
import com.sap.core.connectivity.api.authentication.AuthenticationHeader;
import com.sap.core.connectivity.api.authentication.AuthenticationHeaderProvider;
import com.sap.core.connectivity.api.configuration.ConnectivityConfiguration;
import com.sap.core.connectivity.api.configuration.DestinationConfiguration;
@WebServlet("/neotocf")
public class NeoToCF extends HttpServlet {
    private static final long serialVersionUID = 1L;
    private static final Logger LOGGER = LoggerFactory.getLogger(NeoToCF.class);
    private static final String ON_PREMISE_PROXY = "OnPremise";
    protected void doGet(HttpServletRequest request, HttpServletResponse response)
    throws ServletException, IOException {
        response.getWriter().println("Served to: " + request.getUserPrincipal().getName());
        try {
            // Look up the connectivity configuration API
            Context ctx = new InitialContext();
            ConnectivityConfiguration configuration = (ConnectivityConfiguration) ctx
                .lookup("java:comp/env/connectivityConfiguration");
            // Get destination configuration
            DestinationConfiguration destConfiguration = configuration.getConfiguration("pptest");
            if (destConfiguration == null) {
                response.sendError(HttpServletResponse.SC_INTERNAL_SERVER_ERROR,
                    String.format(
                        "Destination %s is not found. Hint: " +
                        "Make sure to have the destination configured.",
                        "pptest"));
                return;
            }
            AuthenticationHeaderProvider authHeaderProvider = (AuthenticationHeaderProvider) ctx
                .lookup("java:comp/env/myAuthHeaderProvider");
            // retrieve the authorization header for OAuth SAML Bearer principal propagation
            List<AuthenticationHeader> samlBearerHeader = authHeaderProvider
                .getOAuth2SAMLBearerAssertionHeaders(destConfiguration);
            LOGGER.debug("JWT token from CF XSUAA: " + samlBearerHeader.get(1).getValue());
            // get the configured truststore
            KeyStore trustStore = destConfiguration.getTrustStore();
            // create sslcontext
            TrustManagerFactory tmf = TrustManagerFactory.getInstance(TrustManagerFactory.getDefaultAlgorithm());
            tmf.init(trustStore);
            SSLContext sslcontext = SSLContext.getInstance("TLS");
            sslcontext.init(null, tmf.getTrustManagers(), null);
            SSLSocketFactory sslSocketFactory = sslcontext.getSocketFactory();

```

```

// get the destination URL
String value = destConfiguration.getProperty("URL");
URL url = new URL(value);
// use the sslcontext for url connection
URLConnection urlConnection = url.openConnection();
((HttpsURLConnection) urlConnection).setSSLSocketFactory(sslSocketFactory);
urlConnection.setRequestProperty(samlBearerHeader.get(0).getName(), samlBearerHeader.get(0).getValue());
urlConnection.setRequestProperty(samlBearerHeader.get(1).getName(), samlBearerHeader.get(1).getValue());
urlConnection.connect();
response.getWriter().println("Received from CF:");
BufferedReader in = new BufferedReader(new InputStreamReader(
urlConnection.getInputStream()));
String inputLine;
while ((inputLine = in.readLine()) != null)
response.getWriter().append(inputLine);
in.close();
} catch (Exception e) {
// Connectivity operation failed
String errorMessage = e.getMessage();
LOGGER.error("Connectivity operation failed", e);
response.sendError(HttpServletResponse.SC_INTERNAL_SERVER_ERROR, errorMessage);
}
}
protected void doPost(HttpServletRequest request, HttpServletResponse response)
throws ServletException, IOException {
doGet(request, response);
}
}

```

àf

Requirements to the Application in the Multi-Cloud Foundation[^]

In the multi-cloud foundation, you need an application following the XSA security model (protected with SAML, UAA service binding using JWT token needed, roles configured in the xs-security.json).

See:

Application Router

Building Roles and Role Collections for Applications

Note

You can use the XSA Security Sample Application in GitHub (instructions and code) to develop and deploy an application compliant with the above requirements.

Create a Destination[^]

Prerequisites

Before you create the required destination, you need to note down a few properties that will be used as values in the destination settings.

In the cloud cockpit, navigate to the subaccount in the Cloud Foundry environment.

Navigate to the application router.

Enter the Environment Variables section.

Note down somewhere the values of the following properties:

clientid

clientsecret

url

Context

Connect the first subaccount to the second subaccount by describing the source connection properties in a destination. For more information see Modeling Destinations.

Procedure

Choose the global account and navigate to Connectivity Destinations.

Choose New Destination.

In the new destination, provide the following information:

Field

Description

Name

Technical name of the destination. It can be used later on to get an instance of that destination. It must be unique for the global account.

Note

For the purposes of the example listed in this document, use pptest as value.

URL

The URL of the protected resource in the Cloud Foundry environment. See Configuring Application URLs.

Example: <https://<tenant-specific-route-for-your-business-app>.cfapps.eu10.hana.ondemand.com/>

Authentication

OAuth2SAMLBearerAssertion

Proxy Type

Internet

Audience

Copy the value of entityID property of the SAML 2.0 metadata representing your subaccount in the Cloud Foundry environment.

Tip

You can open the metadata of the subaccount in the Cloud Foundry environment using the following URL:

<https://<your subaccount's subdomain>.authentication.<region host>/saml/metadata>

Example:

<https://demo.authentication.eu10.hana.ondemand.com/saml/metadata>

For the <region host>, see Regions and API Endpoints Available for the Cloud Foundry Environment.

Example of audience/entityID:

demo.aws-live-eu10

Client Key

In the cloud cockpit, navigate to the application in the Cloud Foundry environment (<path to your subaccount> Spaces <your space> Applications <your application>). Open Environment Variables. Copy the value of the clientid property in VCAP_SERVICES xsuaa credentials.

Token Service URL

Get the token service URL from the SAML 2.0 metadata representing your subaccount in the Cloud Foundry environment. The token service URL is defined in the Location attribute of the element marked as AssertionConsumerService, like this :

<md:AssertionConsumerService Location="<Token Service URL>"

Binding="urn:oasis:names:tc:SAML:2.0:bindings:URI" index="1"/>

Tip

You can open the metadata of the subaccount in the Cloud Foundry environment using the following URL:

<https://<your subaccount's subdomain>.authentication.<region host>/saml/metadata>

Example:

<https://demo.authentication.eu10.hana.ondemand.com/saml/metadata>

For the <region host>, see Regions and API Endpoints Available for the Cloud Foundry Environment.

Example of token service URL:

<https://demo.authentication.eu10.hana.ondemand.com/oauth/token/alias/demo.aws-live-eu10>

Token Service User

In the cloud cockpit, navigate to the application in the Cloud Foundry environment (<path to your subaccount> Spaces <your space> Applications <your application>). Open Environment Variables. Copy the value of the clientid property in VCAP_SERVICES xsuaa credentials.

Token Service Password

In the cloud cockpit, navigate to the application in the Cloud Foundry environment (<path to your subaccount> Spaces <your space> Applications <your application>). Open Environment Variables. Copy the value of the clientsecret property in VCAP_SERVICES xsuaa credentials.

System User

Empty.

Save the changes.

Create Trust Between the Subaccountsà

Procedure

In the cloud cockpit, log on with the Administrator user.

Save locally the service provider metadata of the subaccount in the Neo environment.

In SAP BTP cockpit, navigate to the subaccount in the Neo environment. See [Navigate in the Cockpit](#)

Navigate to Security Trust Local Service Provider.

Choose Get Metadata and save the metadata file representing this subaccount.

In the subaccount in the Cloud Foundry environment, create trust to the subaccount in the Neo environment.

Navigate to the subaccount in the Cloud Foundry environment.

Navigate to Security Trust Configuration

Choose New Trust Configuration.

In the Metadata field, choose the Upload button.

Upload the service provider metadata file representing the subaccount in the Neo environment.

Save the new trust configuration.

After this procedure, you can use the security context from the application in the Neo environment to the application in the Cloud Foundry environment. The assigned groups from the Neo environment can be used as role collections in the Cloud Foundry environment.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/protecting-your-application>

Title: *Protecting Your Application | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Adding Authentication and AuthorizationProtecting Your Application

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Protecting Your Application

Developers create authorization information for business users in their environment; this information is deployed in an application and made available to administrators who complete the authorization setup and assign the authorizations to business users.

Lifecycle of Security Artifacts for Developers and Administratorsà

Developers store authorization information as design-time role templates in the application security descriptor file (xs-security.json). Using the xsuaa service broker, they deploy the security information to the xsuaa service.

The administrators view the authorization information in role templates, which they use as part of the run-time configuration. They use the role templates to build roles, which are aggregated in role collections. The role collections are then assigned, in turn, to business users.

The tasks required to set up authorization artifacts are performed by two distinct user roles: the application developer and the administrator of the Cloud Foundry environment. After the deployment of the authorization artifacts as role templates, the administrator of the application uses the role templates provided by the developers for building role collections and assigning them to business users.

Note

To test authorization artifacts after deployment, developers can use the role templates to build role collections and assign authorization to business users in an authorization tool based on a REST API.

Setting Up Authorization Artifacts (Developers)

Step

Task

User Role

Tool

1

Specify the application security descriptor file containing the functional authorization scopes for your application.

Application developer

Text editor

(If applicable) If you want to create an OAuth 2.0 client in an application-related subaccount, you must use a separate security descriptor file where you specify the subaccount.

Application developer

CF command line interface

2

Create role templates for the application using the application security descriptor file.

Application developer

Text editor

3

Create a service instance from the xsuaa service using the service broker

Application developer

CF command line interface

4

Bind the service instance to the application by including it into the manifest file

Application developer

Text editor

5

Deploy the application

Application developer

CF command line interface or SAP BTP cockpit

Note

For more information about the different steps in setting up authorization artifacts as an application developer, refer to the associated procedures in this section.

Add Authentication and Functional Authorization Checks to Your Application

Propagate User Information Between Applications or Services

Set Up Your Application for Multitenancy

Setting Up Instance-Based Authorizations

Setting Up Authorization Artifacts (Account Administrators)

Task

Links

Assign the role collection to the users provided by an identity provider

Working with Role Collections

(If you do use a custom identity provider) Assign the role collections to user groups

Map Role Collections to User Groups

Assign the role collections to users and user groups, manage attribute mappings

Mapping Role Collections

Create a role collection and assign roles to it

Define a Role Collection

Use an existing role or create a new one using role templates

Add Roles to Role Collections on the Application Level

Related Information

Application Security Descriptor Configuration Syntax

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/role-based-access-control-rbac-in-kyma>

Title: Role-Based Access Control (RBAC) in Kyma | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP BTP Administrator's Guide...Setting Up

AuthorizationRole-Based Access Control (RBAC) in Kyma

SAP BTP Administrator's GuideEnglish

Provide feedback on our search

à

Role-Based Access Control (RBAC) in Kyma

Assigning permissions in Kyma is based on the Kubernetes role-based access control (RBAC). It's recommended that you start with separating the developers and operators of a cluster. Later, you can refine the role concept as required.

Recommended Role Setup

The goal of the recommended role setup is to implement Kubernetes RBAC best practices, which is a method of regulating access to computer or network resources based on the roles of individual users within your

organization.

The role setup separates the operators from the development teams, and day-to-day user accounts from administrative accounts. It enables DevOps while ensuring security on production clusters.

In production clusters and development and test clusters alike, each service, project, or development team should have its own namespace.

Typically, it's useful that developers have read access to dedicated resources on cluster level or in other namespaces, such as "Istio" or "Application Connector". Use the ClusterRole common-resource-viewer for this. Additional modules can bring additional resources. For more information, see Kyma Modules.

The suggested setup uses the Kubernetes objects "ClusterRole", "RoleBinding", and "ClusterRoleBinding". For examples of the required Kubernetes objects, see the suggested manifest templates.

In RoleBindings and ClusterRolebindings, use groups instead of users. For more information about group management in SAP Cloud Identity Services, see Groups.

To reduce the number of accounts directly assigned to powerful roles in the cluster, use Kubernetes impersonation.

Impersonation in Kubernetes

Role Setup for Operatorsà^

Role Setup for Developers (Dev and Test)à^

Role Setup for Developers (Prod)à^

Tip

Use the following manifest templates to set up the recommended role concept.

Expand the sections to see the role setup for each purpose, and within the sections, expand the sample code to see the manifest templates.

Kubernetes Manifest Templates for Generic Rolesà^

View All Resources

View Common Kyma Objects in the Cluster

Kubernetes Manifest Templates for Operatorsà^

View Access for All Clusters

Admin Access for All Clusters

Kubernetes Manifest Templates for Developersà^

Namespace Admin Access for Dev and Test

Admin Access for Prod

Read Access to Namespace for Prod

Related Informationà^

Kubernetes: Using RBAC Authorization

Kubernetes: Role Based Access Control Good Practices

SAP Blogs: Using the Kubernetes-native Role-based access control

Assign Roles in the Kyma Environment

Cloud Foundry, Kyma, or Both?

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/role-collections-and-roles-in-global-accounts-directories-and-subaccounts>

Title: Role Collections and Roles in Global Accounts, Directories, and Subaccounts | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Platform UsersRole

Collections and Roles in Global Accounts, Directories, and S...

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Role Collections and Roles in Global Accounts, Directories, and Subaccounts

SAP BTP provides a set of role collections to set up administrator access to your global account and subaccounts.

Role collections group authorizations for resources and services. Your administrators assign these role collections to other platform users to create new administrators. Role collections consist of individual roles. For more information on role collections, roles, see the related link.

Role collections are account-specific. Role collections that exist in the global account don't exist in the subaccounts. Likewise, role collections in subaccounts aren't available in the global account.

Note

Neo subaccounts don't use role collections.

For more information, see [Managing Member Authorizations in the Neo Environment](#).

Role Collections

You can use the default role collections, but you can't change or delete them. SAP BTP provides the following administrator role collections:

Global Account Administrator

Subaccount Administrator

Directory Administrator

Cloud Connector Administrator

Connectivity and Destination Administrator

Destination Administrator

Destination Fragment Administrator

Subaccount Service Administrator

SAP BTP provides also viewer role collections for the global account and for subaccounts. In contrast to the administrator role collections, viewer role collections only grant read access.

Global Account Viewer

Subaccount Viewer

Directory Viewer

Administrator Role Collections

If you assign the Global Account Administrator role collection to a user, this user can perform administration tasks for subaccounts, role collections, identity providers, entitlements, and regions on the level of the global account. If you assign the Global Account Viewer role collection, this user can view subaccounts, role collections, identity providers, entitlements, and regions on the level of the global account.

Note

You can also use the command-line interface (CLI) for SAP BTP to assign authorizations. For more information on managing authorizations, see the related link.

Global Account Administrator Role Collection

Roles Included

Description

Global Account Admin

Role for global account members with read-write authorizations for core commercialization operations, such as updating global accounts, setting entitlements, and creating, updating, and deleting subaccounts.

Note

Users with this authorization don't automatically gain administrator authorizations in all subaccounts, but can grant themselves administrator-level access. You can opt out of this feature. For more information, see [Add Members to Your Subaccount](#).

The `GlobalAccount_Admin` role template contains this role. You find the role template in the SAP BTP Cockpit if you choose the `cis-central!<suffix>` application identifier.

Example

`cis-central!b1`

Global Account Usage Reporting Viewer

Role for global account members with read-only authorizations for core commercialization operations, such as viewing global account usage information.

The `GlobalAccount_Usage_Reporting_Viewer` role template provides this role. You find the role template in the SAP BTP Cockpit if you chose the `uas!<suffix>` application identifier

User and Role Administrator

Manage authorizations, trusted identity providers, and users.

The `xsuaa_admin` role template provides this role. You find the role template in the SAP BTP Cockpit if you choose the `xsuaa!<suffix>` application identifier.

Example

`xsuaa!tl`

Auditlog_Auditor

Read access to audit logs

Auditlog_Auditor

View audit logs

System Landscape Administrator

Administrative access to systems and scenario-related resources.

The GlobalAccount_System_Landscape_Administrator role template provides this role. You find the role template in the SAP BTP Cockpit if you choose the cmp!<suffix> application identifier.

Example

cmp!b7

If you assign the Subaccount Administrator role collection to a user, you grant a user administration permission for a subaccount.

Subaccount Administrator Role Collection

Roles Included

Description

Auditlog_Auditor

Read access to audit logs

Auditlog_Auditor

View audit logs

Cloud Connector Administrator

Operate the data transmission tunnels used by the Cloud connector.

Destination Administrator

Manage destination configurations, certificates and subaccount trust via the Destination editor in the SAP BTP cockpit.

Destination Fragment Administrator

Manage destination fragments

Subaccount Admin

Role for subaccount members with read-write authorizations for core commercialization operations, such as viewing subaccount entitlements, and creating and deleting environment instances.

Subaccount Service Administrator

Administrative access to service brokers and environments on a subaccount level.

User and Role Administrator

Manage authorizations, trusted identity providers, and users.

If you assign the Cloud Connector Administrator role collection to a user, you grant the user administration permissions for the Cloud Connector in a subaccount.

Cloud Connector Administrator Role Collection

Roles Included

Description

Cloud Connector Administrator

Operate the data transmission tunnels used by the Cloud connector.

If you assign the Connectivity and Destination Administrator role collection to a user, you grant the user administration permissions for the Cloud Connector and SAP Destination service in a subaccount.

Connectivity and Destination Administrator Role Collection

Roles Included

Description

Cloud Connector Administrator

Operate the data transmission tunnels used by the Cloud connector.

Destination Administrator

Manage destination configurations, certificates and subaccount trust via the Destination editor in the SAP BTP cockpit.

If you assign the Destination Administrator role collection to a user, you grant the user administration permissions for the SAP Destination service in a subaccount.

Destination Administrator Role Collection

Roles Included

Description

Destination Administrator

Manage destination configurations, certificates and subaccount trust via the Destination editor in the SAP BTP cockpit.

If you assign the Destination Fragment Administrator role collection to a user, you grant the user administration permissions for the management of destination fragments for the SAP Destination service in a subaccount.

Destination Fragment Administrator Role Collection

Roles Included

Description

Destination Fragment Administrator

Manage destination fragments

If you assign the Subaccount Service Administrator role collection to a user, you grant the user administration permissions for the Service Manager in a subaccount.

Subaccount Service Administrator Role Collection

Roles Included

Description

Subaccount Service Administrator

Administrative access to service brokers and environments on a subaccount level.

Viewer Role Collectionsà^

If you assign the Global Account Viewer role collection to a user, you grant read access to the same information as the Global Account Administrator role collection.

Global Account Viewer Role Collection

Roles Included

Description

Global Account Viewer

Role for global account members with read-only authorizations for core commercialization operations, such as viewing global accounts, subaccounts, entitlements, and regions.

Global Account Usage Reporting Viewer

Role for global account members with read-only authorizations for core commercialization operations, such as viewing global account usage information.

Auditlog_Auditor

Read access to audit logs

Auditlog_Auditor

View audit logs

User and Role Auditor

Read-only access for authorizations, trusted identity providers, and users.

System Landscape Viewer

Viewer access to systems and scenario-related resources.

If you assign the Subaccount Viewer role collection to a user, you restrict a user's viewer permission to the subaccounts.

Subaccount Viewer Role Collection

Roles Included

Description

Auditlog_Auditor

Read access to audit logs

Auditlog_Auditor

View audit logs

Cloud Connector Auditor

View the data transmission tunnels used by the Cloud connector to communicate with back-end systems.

Destination Fragment Viewer

View destination fragments

Destination Viewer

View destination configurations, certificates and subaccount trust via the Destination editor in the SAP BTP cockpit.

Subaccount Service Auditor

Read-only access to service brokers and environments on a subaccount level

Subaccount Viewer

Role for subaccount members with read-only authorizations for core commercialization operations, such as viewing subaccount entitlements, details of environment instances, and job results.

User and Role Auditor

Read-only access for authorizations, trusted identity providers, and users.

Note

To obtain permissions to view the service binding credentials, ask an administrator to create a new role collection that includes the Subaccount Viewer role collection and the Service Credentials Viewer role (see [Define a Role Collection](#)).

Directory Role Collections

The role collections Directory Administrator and Directory Viewer can be assigned after the creation of a directory. If you select the Enable user management checkbox, you receive the Directory Administrator role collection by default. You can't create custom role collections for directories.

The Directory Administrator role collection grants a user administration permission for directories.

Directory Administrator Role Collection

Roles Included

Description

Directory Admin

Role for directory members with read-write authorizations for core commercialization operations, such as updating directories, setting entitlements, and creating, updating, and deleting subaccounts.

Directory Usage Reporting Viewer

Role for directory members with read-only authorizations for core commercialization operations, such as viewing directory usage information.

User and Role Administrator

Manage authorizations, trusted identity providers, and users.

The Directory Viewer role collection grants a user read access to the same information as the Directory Administrator role collection.

Directory Viewer Role Collection

Roles Included

Description

Directory Usage Reporting Viewer

Role for directory members with read-only authorizations for core commercialization operations, such as viewing directory usage information.

Directory Viewer

Role for directory members with read-only authorizations for core commercialization operations, such as viewing directories, subaccounts, entitlements, and regions.

User and Role Auditor

Read-only access for authorizations, trusted identity providers, and users.

Roles

Create your own role collections by using the roles of the default role collections. The roles are based on role templates, which are provided by applications. The application identifier refers to the application, which provides the role templates.

Example

The GlobalAccount_Admin role template provides the Global Account Admin role. You find the role template in the cockpit if you choose the cis-central!<suffix> application identifier.

Example

cis-central!b1

The following table provides the information about the roles that are available.

Role Details

Roles

Available in

Role Templates

Application Identifier

Application Subscriptions Viewer

Subaccount
Application_Subscriptions_Viewer
cis-local!<suffix>
Application Destination Administrator
Subaccount
Application_Destination_Administrator
destination-xsappname!<suffix>
Application Destination Viewer
Subaccount
Application_Destination_Viewer
destination-xsappname!<suffix>
Auditlog_Auditor
Global account and subaccount
Auditlog_Auditor
auditlog-management!<suffix>
Auditlog_Auditor
Global account and subaccount
Auditlog_Auditor
auditlog-viewer-initial-content!<suffix>
Cloud Connector Administrator
Subaccount
Cloud_Connector_Administrator
connectivity!<suffix>
Cloud Connector Auditor
Subaccount
Cloud_Connector_Auditor
connectivity!<suffix>
Destination Administrator
Subaccount
Destination_Administrator
destination-xsappname!<suffix>
Destination Administrator Instance
Subaccount
Destination_Administrator_Instance
destination-xsappname!<suffix>
Destination Certificate Administrator
Subaccount
Destination_Certificate_Administrator
destination-xsappname!<suffix>
Destination Certificate Instance Administrator
Subaccount
Destination_Certificate_Instance_Administrator
destination-xsappname!<suffix>
Destination Certificate Instance Viewer
Subaccount
Destination_Certificate_Instance_Viewer
destination-xsappname!<suffix>
Destination Certificate Viewer
Subaccount
Destination_Certificate_Viewer
destination-xsappname!<suffix>
Destination Configuration Administrator
Subaccount
Destination_Configuration_Administrator

destination-xsappname!<suffix>
Destination Configuration Instance Administrator
Subaccount
Destination_Configuration_Instance_Administrator
destination-xsappname!<suffix>
Destination Configuration Instance Viewer
Subaccount
Destination_Configuration_Instance_Viewer
destination-xsappname!<suffix>
Destination Configuration Viewer
Subaccount
Destination_Configuration_Viewer
destination-xsappname!<suffix>
Destination Fragment Administrator
Subaccount
Destination_Fragment_Administrator
destination-xsappname!<suffix>
Destination Fragment All Properties Administrator
Subaccount
Destination_Fragment_All_Properties_Administrator
destination-xsappname!<suffix>
Destination Fragment Instance Administrator
Subaccount
Destination_Fragment_Instance_Administrator
destination-xsappname!<suffix>
Destination Fragment Instance Viewer
Subaccount
Destination_Fragment_Instance_Viewer
destination-xsappname!<suffix>
Destination Fragment Viewer
Subaccount
Destination_Fragment_Viewer
destination-xsappname!<suffix>
Destination Subaccount Trust Administrator
Subaccount
Destination_Subaccount_Trust_Administrator
destination-xsappname!<suffix>
Destination Subaccount Trust Viewer
Subaccount
Destination_Subaccount_Trust_Viewer
destination-xsappname!<suffix>
Destination Viewer
Subaccount
Destination_Viewer
destination-xsappname!<suffix>
Destination Viewer Instance
Subaccount
Destination_Viewer_Instance
destination-xsappname!<suffix>
Directory Admin
Directory
Directory_Viewer
cis-central!<suffix>
Directory Usage Reporting Viewer

Directory
Directory_Usage_Reporting_Viewer
uas!<suffix>
Directory Viewer
Directory
Directory_Admin
cis-central!<suffix>
Global Account Admin
Global account
GlobalAccount_Admin
cis-central!<suffix>
Global Account Viewer
Global account
GlobalAccount_Viewer
cis-central!<suffix>
Global Account Usage Reporting Viewer
Global account
GlobalAccount_Usage_Reporting_Viewer
uas!<suffix>
Service Credentials Viewer
Subaccount
Service_Credentials_Viewer
service-manager!<suffix>
Service Instances Viewer
Subaccount
Service_Instances_Viewer
service-manager!<suffix>
Subaccount Admin
Subaccount
Subaccount_Admin
cis-local!<suffix>
Subaccount Service Admin
Subaccount
Subaccount_Service_Admin
service-manager!<suffix>
Subaccount Service Administrator
Subaccount
Subaccount_Service_Administrator
service-manager!<suffix>
Subaccount Service Auditor
Subaccount
Subaccount_Service_Auditor
service-manager!<suffix>
Subaccount Service Viewer
Subaccount
Subaccount_Service_Viewer
service-manager!<suffix>
Subaccount Viewer
Subaccount
Subaccount_Viewer
cis-local!<suffix>
System Landscape Administrator
Global account
GlobalAccount_System_Landscape_Administrator

cmp!<suffix>

System Landscape Viewer

Global account

GlobalAccount_System_Landscape_Viewer

extension-service-cmp!<suffix>

User and Role Administrator

Global account and subaccount

xsuaa_admin

xsuaa!<suffix>

User and Role Auditor

Global account and subaccount

xsuaa_auditor

xsuaa!<suffix>

àf

Roles in Environmentsà^

If you've enabled environments in your subaccount, manage the roles for those environments. For more information, see:

About Roles in the Cloud Foundry Environment

Assign Roles in the Kyma Environment

Note

The ABAP environment uses the roles of the SAP BTP, Cloud Foundry Environment.

Related Informationà^

User and Member Management

Working with Role Collections

Building Roles and Role Collections for Applications

Mapping Role Collections

Managing Users and Their Authorizations Using the btp CLI

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/roles-and-role-collections>

Title: Roles and Role Collections | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Building Roles and Role Collections for ApplicationsRoles and Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Roles and Role Collections

Usually a role collection consists of one or multiple roles. You can use the SAP BTP cockpit to add or remove roles.

Roleà^

A role is an instance of a role template; you can build a role based on a role template and assign the role to a role collection. The SAP BTP cockpit helps you to display information about the selected application and any related roles in the following windows, tabs, and panes:

Roles

Scopes

Attributes

Role templates

Role Collectionà^

Roles are assigned to role collections which are assigned in turn to users or user groups if an SAML 2.0 identity provider stores the users. Using the SAP BTP cockpit, you can display information about the role collections that have been maintained as well as the roles available in a role collection. Additional information includes: which templates the roles are based on, and which applications the roles apply to. Role collections enable you to group together the roles you create. The role collections you define can be assigned as follows:

To users logged on to the SAP ID service.

To user groups containing users logging on with SAML 2.0 assertions.

Related Informationà^

Attributes

Security Administration: Managing Authentication and Authorization

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/sap-authorization-and-trust-management-service-in-cloud-foundry-environment>

Title: SAP Authorization and Trust Management Service | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySAP Authorization and Trust Management Service

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

SAP Authorization and Trust Management Service

The global account and subaccounts get their users from identity providers. Administrators make sure that users can only access their dedicated subaccount by making sure that there is a dedicated trust relationship only between the identity providers and the respective subaccounts. Developers configure and deploy application-based security artifacts containing authorizations, and administrators assign these authorizations using the SAP BTP cockpit.

Note

Before you start, make yourself familiar with the sections about authentication and authorization of the SAP BTP Planning and Lifecycle-Management Guide. See the Setting Up Your Security and Compliance Model section.

Hold your pointer over a box for a description. Select a box to display more information.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/secure-administration-and-operations-in-kyma-environment>

Title: Secure Administration and Operations in the Kyma Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySecurity in the Kyma EnvironmentSecure Administration and Operations in the Kyma Environment

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Secure Administration and Operations in the Kyma Environment

Secure administration and operations focus on landscape setup, authentication, authorization, and Istio access logs. Learn about the security measures you can take to improve the security of your Kyma environment.

Landscape Setupà

While creating a staged development environment is a good idea in any case, there are some considerations specific to Kyma you might want to take into account. For more information, see Cloud Foundry, Kyma, or Both?.

Authenticationà

SAP BTP, Kyma runtime uses OpenID Connect for authentication. Kyma runtime is configured to use a default shared SAP Cloud Identity Services tenant, SAP ID service, as an identity provider. This is a good starting point for development and testing purposes. However, for production scenarios, it is recommended to get your own SAP Cloud Identity Services tenant. For more information, see Authentication in the Kyma Environment.

Authorizationà

Kyma uses Kubernetes Role-Based Access Control (RBAC) and assures during provisioning that a user who creates and owns a particular runtime is given the cluster-admin role. Users with the cluster-admin role can define any additional cluster roles or use those defined in Kyma and bind them to other users from Kyma dashboard or with the kubectl CLI tool. See Assign Roles in the Kyma Environment. For recommendations on setting up roles and permissions in Kyma, see Role-Based Access Control (RBAC) in Kyma.

Note

For more information about user and member management in the SAP BTP cockpit, see User and Member Management.

Istio Access Logsà

Collecting Istio access logs can help indicate the core concepts of monitoring (latency, traffic, errors, and saturation) and capture critical aspects of system behavior. By Configure Observability for the Istio Service Mesh you monitor and analyze the traffic in your Kyma cluster. Then, send the logs to a central platform, for example, a Security Information and Event Management (SIEM) system, for threat detection and incident

response.

Related Information^

Kyma Security Concepts

Secure Development in the Kyma Environment

Authentication in the Kyma Environment

Configuring a Custom Identity Provider for Kyma

Assign Roles in the Kyma Environment

Auditing and Logging Information in Kyma

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/secure-development-in-kyma-environment>

Title: *Secure Development in the Kyma Environment* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySecurity in the Kyma EnvironmentSecure Development in the Kyma Environment

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Secure Development in the Kyma Environment

Secure development focuses on Pod security, network traffic restriction, Istio sidecar proxy injection, and workload exposure. Learn about the security measures you can take to improve the security of your Kyma environment .

Pod Security^

To learn how to secure your Kubernetes Pods in Kyma, see Kubernetes Pod Security Recommendations.

Restrict and Secure Network Traffic^

Set up Kubernetes Network Policies to restrict the network traffic between Pods in your namespaces.

Enabling Istio Sidecar Proxy Injection for your namespaces.

Expose Workloads Securely^

To securely expose workloads in SAP BTP, Kyma runtime, use the Istio and API Gateway modules. As a prerequisite, make sure that you have those two modules added to your Kyma cluster. Then, perform the following tasks:

Set up a custom domain for a workload. See Istio Gateways.

Disable the default gateway. See Kyma Gateway.

Set up your own API gateway with one of the following options:

Configure a TLS Gateway

Configure an mTLS Gateway

Create an APIRule Custom Resource to securely expose your workloads. See Expose and Secure a Workload with a JWT Using SAP Cloud Identity Services.

Module-Specific Security Considerations^

Serverless Module

For more information, see Function Security for the Serverless module.

Related Information^

Kyma Security Concepts

Secure Administration and Operations in the Kyma Environment

Kubernetes Pod Security Recommendations

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/security-administration-managing-authentication-and-authorization>

Title: *Security Administration: Managing Authentication and Authorization* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Account

Administration in the CockpitSecurity Administration: Managing Authentication and Authorization

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Security Administration: Managing Authentication and Authorization

This section describes the tasks of administrators of SAP BTP. Administrators ensure user authentication and assign authorization information to users and user groups.

Since identity providers provide the users or user groups, you make then sure that there is a trust relationship between your subaccount and the identity provider. This is a prerequisite for authentication. You can manage the authorizations of the users.

Authentication^

A user account corresponds to a particular user in an identity provider. The user is always authenticated using an external identity provider.

Recommendation

We recommend to use a custom tenant of SAP Cloud Identity Services. You can connect SAP Cloud Identity Services to your corporate identity provider.

SAP BTP distinguishes two types of users. Platform users are usually administrators, operator, or developers. They have full access and give permissions at global account, directory, and subaccount level. Business users use the applications deployed to SAP BTP. They are, for example, end users of SaaS apps or of custom applications.

For more information, see the related links.

Authorization^

Application developers create and deploy application-based authorization artifacts for business users.

Administrators use this model to manage roles, build role collections, and assign these collections to users or user groups. In this way, they control the users' permissions.

To perform the functions related to authorization artifacts, account administrators can have multiple options.

Here are some of the options:

The SAP BTP cockpit covers all authorization functions. Its user interface offers easy-to-use and clear navigation.

There is also a command line option to manage most authorization artifacts. If you prefer working in a terminal or automating operations, use the SAP BTP command line interface (btp CLI). It's suitable for repetitive tasks. Especially if you need to perform bulk operations or programmatically access the authorizations, we recommend to use the REST API for authorizations of the SAP Authorization and Trust Management service. Administrators can also use the Terraform Provider for SAP BTP within Infrastructure as Code to manage some of the authorization functions.

You find the all available options and tools for managing authorizations in the account administration overview.

See Account Administration.

Setting Up Authorization Artifacts (Account Administrators)

Task

Links

Assign the role collection to the users provided by an identity provider

Working with Role Collections

(If you do use a custom identity provider) Assign the role collections to user groups

Map Role Collections to User Groups

Assign the role collections to users and user groups, manage attribute mappings

Mapping Role Collections

Create a role collection and assign roles to it

Define a Role Collection

Use an existing role or create a new one using role templates

Add Roles to Role Collections on the Application Level

Note

When users log on, their authorizations are stored in each user's current session. These authorizations are not dynamically updated and are removed from there only when the session is terminated. This means that, after changes of role collection assignments of a user, these changes only become effective after the user logged out and logged on again.

Related Information^

Trust and Federation with Identity Providers

Monitoring and Troubleshooting

SAP Authorization and Trust Management Service

Default Identity Provider

User and Member Management

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/security-and-data-privacy-configuration>

Title: SAP Help Portal | SAP Online Help

ProductsWhat's NewExplore SAP

Loading Document...

âf

â„

âç

à PDF

àFavorite

á=Share

áÀ

áTable of Contents

Loading Table of Contents...

Loading Topic...

âWas this page helpful?

â"Yes

â#No

Copyright

Disclaimer

Privacy Statement

Legal Disclosure

Trademark

Terms of Use

Cookie Preferences

Accessibility & Sustainability

Ask a Question about the SAP Help Portal

Find us on

Share

á=

Your choices regarding cookies on this site

This site uses cookies and related technologies, as described in our Cookie Statement, for purposes that may include site operation, analytics, enhanced user experience, or advertising. You may choose to consent to our use of these technologies, or manage your own preferences.

[Privacy Statement](#) | [Cookie Statement](#)

[Accept All](#)

[Deny All](#)

[Manage Settings](#)

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/security-in-kyma-environment>

Title: Security in the Kyma Environment | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySecurity in the Kyma Environment

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Security in the Kyma Environment

Security in SAP BTP, Kyma runtime comprises the following pillars:

Kyma Security Concepts

Secure Administration and Operations in the Kyma Environment

Secure Development in the Kyma Environment

Go to the respective topics to learn more about the security features and configurations they propose.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/service-instance-secrets>

Title: Service Instance Secrets | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Managing Secrets

Service Instance Secrets

When an application consumes a service instance of the SAP Authorization and Trust Management service (XSUAA), the application identifies itself to the service instance with a client ID and a secret. The client ID and secret are the credentials with which an application authenticates itself to the service instance.

The SAP Authorization and Trust Management service (XSUAA) creates these credentials either when you bind the application to the service instance or when you create a service key for the service instance.

The service instance can use multiple secrets in the application plan.

The instance secret is the same for all bindings of the service instance. The secret remains valid as long as the instance exists.

Note

Starting with January, 19, 2026, the instance-secret credential type isn't supported anymore for new bindings and service keys. We recommend to remove old bindings with this credential type.

The binding secret is the default secret type. Binding secrets must be enabled in the application security descriptor (xs-security.json) when you create the service instance. When you bind an application to a service instance or create a service key, you can pass a parameters.json to use a binding secret. The secret remains valid as long as the binding or the service key exists.

X.509 secrets must be enabled in the application security descriptor (xs-security.json) when you create the service instance. When you bind an application to a service instance or create a service key, you can pass a parameters.json to use an X.509 secret. SAP Authorization and Trust Management service can generate an X.509 certificate for you or you can provide your own. The X.509 secret remains valid as long as the certificate itself is valid.

Note

The service doesn't check for certificate revocation. To stop the service from accepting a certificate that is still valid, delete the relevant bindings or service keys. As soon as the binding is deleted, the service stops accepting the certificate.

For bindings with self-managed certificates and the certificate-pinning parameter set to false, you can rotate the secrets without deleting bindings. Just use a new certificate with the same subject and issuer distinguished name (DN). The service saves the new validity date of the new certificate.

For more information, see Parameters for Self-Managed X.509 Certificates.

The following figure illustrates the XSUAA app and the binding information about the OAuth 2.0 client as part of a service instance of the SAP Authorization and Trust Management service. A consuming application, functioning as an OAuth 2.0 client is bound to the SAP Authorization and Trust Management service instance. The secret is part of the environment of the consuming application and the information about the OAuth 2.0 client saved with the XSUAA app. Alternatively, this information is saved as part of a service key.

Binding Between an SAP Authorization and Trust Management Service Instance and a Consuming Application

The credential-types parameter of the OAuth client configuration in the application security descriptor (xs-security.json) determines which types of secrets that bindings support.

In the following example, the service instance creates a binding secret for all new bindings. It allows the creation of X.509 secrets.

Example

Sample Code

âE

ã

```
"oauth2-configuration": {
  "credential-types": ["binding-secret","x509"]
}
```

In the following example, the service instance creates a binding secret for all new bindings, but doesn't accept the instance secret or the use of X.509 secrets.

Example

Sample Code

âE

ã

```
"oauth2-configuration": {  
  "credential-types": ["binding-secret"]  
}
```

Related Informationà^

Rotate Binding Secrets

Rotating Instance Secrets

Migrate from Instance Secrets to Binding Secrets

Application Security Descriptor Configuration Syntax

Limits for Technical Artifacts of the SAP Authorization and Trust Management Service

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/setup-of-custom-identity-service>

Title: *Setup of a Custom Identity Service* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Getting Started with a Customer Account in the ABAP EnvironmentSetup of a Custom Identity Service

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Setup of a Custom Identity Service

For your business users in the ABAP environment, you set up a custom identity service.

Custom Identity Service for the ABAP Environmentà^

For platform users such as the administrator, the default identity provider is SAP ID Service, which is set up by default. For the business users in the ABAP environment, you must set up a custom identity service. For example, the users of your deployed application or users of subscribed apps or services, such as SAP Business Application Studio, are business users. For more information about platform and business users in the ABAP environment, see User Types.

In this documentation, a custom trust configuration is described using SAP Cloud Identity Services - Identity Authentication. The Identity Authentication service is a cloud solution for identity lifecycle management for SAP BTP applications. You can set up SAP BTP as a service provider, and Identity Authentication service as an identity provider.

Identity Authentication Service as Proxyà^

If you have your own custom identity providers at your company, you can use SAP Cloud Identity Services - Identity Authentication as a proxy. For more information about setting up the Identity Authentication service as a proxy, see Establish Trust and Federation Between UAA and Identity Authentication and Configure Trust with Corporate Identity Provider.

More Informationà^

This documentation describes the basic trust concepts and helps you to get started with a simple landscape. To learn more about trust setup with custom identity providers, check the following, more detailed documentation:

For more information about trust in SAP BTP, see Trust and Federation with Identity Providers.

For more information about the Identity Authentication service, see Overview and Initial Setup.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/tasks-on-demand>

Title: *Tasks On Demand* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Adding Authentication and AuthorizationTasks On Demand

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Tasks On Demand

Here you can find information regarding the available extended tasks for creating authorization artifacts, as well as the process of configuring redirect URLs.

In addition, as an application developer, you may want to create role collections for immediate use. For example, to deliver role collections that administrators can use in the SAP BTP cockpit and easily assign to users in an onboarding process.

Update a Service Instance

You can update a service instance from the xsuaa service using the service broker.

Sharing and Unsharing Service Instances

You can share service instances of the SAP Authorization and Trust Management service across multiple spaces or environments. This has the advantage that you don't need to create separate service instances in multiple spaces or environments.

Compatible Changes in the Security Descriptor File

If you update a service instance, you can add, change, and/or delete scopes, attributes, and role templates.

Whenever you change role templates, you adapt roles that are derived from the changed role template.

Retrieve Credentials for Remote Applications

You need to get the credentials of a service instance for an application that runs outside SAP BTP.

Configure Redirect URLs for Browser Logout

To avoid open redirect attacks, direct users to a safe and valid URL when they log out.

Create Role Collections with Predefined Roles

As an application developer, you want to create role collections for immediate use. You want to deliver role collections that administrators can use in the cockpit, and easily assign to users, for example in an onboarding process.

Validation and Revocation of Access Tokens

To confirm that access tokens were truly issued by the SAP Authorization and Trust Management service and are still valid, applications check the tokens for validity.

Include Tokens from Corporate Identity Providers or SAP Cloud Identity Services in Tokens of the SAP Authorization and Trust Management Service

In scenarios where your SAP BTP application interacts with applications that don't support tokens issued by the SAP Authorization and Trust Management service, but require a token from a corporate identity provider or SAP Cloud Identity Services, you can configure SAP Authorization and Trust Management service to include this token.

Best Practices When Handling Access Tokens

Calls to SAP Authorization and Trust Management service can fail for many reasons, including network latency, connection errors, service downtime, idle connections closed by routing components and so on. The following sections provide recommendations on when to retry connections and the caching of tokens.

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/troubleshooting-for-sap-authorization-and-trust-management-service>

Title: *Troubleshooting for SAP Authorization and Trust Management Service | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Monitoring and TroubleshootingTroubleshooting for SAP Authorization and Trust Management Service

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Troubleshooting for SAP Authorization and Trust Management Service

This section contains troubleshooting information for the Cloud Foundry environment of SAP Business Technology Platform. It provides assistance with issues concerning platform security functions such as business user authentication, authentication of applications, authorization management, trust management, and other security functions.

If you need support or experience issues, please report an incident under component BC-CP-CF-SEC-IAM.

The Security Tab is Missing in the Subaccount

Access Is Denied or Forbidden

Identity Provider Could Not Process Authentication Request

Login Screen Shows "SAP HANA XS Advanced"

Requested Route Does Not Exist

Subdomain Does Not Map to a Valid Identity Zone

No Client with Requested ID

Login Issues

Cannot Add Role Templates to Predefined Role Collections

409 Error Code on Deleting a Custom Identity Provider

Unexpected AuthnResponse : Existing authentication - <User>
AuthnRequest expired - ID: <RequestId> Destination: <IdPDestination>
InResponseToField of Response Doesn't correspond to the Sent Message
Response Issue Time is Either too Old or with Date in the Future. Sync IdP to Match Skew <skew>
Trust Establishment Issues
Token Retrieval Fails With Status Code 401
Cockpit Displays HTTP Status 500 Error on Logon with Custom IdP User
IAS Application Reference isn't Created in Your IAS Tenant
User Base Doesn't Appear in Existing Neo Subaccounts
User from Corporate IdP Cannot Log on to Neo Subaccount
Share Authorization and Trust Management service instances
Invalid "redirect_uri"
400 Error: Call to /oauth/token Was Not Successful
Missing Administrator Access to SAP Business Technology Platform
Unexpected User in Subaccount
There Was an Error When Authenticating Against the External Identity Provider
Common Authorization Issues in SAP Integration Suite

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/trust-and-federation-with-identity-providers>

Title: Trust and Federation with Identity Providers | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Security
Administration: Managing Authentication and AuthorizationTrust and Federation with Identity Providers
SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Trust and Federation with Identity Providers

When setting up accounts you need to assign users. While we provide you with your first users from the default identity provider to get you started, your organization has identity providers that you want to integrate.

SAP BTP supports identity federation, a concept of linking and reusing digital identities of a user base across loosely coupled systems. Identity federation frees applications on SAP BTP as well as the platform itself from the need to obtain and store the credentials of users and to authenticate them. Instead, the user base is reused from identity providers, which support the administration of digital user identities, authentication, and authorizations in a centralized and decoupled manner. To enable communication between SAP BTP and identity providers, you must cross-configure the communication endpoints of the involved systems, establishing a trust relationship between them.

Recommendation

We strongly recommend that you use a custom tenant of SAP Cloud Identity Services. Using SAP Cloud Identity Services eases integration with other SAP solutions. When setting up accounts you need to assign users. We provide you with your first users from the default identity provider. By using SAP Cloud Identity Services as a proxy to your corporate identity provider and hosting your users there, you gain a number of advantages:

Integrate the management of these users with your broader identity management strategy, hosted on your own identity providers. You control your own user lifecycle and single sign-on strategies throughout the entire landscape.

Enforce your own password and authentication policies, such as stronger passwords or multifactor authentication.

For platform users, the use of SAP Cloud Identity Services is mandatory. If you don't have a tenant yet, check [Getting a Tenant](#).

To connect your corporate identity provider to SAP Cloud Identity Services, see [Corporate Identity Providers and Configure Conditional Authentication for an Application in What Is Identity Authentication and SAP Cloud Identity Services](#)

Identity Provider and the SAP Authorization and Trust Management Service in SAP BTP Architecture
SAP Cloud Identity Services is a multitenancy-enabled identity provider for all SAP cloud applications and optionally on-premise applications. The service provides capabilities for authentication, single sign-on, authorizations, identity lifecycle management, and on-premise integration as well as self-services like self-

registration or password reset.

SAP has its own SAP Cloud Identity Services tenant, SAP ID service. SAP ID service is the default identity provider of SAP BTP and where you register to get initial access to SAP BTP. Trust to SAP ID service is preconfigured by default.

We recommend that you request your own SAP Cloud Identity Services tenant (see Getting a Tenant). To establish trust with your identity provider, proceed as follows.

For business users: Business Users

For platform users: Platform Users

Related Information^

Map User Attributes from a Corporate Identity Provider for Business Users

Map User Attributes from a Corporate Identity Provider for Platform Users

Settings for Default SAML Federation Attributes of Identity Providers for Business Users

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/tutorials-for-sap-authorization-and-trust-management-service>

Title: *Tutorials for the SAP Authorization and Trust Management Service | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Adding

Authentication and AuthorizationTutorials for the SAP Authorization and Trust Management Service

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Tutorials for the SAP Authorization and Trust Management Service

Follow the tutorials below to get familiar with the SAP Authorization and Trust Management service in the Cloud Foundry environment of SAP BTP.

Tutorials for the SAP Authorization and Trust Management service in the Cloud Foundry environment

Language / Framework

Link

Learn how to secure a basic single-tenant Node.js application. Start with a Node.js application that uses the express framework and SAPUI5 to display a list of products and add the security components step by step.

Node.js

SAP Developers

Learn how to secure a basic java application. This tutorial starts with a Hello World Java application built with SAP Cloud SDK.

Java, SAP Cloud SDK

SAP Developers

Learn how to build a cloud-native Node.js application that features secured service-to-service communication. The application shows you two different ways of securing service-to-service-communication (by propagating a business user or using a technical user).

Node.js

GitHub

Learn how to secure microservices in SAP BTP using spring-xsuaa and Spring security. Furthermore, learn how to test the secured application using the java-security-test utilities.

Spring (Boot)

GitHub

Learn how to add multitenancy to a node.js application and make it available for other subaccounts using the SaaS Provisioning service and the XSUAA.

Node.js

SAP Developers

Learn how to secure microservices in SAP BTP. This sample provides J2EE Configuration using web.xml and uses the SAP Java Buildpack.

J2EE, SAP Java Buildpack

GitHub (SAP Java Buildpack version >=1.26.1)

GitHub (SAP Java Buildpack version <= 1.26.0)

Learn how to use the java-security library to perform JWT Validation as part of your Java application. Furthermore, learn how to test the secured application using the java-security-test utilities.

Java

GitHub

Learn how to validate OAuth tokens using a Python library. Use this library to add authentication in your Python application.

Note

This library isn't part of an SAP BTP license. However, it belongs to a related open source project.

Python

GitHub

Learn in this reference application how the service fits into a complete architecture of microservices that interact with each other propagating user information.

Java

GitHub

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/what-is-sap-authorization-and-trust-management-service>

Title: *What Is the SAP Authorization and Trust Management Service?* | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology PlatformSecuritySAP Authorization and Trust Management ServiceWhat Is the SAP Authorization and Trust Management Service?SAP Business Technology PlatformEnglish

Provide feedback on our search

à

What Is the SAP Authorization and Trust Management Service?

Get a high-level overview of the concepts that underpin the SAP Authorization and Trust Management service for SAP BTP in the Cloud Foundry environment.

The SAP Authorization and Trust Management service lets you manage user authorizations and trust to identity providers. Identity providers are the user base for applications. We recommend that you use an SAP Cloud Identity Services tenant, an SAP on-premise system, or a custom corporate identity provider. User authorizations are managed using technical roles at the application level, which can be aggregated into business-level role collections for large-scale cloud scenarios.

Environmentà

The SAP Authorization and Trust Management service is available for consumption in the following SAP BTP environments:

Cloud Foundry

Kyma

Neo

Note

This documentation refers to SAP BTP for multi-environment subaccounts.

If you're looking for documentation about the Neo environment, see *Authorization and Trust Management in the Neo Environment*.

Featuresà

Use your corporate or a default IdP

Enable user management for your applications by handling authentication to an external identity provider. Start with SAP ID service as a pre-configured easy-to-use identity provider. Switch to your corporate identity provider for customized user management.

Enable role-based access to applications

Enable different privileges to users accessing your applications based on roles.

Overview

The following figure shows a high-level overview of components, which comprise an SAP BTP business web applications and how these applications are embedded in the Cloud Foundry environment. Further details have been omitted for the sake of simplicity. It's further assumed that the Cloud Foundry environment is set up with basic configuration (that is, container-to-container networking isn't configured). The components and their interactions are depicted in the following block-diagram.

Application, Microservice, and App

The components and their interactions are depicted in the previous block-diagram. It shows a runtime platform for business web applications. These are referred to as applications. An SAP BTP application is implemented in

an architectural style that structures the application as a collection of loosely coupled components, termed microservices. Microservices can be deployed independently from one another. This eliminates the need to deploy the complete application if only a subset of its microservices have received new features or a bug fix. In the terminology of the Cloud Foundry environment of SAP BTP, microservices are referred to as apps.

Application Architecture

The application consists of a distinct gateway app with at least one or more resource apps. The gateway serves as a reverse-proxy and provides functionality for security and session management. The application router app is a standard implementation of the gateway and is used as the single point-of-entry for the application. It also serves static content, initiates the authentication process, checks on cross-site request forgery (XSRF) attacks, and forwards requests to the resource apps while propagating user information.

The resource apps can use the security client library, which also provides security functionality. As stated in the previous section, all apps represent microservices, in the meaning of an app engineered and operated according to the 12-factor paradigm. All apps run in their dedicated runtime containers, which are hosted on the Cloud Foundry runtime platform.

OAuth 2.0, Resource Owner, Client, Resource Server, and the SAP Authorization and Trust Management Service

The security functionality of SAP BTP is based on the OAuth 2.0 specification. OAuth 2.0 defines how a user - the OAuth 2.0 resource owner - can delegate all or a subset of the authorizations to a third-party application - the OAuth 2.0 client - without the third-party application needing to know the credentials of the user.

The Cloud Foundry environment uses a standard implementation of OAuth 2.0 to protect its platform resources (orgs, spaces, and platform operations on those entities).

However, the OAuth 2.0 specification is reused for SAP BTP with a proprietary implementation to protect the resources of business web applications powered by the Cloud Foundry environment. The proprietary implementation exchanges the responsibilities of the OAuth 2.0 entities, client and resource owner: the OAuth 2.0 client - represented by the application - holds all the authorizations. A set or sub-set of these authorizations is assigned to the user after authentication in the system. The application also acts as the OAuth 2.0 resource server because it contains the resource apps. All apps of an application operate under the same OAuth 2.0 client.

The SAP Authorization and Trust Management service (XSUAA) provides functionality for administrating and assigning application authorizations. It acts as the OAuth 2.0 authorization server and represents a typical reuse service. The SAP Authorization and Trust Management servicebroker creates a service instance for each application. Each app that wants to enforce authorizations with the security client library is then bound to this SAP Authorization and Trust Management service instance of the corresponding application.

Note

The Cloud Foundry environment also supports the following token grant types of Cloud Foundry.

Authorization code grant

Client credentials grant

SAML 2.0 bearer grant

Refresh tokens are supported as well.

For more information, see the Cloud Foundry environment's API reference of the User Account and Authentication and the related link.

Service, Service Broker, and Service Instance

A service is an app that includes service broker functionality. The service broker must implement the Open Service Broker API specification, for which the Cloud Foundry environment is a client. The service broker is responsible for advertising its service offerings and service plans to the Cloud Foundry environment of SAP BTP and acting on requests from the platform for provisioning, binding, unbinding, and deprovisioning.

A service instance represents a reserved resource and is an instantiation of a service offering for a service plan. The service offering is the advertisement of a service that the service broker supports. The service plan is a variant of the service offering and usually represents the costs and benefits of that plan.

The service broker binds the service instance to the consuming apps. The service binding contains information about the service (for example, URL, credentials), which the app uses to consume the service. Apps and services communicate with one another indirectly, using the Cloud Foundry router.

Reuse Service, Backing Service

As a service is an app that includes service broker functionality, it can also run as a microservice component

within an application. In this case, the service represents a reuse service. Services that don't represent components within applications, but rather run standalone, are referred to as backing services.

Authentication Against Trusted Parties Only

The apps of the applications are accessed either using the UI of a user agent or the APIs that the app provides. All requests must first go through the Cloud Foundry router. Users of a user agent must first authenticate against a configured identity provider. The identity provider and the SAP Authorization and Trust Management service have a special trust relationship, which is established through crossover metadata configuration between the two systems (not depicted in the diagram above). Authentication is processed according to the SAML bearer assertion flow and initiated during the processing of the first request. A series of redirects leads to a request for authentication from the user agent towards the identity provider. After the user authenticates successfully, the identity provider responds with a SAML bearer assertion confirming the user's identity. This SAML bearer assertion is presented to SAP Authorization and Trust Management service and the service determines the authorizations of that user. API clients receive their credentials directly from, and authenticate directly against, SAP Authorization and Trust Management service.

JSON Web Tokens

A JSON web token (JWT) (according to RFC 7519) is an open standard that defines a compact token format for transmitting information between parties as a JSON object. This information can be verified and trusted because it is digitally signed. JWT tokens can be signed using a secret key pair (with HMAC algorithm) or a public/private key pair using RSA.

The JWT token contains header and claims information (for example, issuer, subject, expiration time, consumer-defined information), and is digitally signed with the private key of the authorization server (UAA service). The cloud or business application has a trust relationship with the authorization server. The trust is configured in the <VCAP_SERVICES> environment variable for the application router and each microservice of the business application. <VCAP_SERVICES> contains a credentials string for the UAA, which is created by the respective service broker when the application router and/or the microservice is bound to the UAA service instance. The credentials string contains, among other things, the public key corresponding to the private key of the UAA. This public key is used to verify the token signature.

Related Information

<http://saml.xml.org/saml-specifications>

<https://tools.ietf.org/html/rfc6749#section-1.4>

SAP Authorization and Trust Management Service

Cloud Foundry API Reference for User Account and Authentication Server API

Security in the Kyma Environment

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/working-with-role-collections>

Title: *Working with Role Collections | SAP Help Portal*

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Security

Administration: Managing Authentication and AuthorizationWorking with Role Collections

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Working with Role Collections

As an administrator, you group application roles in role collections. You then assign role collections to application users.

Application developers have defined application-specific role templates in the security descriptor file. The role templates contain the role definitions. You can assign the role to a role collection.

Tip

Application developers can even directly define role collections with default roles. For more information, see [Create Role Collections with Predefined Roles](#).

Typically, these role collections provide authorizations for certain types of users, for example, sales representatives.

Once you have created a role collection, you can pick the roles that apply to the typical job of a sales representative. Since the roles are application-based, you must reference the application to see which roles come with the role template of this application. You are free to add roles from multiple applications to your role collection.

Finally, you assign the role collection directly to users or indirectly to attributes such as groups. For more information, see the related link.

Prerequisites[^]

Your user has administration rights in this subaccount and or global account. For more information, see Security Administration: Managing Authentication and Authorization or Role Collections and Roles in Global Accounts, Directories, and Subaccounts.

The roles defined by your application developers in the application security descriptor are available in the SAP BTP cockpit. For more information, see Adding Authentication and Authorization.

The users are stored in identity providers that are connected to SAP BTP.

Default identity provider (SAP ID service). For more information, see Default Identity Provider.

Custom identity provider. For more information, see User Management in SAP Cloud Identity Services.

Note

SAP BTP provides default role collections. You can use the default role collections, but you can't change or delete them. For this reason, the Delete icon of a default role collection is grayed out.

You can perform the following tasks:

Define a Role Collection

Add Roles to a Role Collection

Delete Roles from a Role Collection

Assigning Role Collections to Users or User Groups

Assign Users to Role Collections

Delete Users from Role Collections

Assign User Groups to Role Collections

Delete User Groups from Role Collections

Related Information[^]

Security Administration: Managing Authentication and Authorization

Role Collections and Roles in Global Accounts, Directories, and Subaccounts

Limits for Technical Artifacts of the SAP Authorization and Trust Management Service

URL: <https://help.sap.com/docs/btp/sap-business-technology-platform/working-with-users>

Title: Working with Users | SAP Help Portal

HomeSAP Business Technology Platform (SAP BTP)SAP Business Technology Platform...Security

Administration: Managing Authentication and AuthorizationWorking with Users

SAP Business Technology PlatformEnglish

Provide feedback on our search

à

Working with Users

In the SAP BTP cockpit, you can see the users of your global account or subaccount, user-related identity provider information, and their authorizations. In a user's overview, you can create and delete users, and assign role collections. You can also display an overview of the role collections, where you can drill down all the way to the role, and see the application that the role belongs to.

Overview[^]

All users in the global account, subaccount, directories, and environments are stored in identity providers.

Users in the subaccounts of SAP BTP are either stored in the default identity provider or in a custom identity provider.

SAP BTP creates a copy of the user in the global account or in the subaccount when a user-related action happens. This copy of the user is called a shadow user. Global account or subaccount administrators of SAP BTP assign role collections to shadow users. To comply with data protection and privacy regulations, administrators can be obliged to delete shadow users who belonged to employees who left the company.

Remember

For access tokens of subaccounts created after September 23, 2020, user IDs preserve the case that they are created in. This means that both uppercase and lowercase letters can be used. However, this does not qualify as a means to differentiate between them; for example, denise.smith@example.com and Denise.Smith@example.com are considered to be the same.

Subaccounts before this date convert the user IDs to lowercase.

Note

User data of shadow users is regularly updated after authentication at the identity provider.

When a user authenticates against SAP BTP, an authentication request is forwarded to the trusted identity provider (for example, SAP Cloud Identity Services). After successful authentication, the identity provider creates a user token based on its configuration and sends it back to SAP BTP. In SAP BTP, the user data is updated according to the token.

Prerequisites

You have administration rights in this global account, subaccount, or directory. For more information, see [Security Administration: Managing Authentication and Authorization or Role Collections and Roles in Global Accounts, Directories, and Subaccounts](#).

The users are stored in identity providers that are connected to SAP BTP.

Default identity provider. For more information, see [Default Identity Provider](#).

Custom identity provider. For more information, see [Trust and Federation with Identity Providers](#).

Use Case

Description

Enable a new hire to log on to the subaccount and have access to necessary resources.

If automatic creation of shadow users was switched off for this identity provider, shadow users aren't created automatically in the subaccount (see the related link). This means that the new user can't log on to the subaccount. As an administrator, create a shadow user that corresponds to the user in the identity provider and assign the necessary role collections to this user.

See [Create Users](#).

If automatic creation of shadow users was switched off for this identity provider, shadow users aren't created automatically in the subaccount (see the related link). Add the user group to the role collections that are necessary for this user if the user belongs to a user group in the identity provider.

See [Assign User Groups to Role Collections](#).

Enable a new hire to have access to necessary resources.

A shadow user is automatically created in the subaccount. This means that the new user can log on to the subaccount, but the user doesn't have any authorizations. As an administrator, you have created new role collections or you want to use existing ones for the new hire. You grant authorizations by assigning the role collections to this user.

See [Assign Users to Role Collections](#).

Enable a new hire to log on.

If automatic creation of shadow users was switched off for this identity provider, shadow users aren't created automatically in the subaccount (see the related link). As an administrator, create a new shadow user in the subaccount.

See [Create Users](#).

If your subaccount uses the default trust configuration, you can also create a shadow user there.

See [Add Users from SAP ID Service for Multi-Environment Subaccounts](#).

Review authorizations of individual users.

You want to find out which authorizations have been granted to users. To do so, access the list of all users, find the users you want to review, and check the role collection assignments. From the user's role collection, you can drill down to the roles of the role collection. You can also assign and remove role collections.

See [Find Users and Their Role Collection Assignments](#).

Delete users of employees who have left the company.

You want to find and delete users of employees who have left the company, but their users still exist in the system.

How to find users, see [Find Inactive Users](#).

How to delete users, see [Delete Users](#).

Automate the provisioning of users.

You want to provision users to SAP cloud solutions, such as SAP BTP so that you can manage your identities centrally.

How to provision users to SAP BTP, see [Provision Users to SAP BTP Accounts](#).

Find users who have never logged on.

You want to find users who never logged on. For example, they could be manually created shadow users with a typo in their user ID, so they don't match the user ID provided by the identity provider. They were never used,

and it might make sense to delete them.

See [Delete Users](#).

Delete shadow users to comply with data protection and privacy regulations.

For data protection and privacy reasons, administrators might be legally obliged to delete shadow users who belonged to employees who left the company. You can find and delete the shadow users in the SAP BTP cockpit.

See [Delete Users](#).

You can also delete the users using APIs.

See [Delete Shadow Users for Data Protection and Privacy Using APIs](#).

Related Information

[Switch Off Automatic Creation of Shadow Users](#)

[Security Administration: Managing Authentication and Authorization](#)

[Role Collections and Roles in Global Accounts, Directories, and Subaccounts](#)
